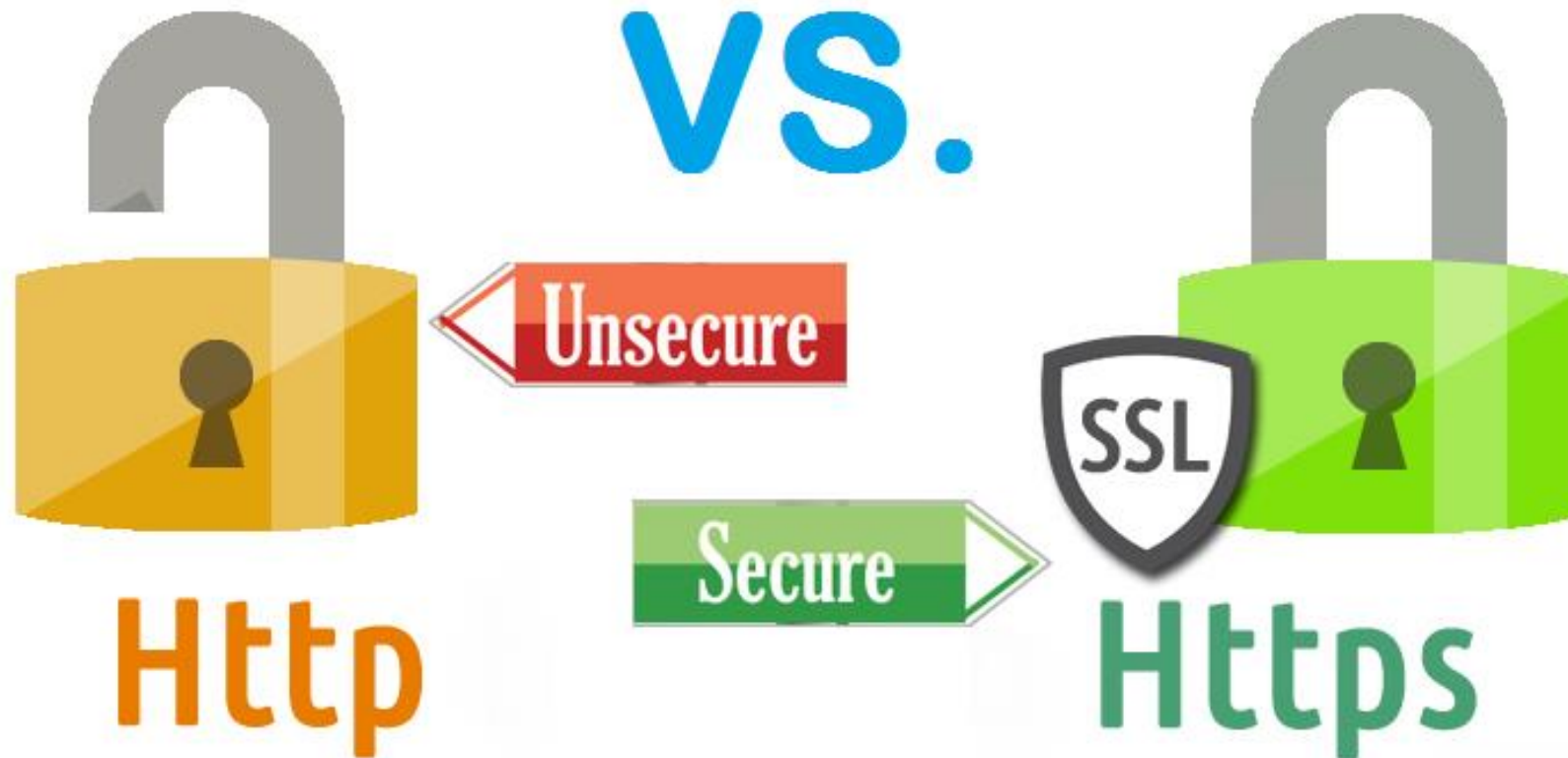


Technologies for E-Commerce

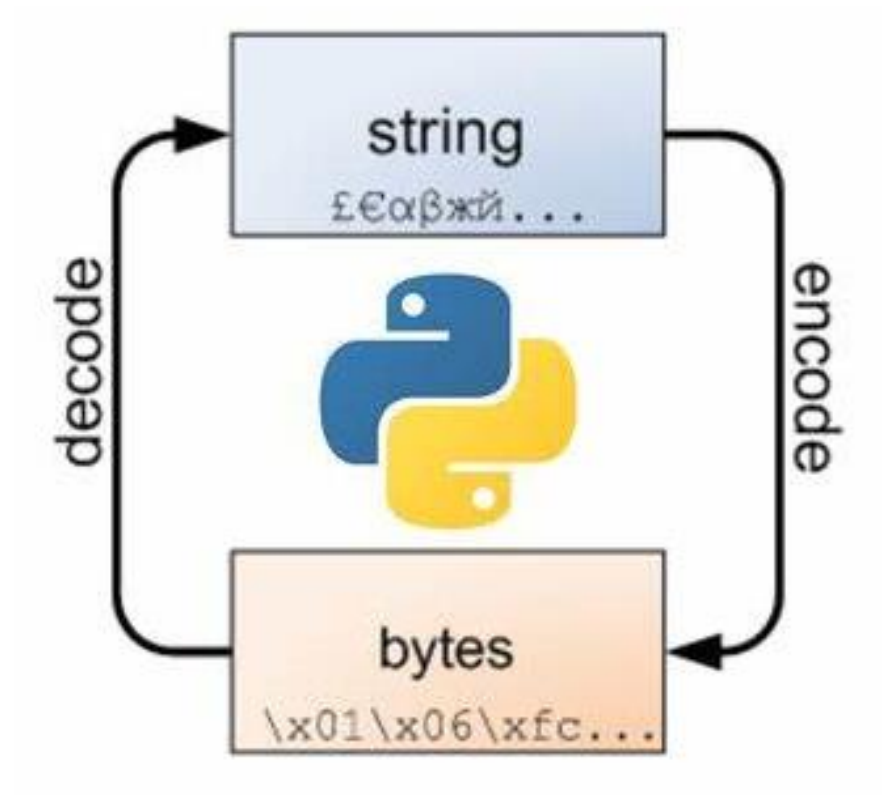
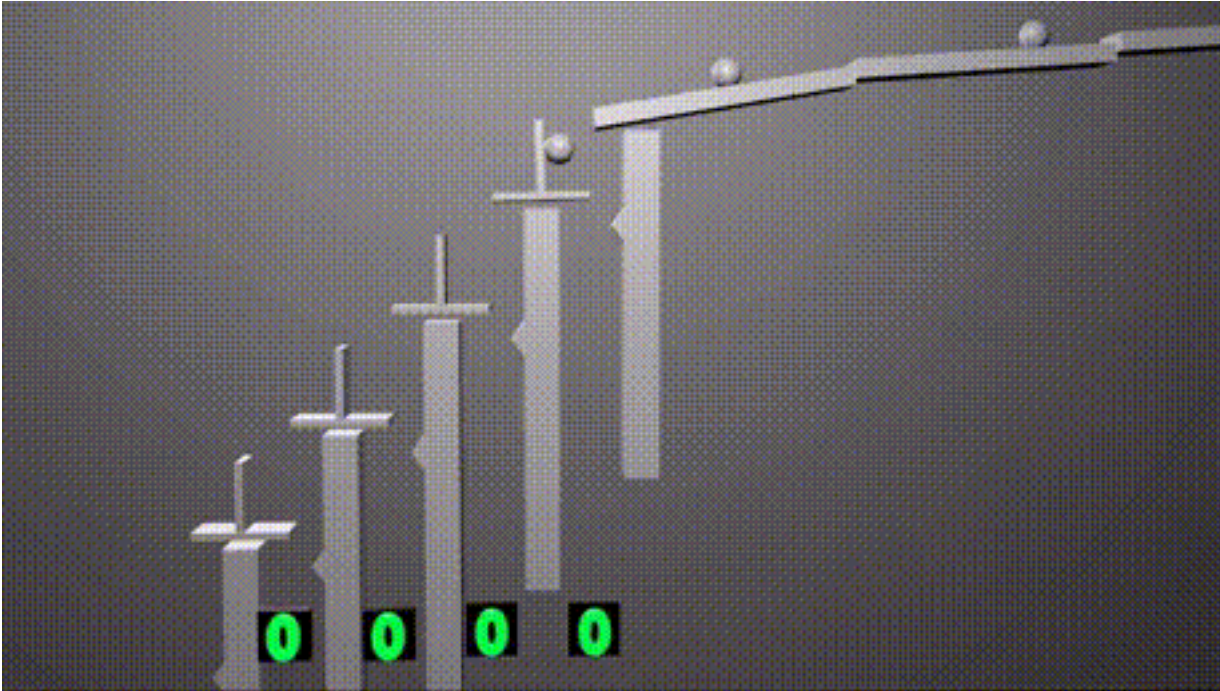
CAN302

**Department of Communications and Networking
Xi'an Jiaotong-Liverpool University (XJTLU)**

Lecture 8 – Secure the Web

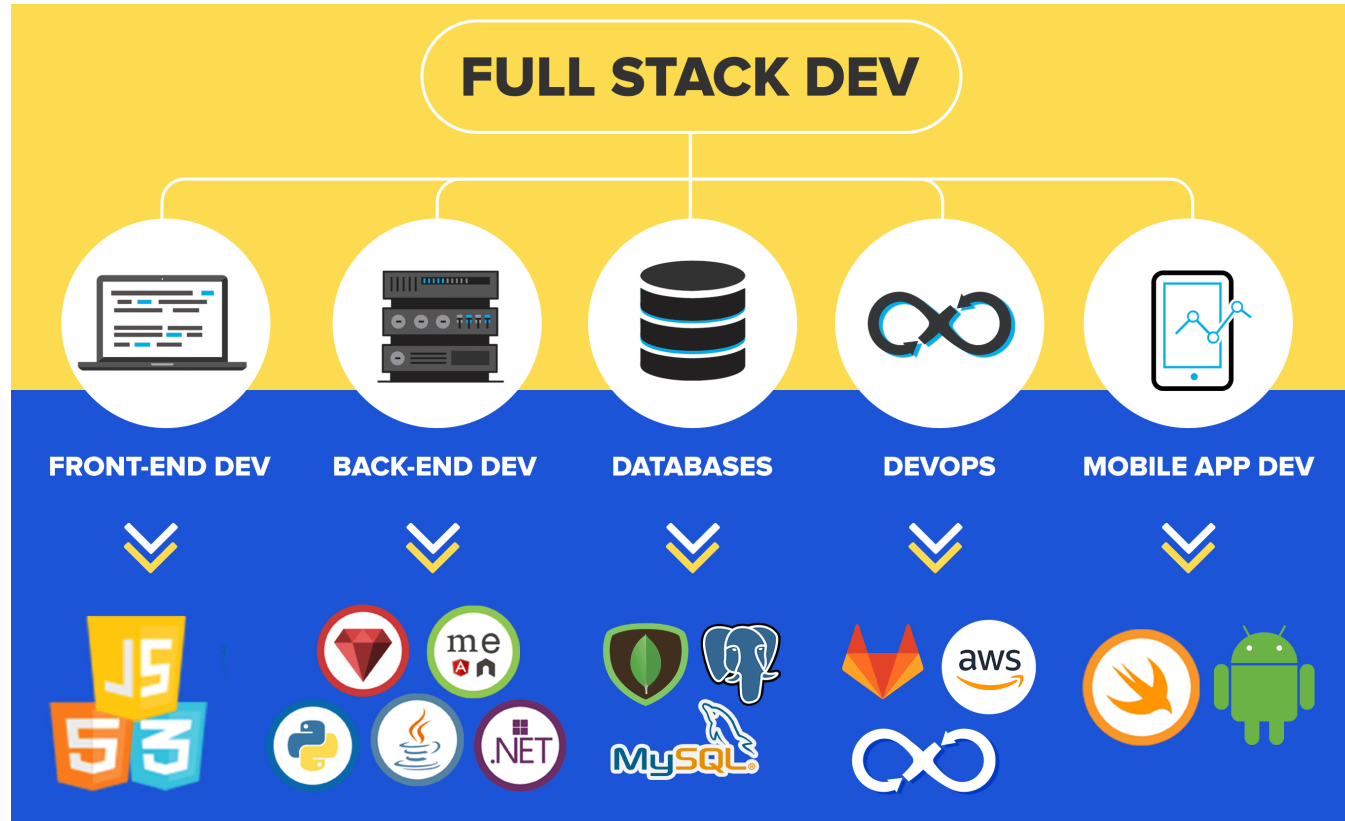


Encoding



- Encoding is the the process of converting data from one form to another.
- Decoding is the revers process

All digital data is number



full-stack-development-min.png

```
0 89504E47 0D0A1A0A 00000000 49484452 00000AA9 00000679 08030000 00F44A9C 8C000000 0467414D 410000B1 8F08FC61 05000000 01735247
56 4200AECE 1CE90000 026D504C 54451B54 D71C5308 211E1F24 23233232 32554544 68B345FC D850FFFF FF1B5403 FFC60E34 3537F3F3 F3402F1F
112 336691FF FFAFCDB 53F89628 FA7A1B00 00000968 AD6A2D66 5382A28E C74FFEDB 4FC33737 04AEAE36 C2DC524E 4E82C564 E24328FF 9601FFC0
168 31F86C25 FCA225EC ECEEFEE6 814A4747 01618A54 C8E10139 C536744A FAF30F4 F4F605A9 E0942D2D E48E0197 959A2458 CEF4FAFE E9F4BA5
224 B6C93939 39509646 5E5E5DFF CA20EBE9 EGFFFAF0 41403FE4 5C5CF9F8 F862215E D6DEF51F 2C3D8C8D 8DA4A3A3 47C8DEF8 7F24FEFF ACF8E01
280 738FE230 5FC667AD 52FFF8E1 53181B72 7272FA89 33FF3302 487B9BDF EBF9FCE0 74F9911D 3665DA80 7F802A2A 2AFDD064 57A8482D BEDAA896
336 3FFFF2C1 C9C2C725 5DD9FED2 43D58841 89C8F00F E2E5F9AE 65D64141 ECBE21F9 B87081D5 EE77B565 424032FF EF99CFEF FA2488EB D1D00188
392 AGE76766 66F6DEBA EDE3D139 68B84873 DC0F4A7E 47C3EED0 7E428CB8 B8628FAE A1789EC6 D7E24978 AC0E46CD EFCF4ED0 D9DC69CB ECFEE88F
448 88C446CA 2C2C89D0 6CF89951 8CAEC61A 1919C7D6 F68BE9F8 799CBA18 54C1B1C8 D8375488 4860AFE7 9434F8C8 8FF7D0A9 5880DEEA 7A287A41
504 7606121F B4765B9D B8CFEEEA E6A8E2F7 205B84FA A943825F 8497DBF4 90726EF1 CAAD8DC6 65639F71 60699D01 3C4633AB DAFFD583 56439021
560 72995F90 DCAEAEEA 71748FAB 985CE769 032F98D6 246B0826 82D8C1A8 43FD09D6 796A3D36 5363899D 873F4AA7 559189C9 4F4DC3BA 70DF7A7E
616 A7D1755D 3378FCBE BE147E84 53563317 90C26787 BE984264 AD080A64 6738D6E7 BC2D3D50 4DA908D0 7E3FD014 11908D6E 4ABEC885 A987378D
672 C1D55E62 FC9D9D80 88946C28 22102866 1944A8D7 D7F83800 03D01149 44415478 DAECDD38 92D8C616 0660673D 193AC05 7013CC91 20401512
728 04580157 818D5FA2 18AF9139 63CB5743 82E4F795 86A5925C D61424E0 FCE8C7E9 8F020000 1CD15F2E 01000092 2A000048 AA000048 AA000020
784 A9020020 A9020080 A40A0000 922A0000 922A0000 48AA0000 48AA0000 20A90200 20A90200 80A40A00 00922A00 00922A00 00A40A00 00A40A00
840 0020A902 0080A40A 0080A40A 0000922A 0000922A 000048AA 000048AA 000020A9 002080A4 0A0080A4 0A000092 2A000092 2A000048 AAF09662
896 BC7E85F2 553E96D7 E88BF152 0F43D0B9 CFE7EA03 F8695575 6E9A7618 EACBA9EB E78B312D 37679C7E 0A48AFA0 5E4135A5 520CAF1F B1FC2485
952 7EAC8746 388587C6 D666A8C7 6E49A9F9 337A6281 A0A0EF18 57E71FD7 8F6E9451 E161E9F4 565E1D8B 72738690 425C2641 004915D0 27A7E6A0
1008 1ABBC830 4DF35788 7A597D59 40817B39 87976E17 4FAD0200 4915D644 8A31A570 FDE8C7E1 2C10C071 D3EA30F6 06534152 85F71850 8DA1B8DC
1064 9AF1378E 0A475800 00692F8D 671648AA F05EAFB8 C7D475CE BF6C431E C7F104FC B8711CE7 86185FE5 D5AABDF4 46564152 85B71952 3D855FEF
1120 3AE8B7AD C6361DC3 5D0FC8BE 281D386E EC816A47 D0772455 78D50288 EC21CEC5 803FEF32 C87A2D8C CDD21907 78F4FD0A 8D5F8D01 D573DDE7
1176 36AB292C 9F5A5881 A40AAF11 5473584D 31A518C3 A955589F 6252F0E0 386F9631 F4A7BAFD 585A6D4F 610EAA21 E8580592 2ABC5052 F056F6C
1232 3EAF48AD 9AE1D497 F1198333 709C7836 CF83F4A7 A1F925AB 36E374A7 A6881D30 E7C60549 155E408A 215E7E69 49D05450 5C066804 5538D0D0
1288 1A420A29 C6908ABA F9A8F68D 8ECF9798 D637D018 25590054 E1E9E85E 3EE6E672 FED4D18F A98BF2B8 318588FC 67C0E395 598E906 0C298530
1344 85D54F08 56A7AC9A 96B74849 15245578 FABA17F7 E3A9D371 54C329AE 456E1E01 F7680A65 4475D93A 9552E886 EA97AC1A 85549054
1400 E155A081 29C852CB 786A533A 89976D54 C9502A1C EA76FD25 83C6BCC3 2A5E9A7D C78EE634 AF519556 41528567 D785FBF1 D0761A4E 4DE54A05
1456 B912BA44 701CD8B4 7E59919A E6CE54DD 80D0F0E9 76D6A882 A0A4F5A E9E619FD FCD907F8 96548386 A9F0ACF7 F5A74500 55D0C7BC 55328494
1512 92D40A92 2A3C9375 4E7F3CE7 8661EA7E 1EA5019E 2FA9C6F2 E289C4D5 F3186248 798C554E 0549159E AEAC4D75 A0D00E66 AC863E99 2F84678E
1568 A53EAF7 E3AA438F CEC0E148 AAF05431 358518E2 A5A78FC 5F685A52 D3E069AD EBCAF759 B5BAC2D0 55D0D720 A9C27315 B594F00C C9A9A0A7
1624 5F2A3CF7 E8679EE4 9F9269D7 6C7B8ABD 7EEB3807 48AAF00C 15ADEC15 1EB716AA E7713951 35EAA085 CFFB82BA 8D0EDD08 6AD51442 82521524
1680 5578AE88 3AAC832E 551D87D6 88494183 27BDA9E7 833A620A 718DC1A7 D5AAF9CC 2A405285 E73805D1 BED94FFC 7CB5C38F 9C0AAFD7 7797FC14
1736 52D7ACC3 AA8DE673 20A9C293 D4809887 529DCE58 D345350C 5E51ACB7 C61E633E 27C01A00 9054E1D0 952BC7B8 2EB60AD6 742E08BC E8DEBEE0
1792 ACFAA8E7 D53016A2 83A4A0C7 8EAA29C5 GDCFBF01 5578E538 BE5E1BD1 857D59F8 93960749 150E2AE5 CE8A7158 A27A3E29 5FC082F7 7B0A216C
1848 0B7D9A7E FA45373C 48AA70EC F2D5AD95 ABCD9548 E182D714 63486168 987CEE82 2E7420A9 C2910857 8E959499 F9877778 299D3F63 8D04A298
1904 43014915 8E5D8CC6 6033F052 CC0C82C0 884605D2 EA635C5F 4F475705 24553872 E5A339F6 0D1648C8 1A49155E F27E5F97 A16F487E 6A970524
1960 5538E5C5 4A415350 9DCE0297 4FE12DCA 1002B8A0 2BAAF3A6 2A7D5541 502803AA 87D31597 83A78197 8FAA7177 886A1955 80555541 52856315
2016 ABDD0C6A 3A8614CC FAC33848 F9A8E454 EFA26A8A 6E779054 E13829B5 8C9EE2B8 558851A5 82777904 A410436D AD2AA8AA 70609765 80EA6E25
2072 5E2E090C 4F540DE1 B2840088 882020A9 C291AA54 D887A78A E441D6A8 E33FBCC9 F09F4259 97BE46D5 1D0D0972 2A1CAB52 90760615 E3D26711
2128 78884740 2A6FAC63 9E55897E 9DACS307 49150E24 7D57E44 35ADC508 78F937D5 328D1252 0C97A559 55E74515 2455787C 854A21C6 78F8DEC9
2184 16A881C4 BA46D573 BF8CA8A AC20A9C2 E3C8B5A8 297BA93E AE64D33F BC73565D 3A00331 05880541 528587C6 04144883 A76D0E5F 3F84DC5F
2240 1178CF77 D698C272 044018A3 A80A922A 3C52DEEE 98D63354 A793A9E4 5478E8AC BA46D57C AEAA8D55 20A9C283 085388E3 3C5DFD6 9062822E
2296 00DE6F79 106348C1 9D5F5D4F 8EA0A349 151E29E6 1FFD39F7 A5F938F7 79AACFF4 3FB8CF73 1A35F7F3 AE2A6FAE 20A9C283 A3EAB98 6A6A4853
2352 7E495D82 37D1EA4A 10528C21 2C4DEB9A 58960801 922A3C46 0A61D89F 4A9392A5 AAF0868F 8332A312 37262D0D E0710092 2AD0CF32 4812538A
2408 A765F784 8A04CC0F 887A38B2 2E380504 24557898 89E57FD5 6AA30A4C F23ECB76 38002096 F0EAD01 922AD5CD 6C3FAA5 1EA94440 5EA0A9A2
2464 B2ABAA4C 413559AE 0A922A3C A222D247 279EA22D BEC0FC06 7BFD3ACD CDEB2EBA FF83A40A 8FAA47FD BCC587CE 58A900E6 D7D865A9 6AD58B18
2520 20A9C283 926A8BF6 A209FA53 01F94990 17AAC6A5 7F5D3B37 04F07C00 4915EE58 8FE28874 528DCA10 304BF979 9096AEAA 63D04EE5 0901922A
```

- Computer store all information as a series of 0 and 1
- The right HEX code is a part of the corresponding series of 0 and 1 for the left picture

Base64 Encoding

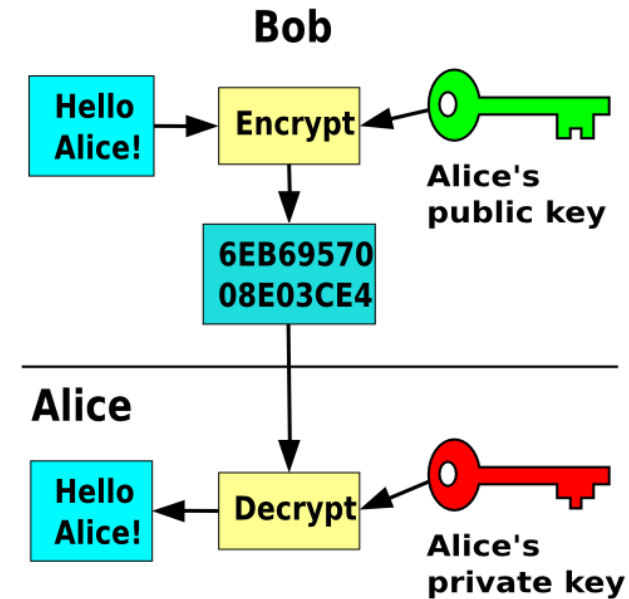
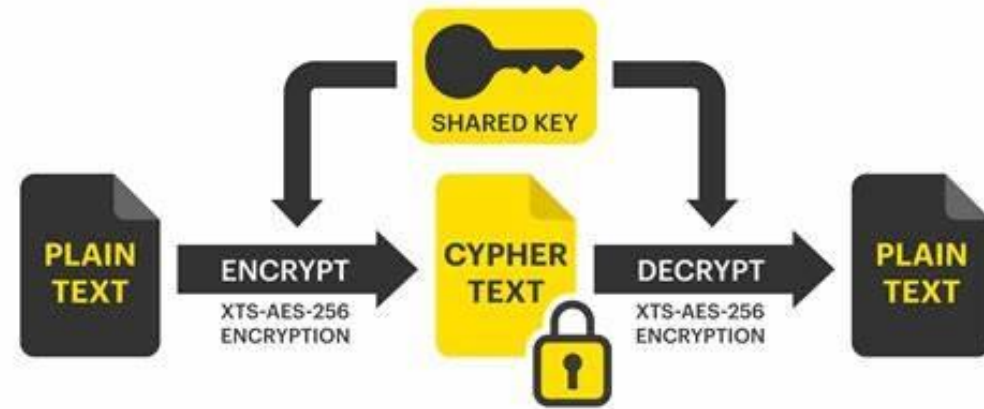
RHVyaW5nIHRoZSAxNnRoIGNlbnR1cnksIFZpZ2VuZXJlIGRlc2lnbmVk
IGEgY2lwaGVyIHRoYXQgd2FzIHN1cHBvc2VkbHkgdGhlIGZpcnN0IGN
pcGhlciB3aGljaCB1c2VkIGFuIGVuY3J5cHRpb24ga2V5LiBjbiBvbUgb
2YgaGlzIGNpcGhlcnMsIHRoZSBibmNyeXB0aW9uIGtleSB3YXMgcmV
wZWFOZWQgbXVsdGlwbGUgdGltZXMgc3Bhbm5pbmcgdGhlIGVudG
lyZSBtZXNzYWdlLCBhbmQgdGhlbiB0aGUgY2lwaGVyIHRleHQgd2FzI
HByb2R1Y2VkIGJ5IGFkZGluZyB0aGUgbWVzc2FnZSBjaGFyYWN0ZXI
gd2l0aCB0aGUga2V5IGNoYXJhY3RlciBtb2R1bG8gMjYyIChNb2R1bG8s
IG9yIG1vZCwgaXMgYSBtYXRoZW1hdGJlYWwgZXhwcmVzc2lvbiBpbi
B3aGljaCB5b3UgY2FsY3VsYXRlIHRoZSBYZW1haW5kZXIgb2YgYSBka
XZpc2lvbiB3aGVuIG9uZSBudW1iZXIgaXMgZGltZW1haWRlZCBieSBhbm90
aGVyLikgQXMgd2l0aCB0aGUgQ2F1c2FyIGNpcGhlciwgVmlnZW5lcmU
ncyBjaXB0ZXIga2F1IGFsc28gZWFFzaWx5IGJlIGJyb2tlbjsgaG93ZXZlci
gVmlnZW5lcmUncyBjaXB0ZXIga2F1IGJvZDdodCB0aGUgdmVyeSBpZGV
hIG9mIGludHJvZHVjaW5nIGVuY3J5cHRpb24ga2V5cyBpbmRvIHRoZS
BwaWN0dXJlLCB0aG91Z2ggaXQgd2FzIHbvb3JseSBleGVjdXRlZC4gQ
29tcGFyaW5nIHRoaXMgdG8gQ2F1c2FyIGNpcGhlciwgGhlIHNIY3JlY3
kgb2YgdGhlIG1lc3NhZ2UgZGVwZW5kcyBvbiB0aGUgc2VjcmVjeSBvZi
B0aGUgZW5jcnlwdGlviBrZXksIHJhdGhlciB0aGFuIHRoZSBzZW5yZW
N5IG9mIHRoZSBzeXN0ZW0u



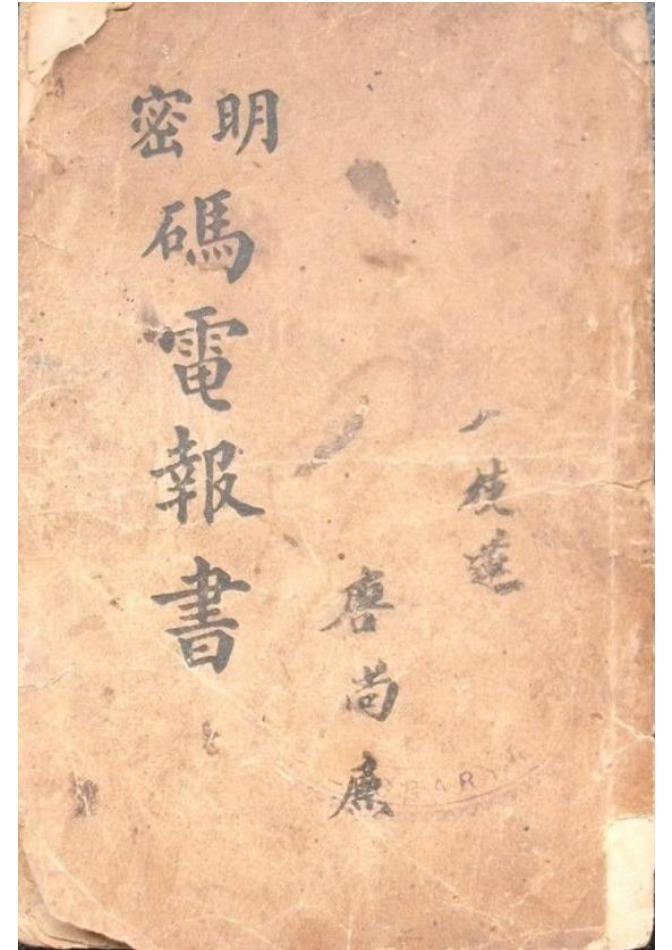
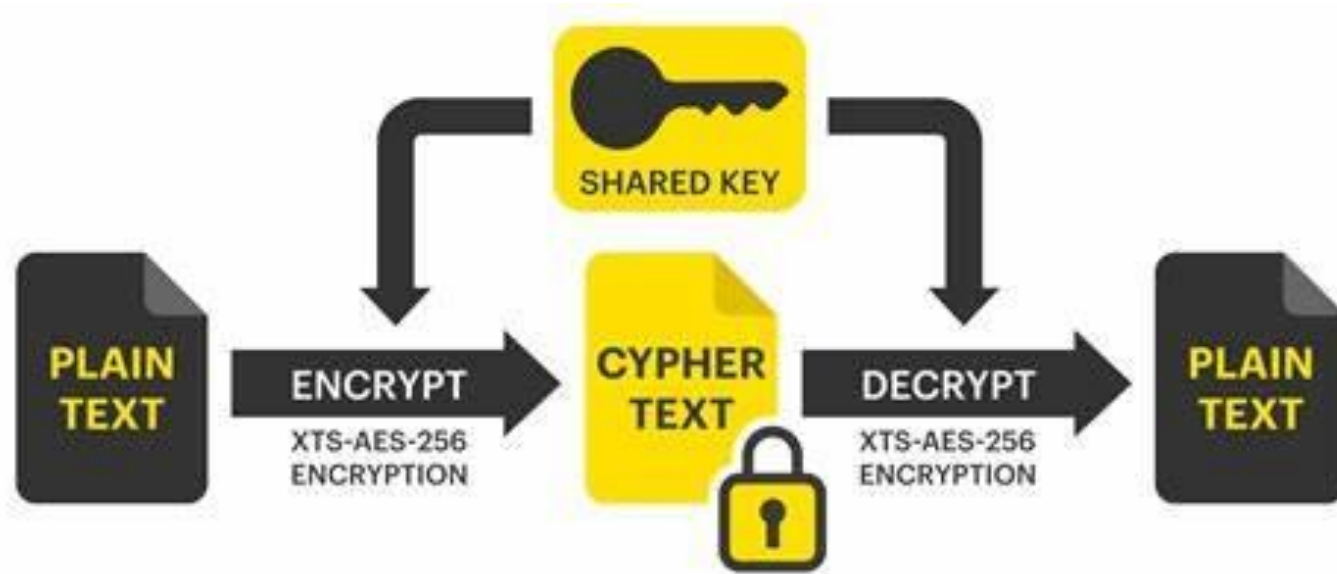
- Is **Base64** encoding one kind of **encryption**?

<https://www.zhihu.com/question/36306744>

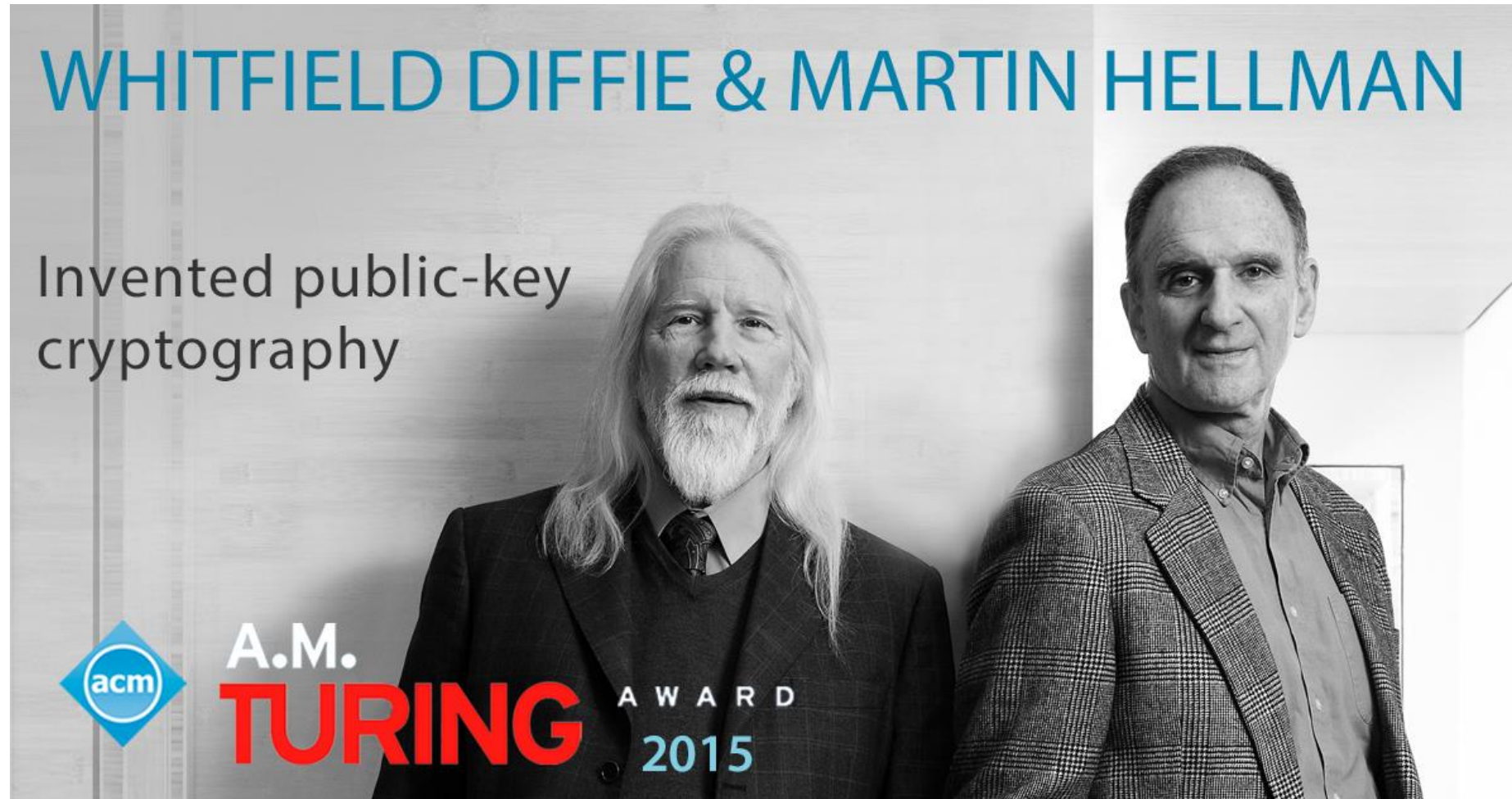
Symmetric and Asymmetric Encrypt/Decrypt



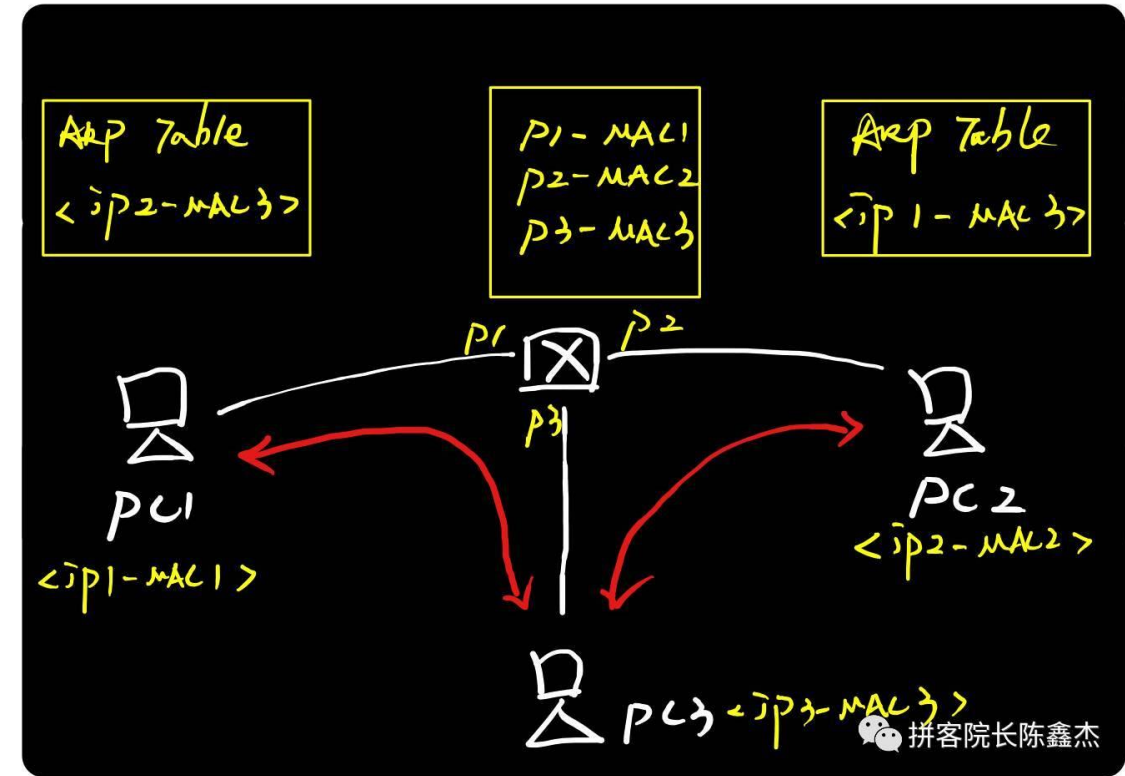
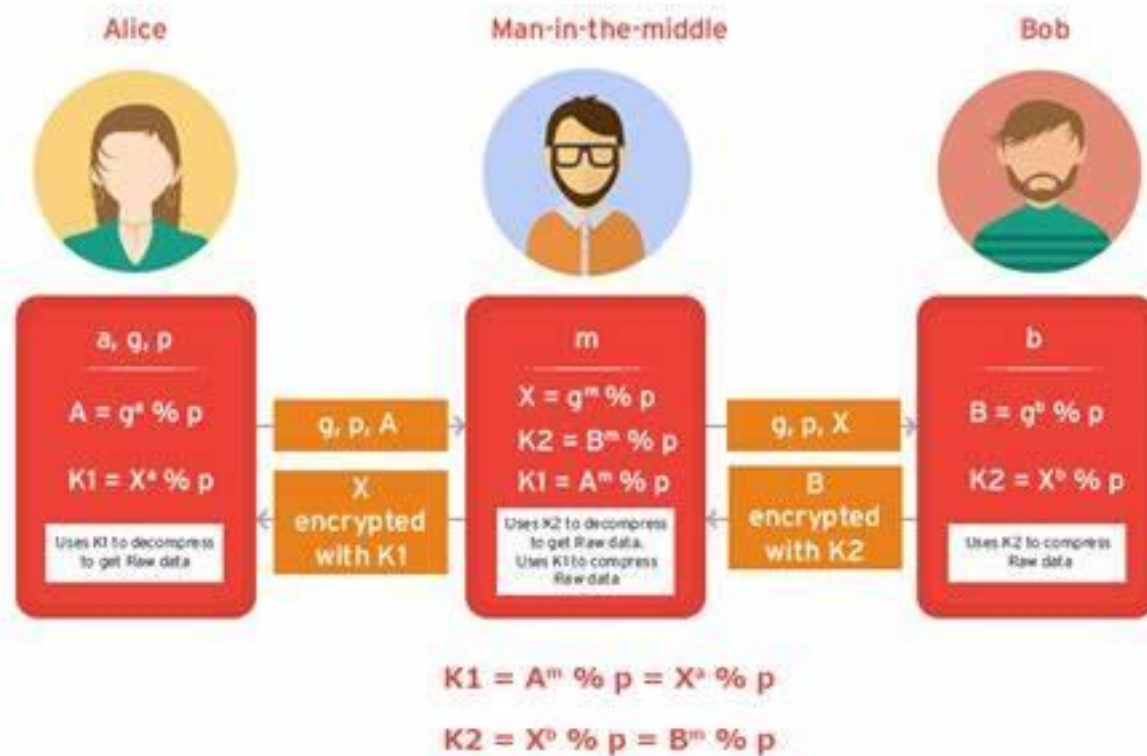
How to exchange the key safely



Generate the key by **A**symmetric algorithms

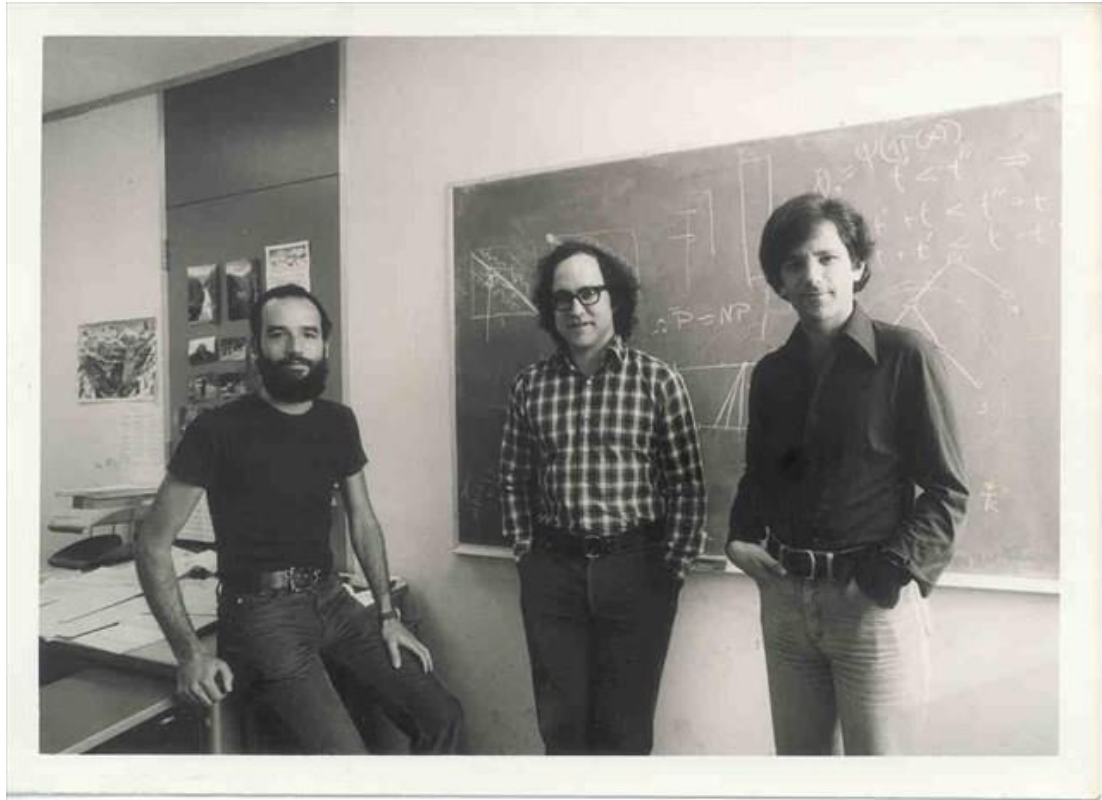


How about Middle-men?



- Only by D-H algorithm, **NO** way to make sure the public key is really from Alice or Bob

RSA asymmetric encryption



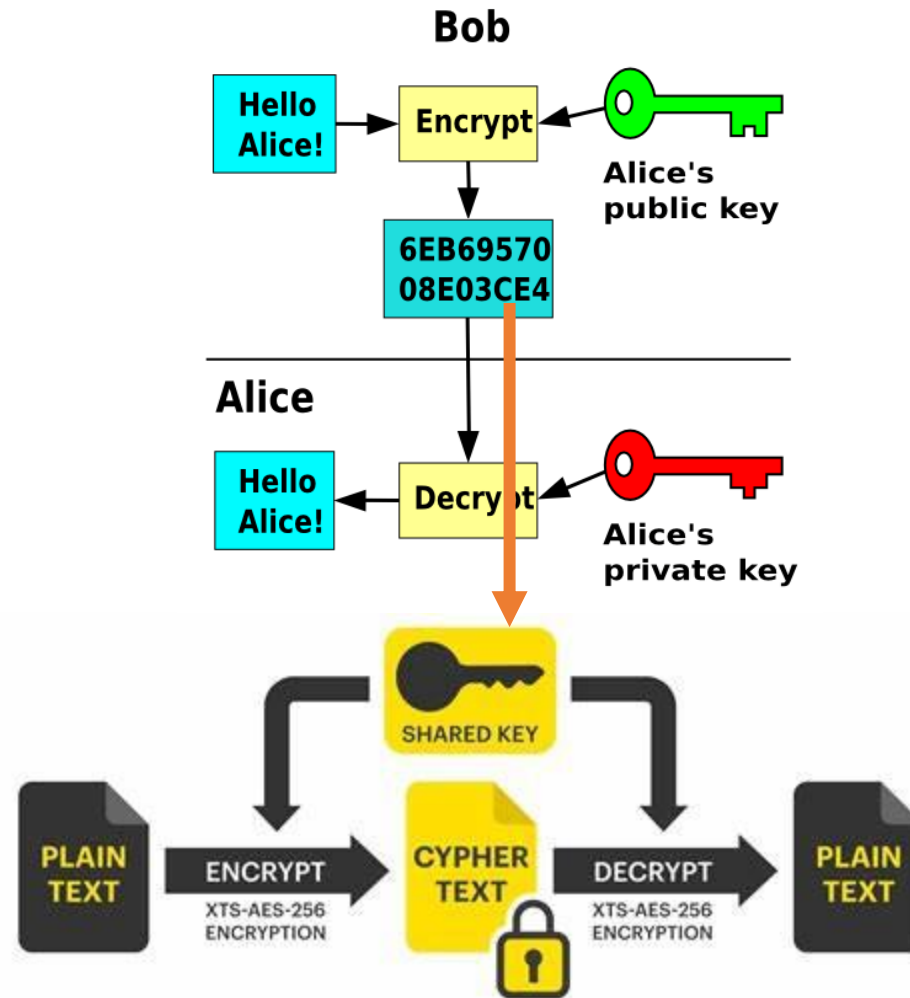
Rivest, Shamir and Adleman @1977

How RSA Encryption Works



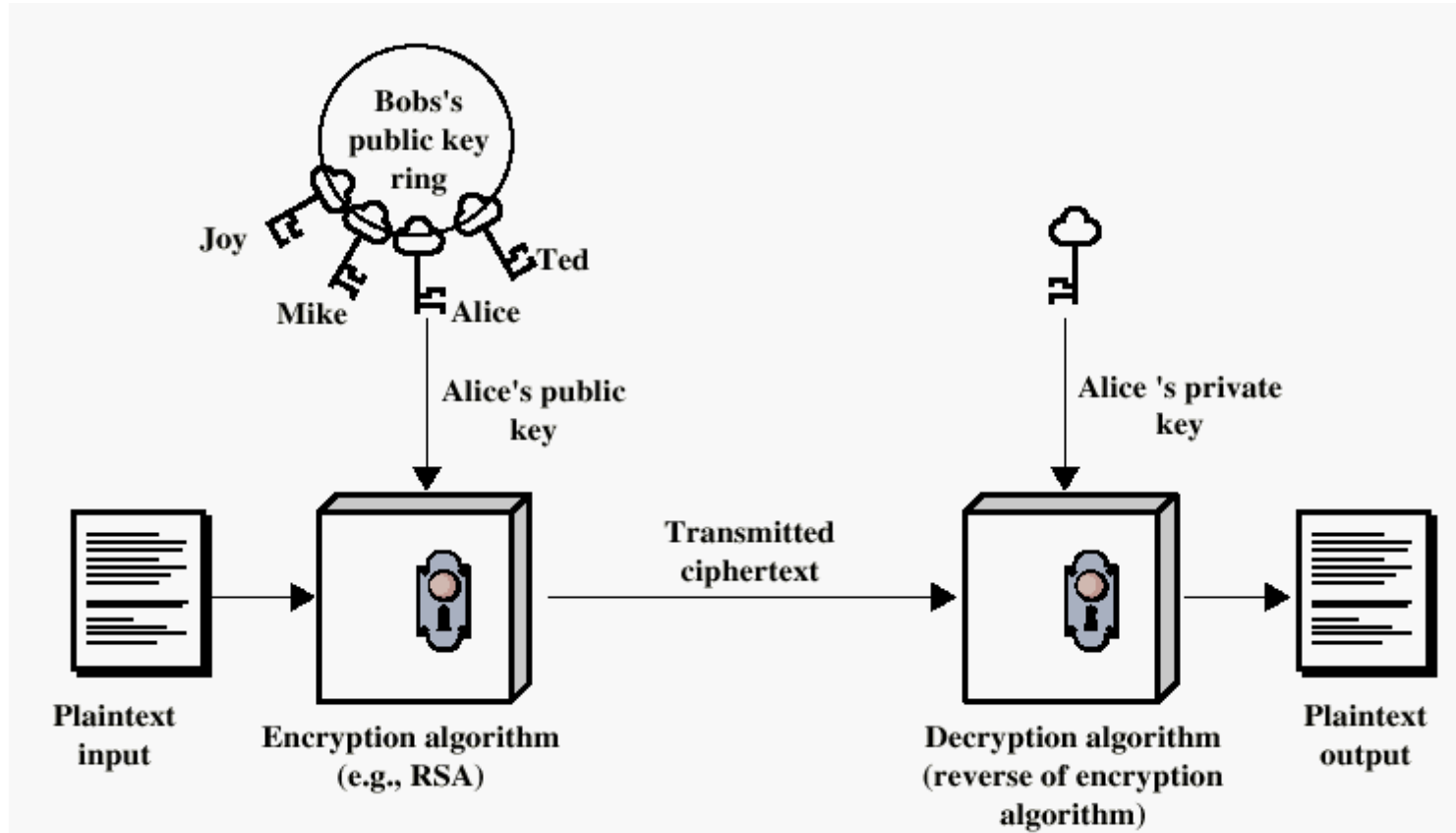
- Typically, it uses key pairs. Keep one privately and public another that everyone can access it.
- Most information are public (assume everyone can access the ciphered text and public key)
- There is **theoretical difficulty** to deduce the secret from the public information

HTTPS - symmetric + asymmetric algorithm



- Using asymmetric algorithm to generate a safe session key
- Session is encrypted by the symmetric algorithm

Challenges for public key management

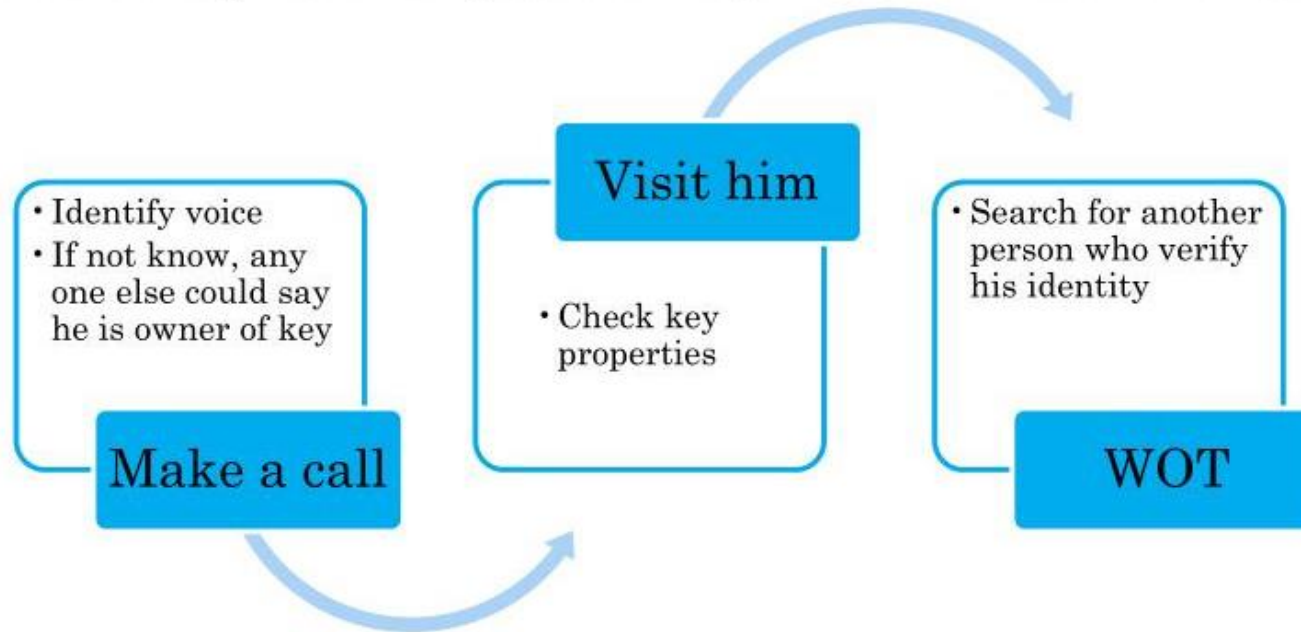


"On the Internet, nobody knows you're a dog."

- How to verify the key's real owner?
- How to manage so many public keys?

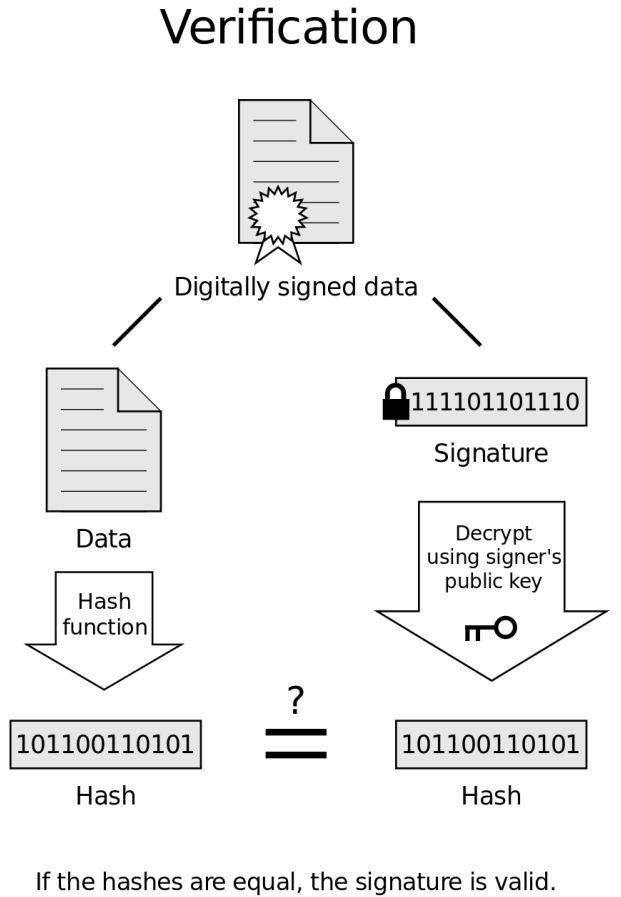
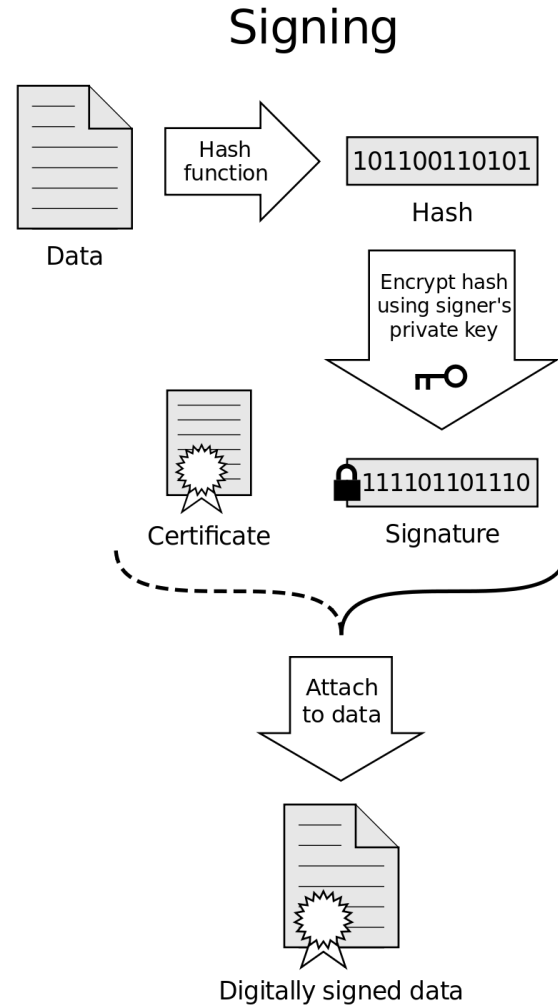
A good practice - PGP (Pretty Good Privacy)

- Anyone can upload keys to “Key Servers”-- even **fake keys**
- **Authenticity of this *public key* can be checked as**



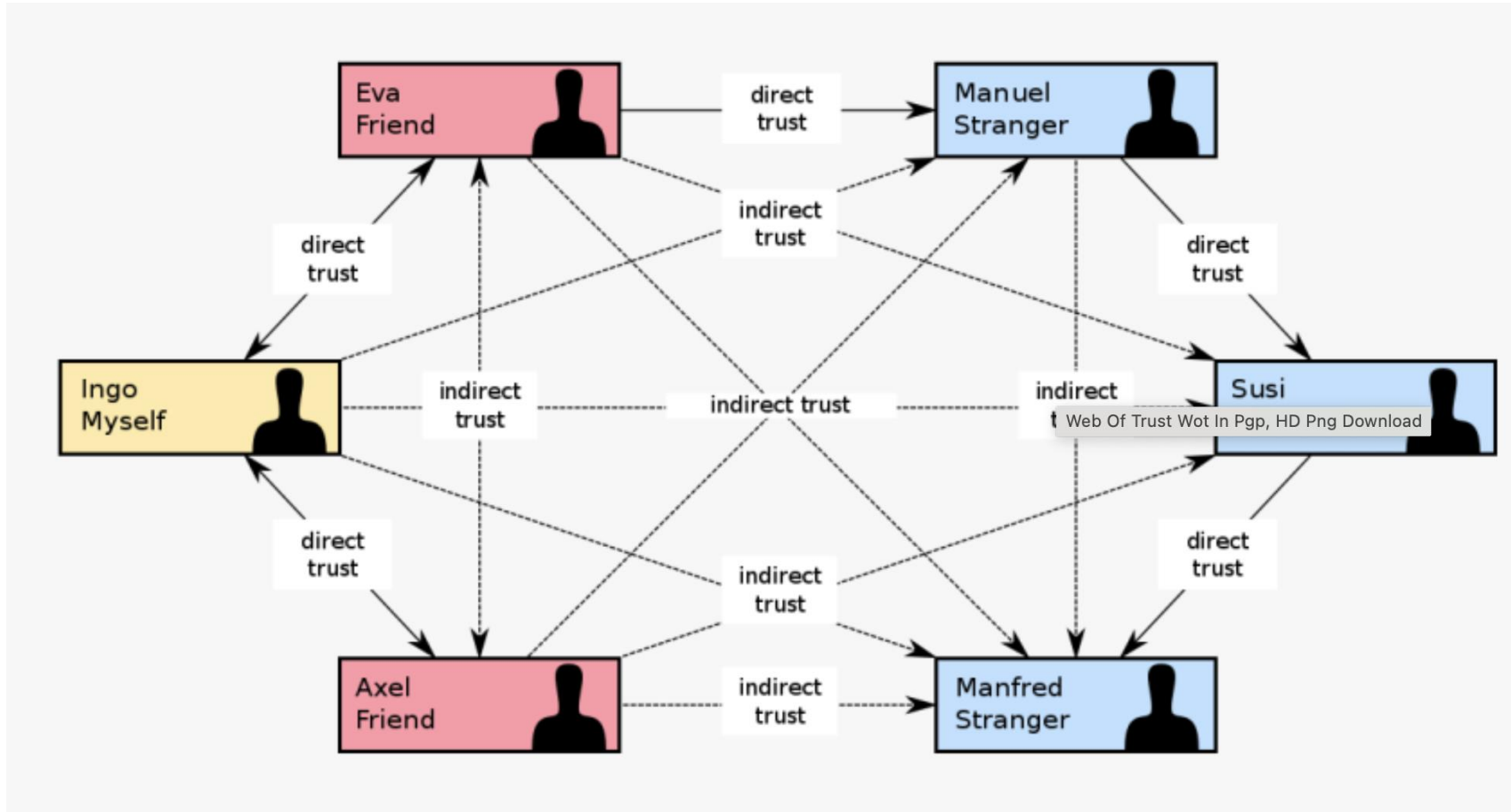
- If you can verify that a key belongs to its owner, you can sign that key, indicating that you have verified ownership
- **WOT** (Web of Trust) is an **in-direct trust**, but it can expand the trust chain easily

DSA (Digital signature algorithm)



- The pub key can be digital signed!

WOT sample

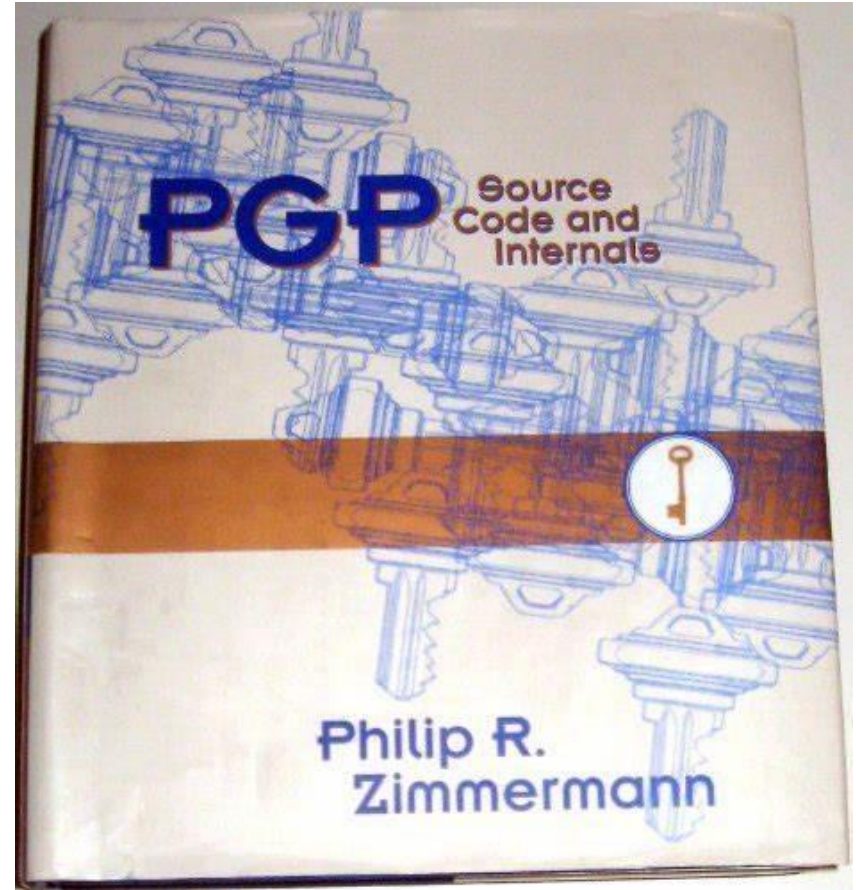


- Based on the trust of digital sign of your direct trust, you can extend to indirect trust.

PGP story



- PGP was published for free on the Internet in 1991.
- This made Zimmermann the target of a three-year criminal investigation, because the government held that US export restrictions for cryptographic software were violated when PGP spread worldwide.
- Source code is published as a book...



<https://philzimmermann.com/EN/background/index.html>

PGP trust level

Unknown

- This is the default trust level, where there is not enough information to discern the trust of a key.

Never

- You have explicitly marked a key so that any signatures from it are *never* trusted, something most commonly used if, say, you know the key holder is compromised, making bag signatures, or not verifying keys before signing them.

Marginal

- Marginal trust means that they're good, but not *too* good. For a key to be marked as "trusted," it will need signatures from *three* keys you've given marginal trust to.

Full

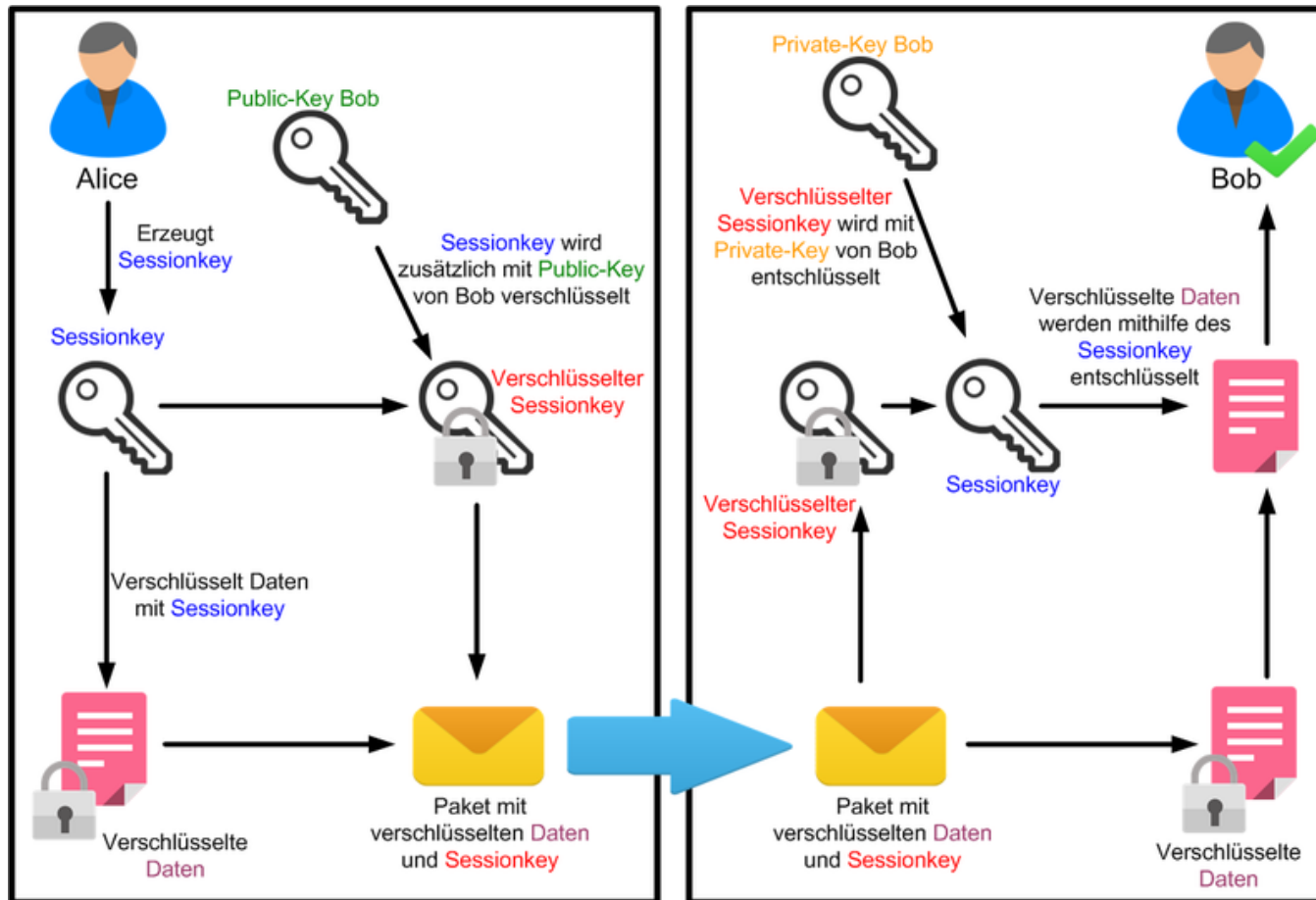
- Full trust should be used for keys that, well... you trust. Unlike marginal trust, full trust only requires *one* signature on a key to mark it as trusted.

Ultimate

- **Only use with your own keys!** Ultimate trust is the highest level of trust, and should only be used for your own keys. Others, if well verified, should be given full trust, and, if you're not too sure, use marginal trust.

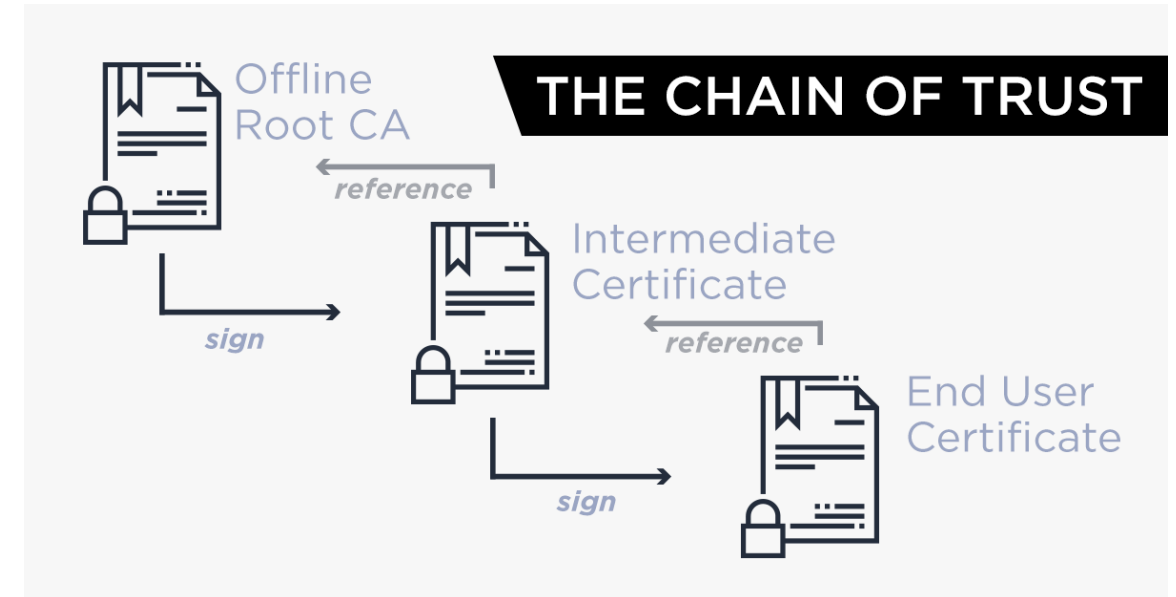
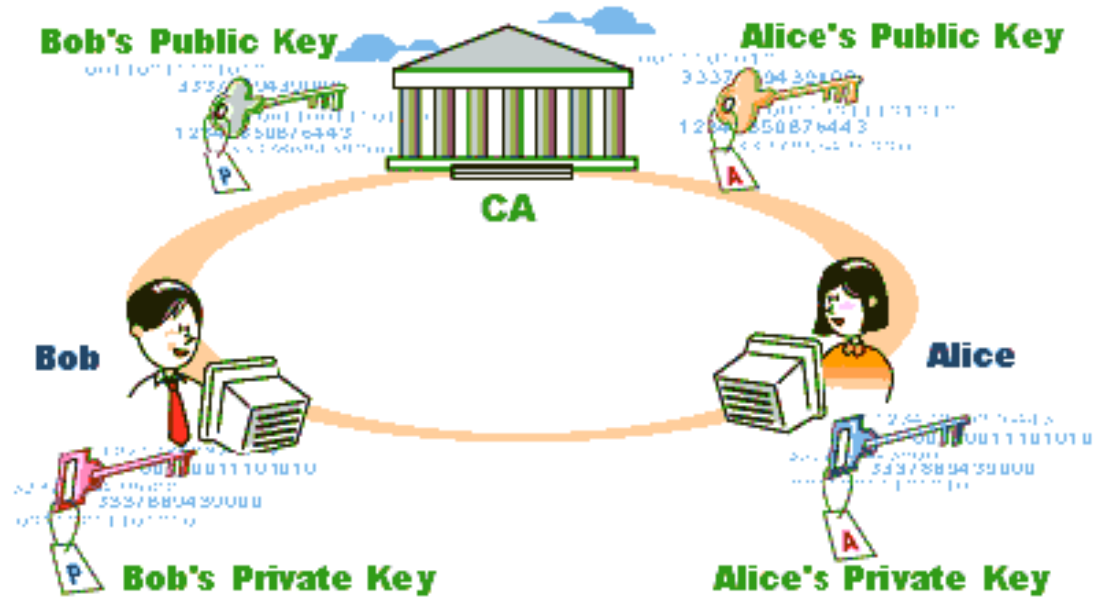
<https://teknikaldomain.me/post/pgp-trust-levels-and-sig-types-explained/>

PGP for emails



<http://books.msspace.net/mirrorbooks/securitytools/ddu/ch09lev1sec1.html>

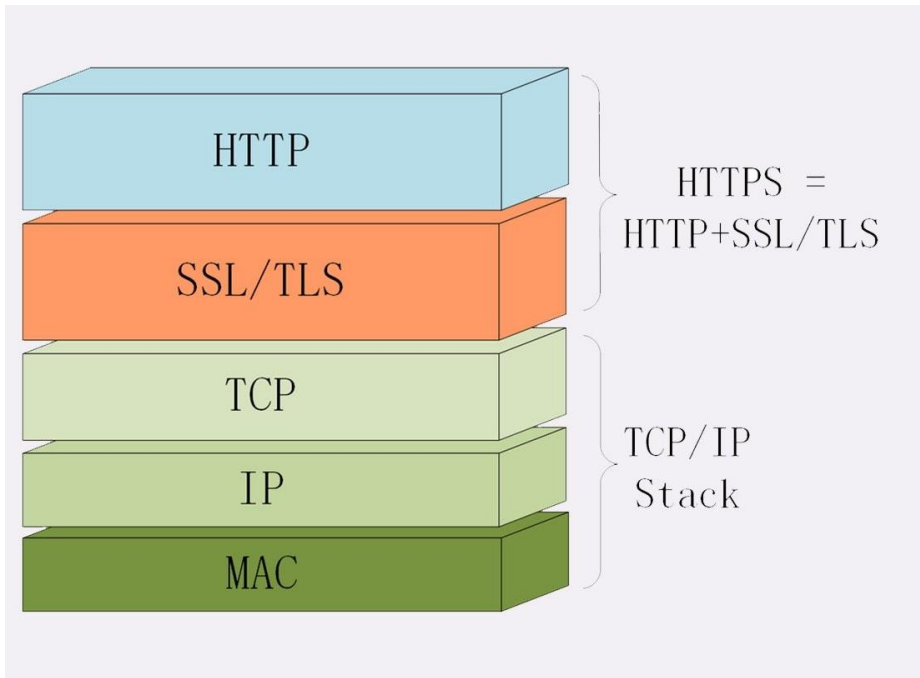
Certificate Authority



- Key idea is to set up the central authority
- Trust of a public key is based on the chain of trust to the CA root.

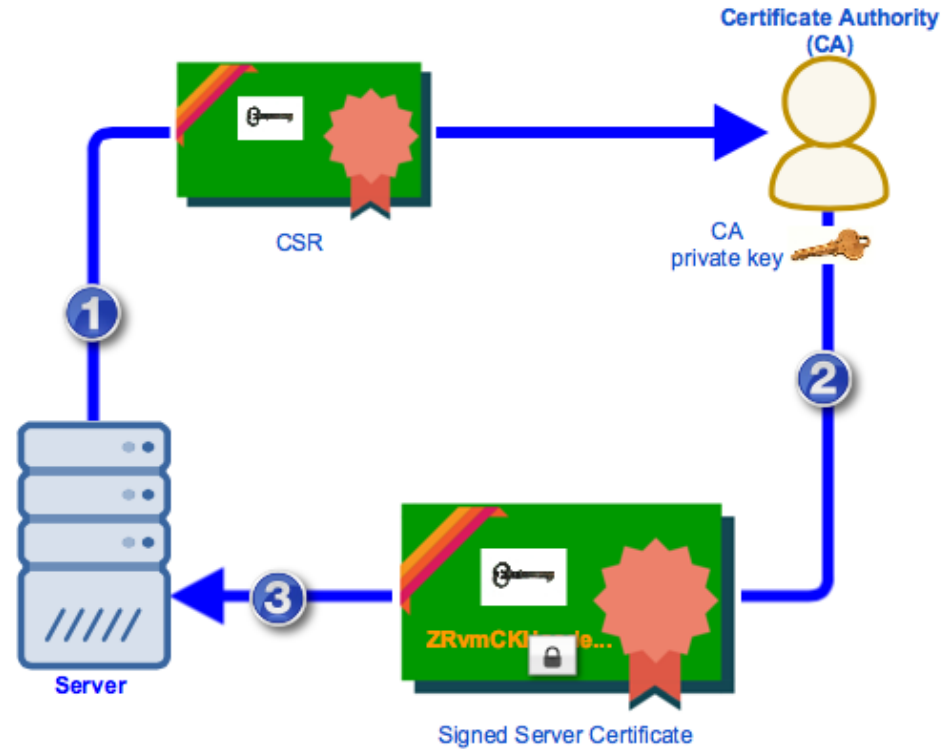
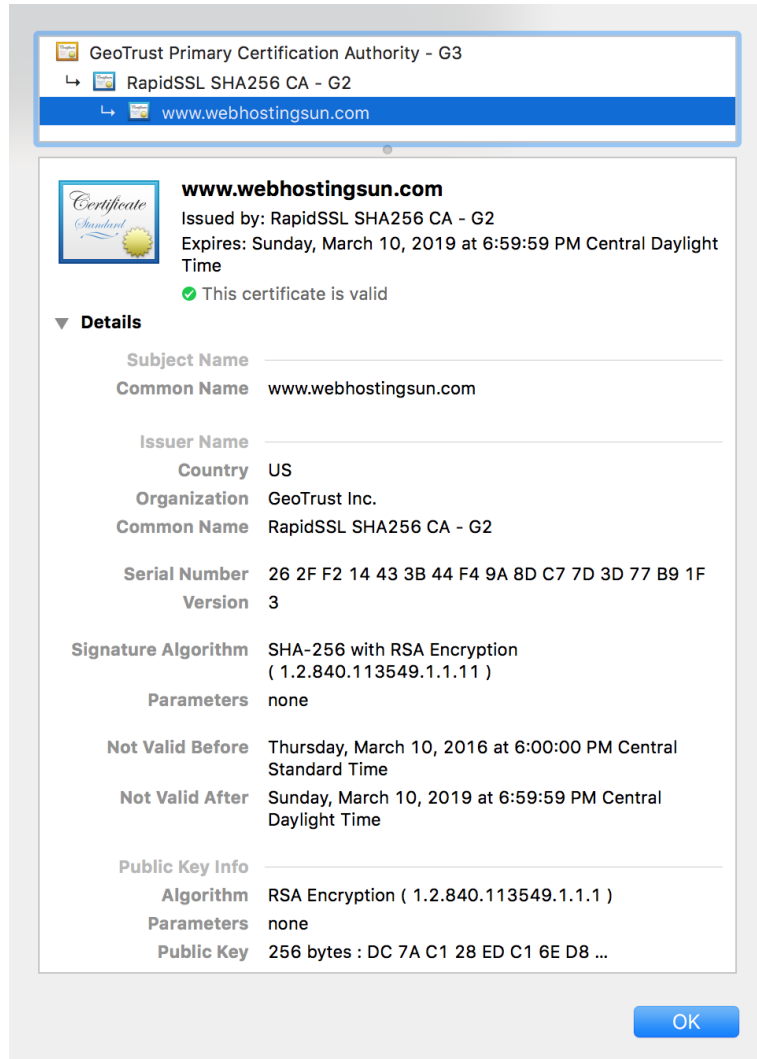
<https://www.comodo.com/resources/small-business/digital-certificates5.php>
<https://www.jscape.com/blog/an-overview-of-how-digital-certificates-work>

SSL/TLS approach



<https://www.clickssl.net/blog/an-easy-to-understand-guide-ssl-tls-https-ssl-certificate-and-https>

The certificate



- Webmaster create the key pairs and **only** send the CSR including public key to CA for registration.
- CA need to verify the authority (for example, face to face or by emails) of CRS application.

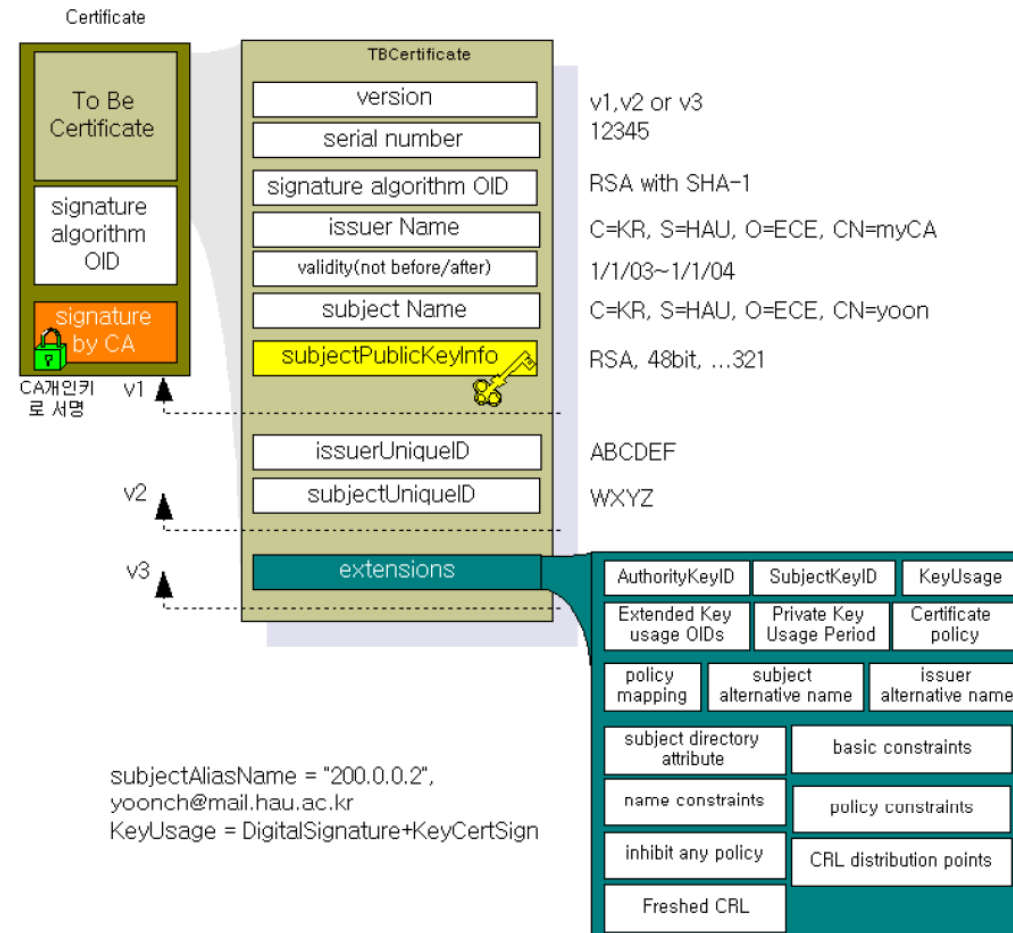
<https://www.comodo.com/resources/small-business/digital-certificates5.php>

<https://www.jscape.com/blog/an-overview-of-how-digital-certificates-work>

<https://www.myssl.cn/tools/>

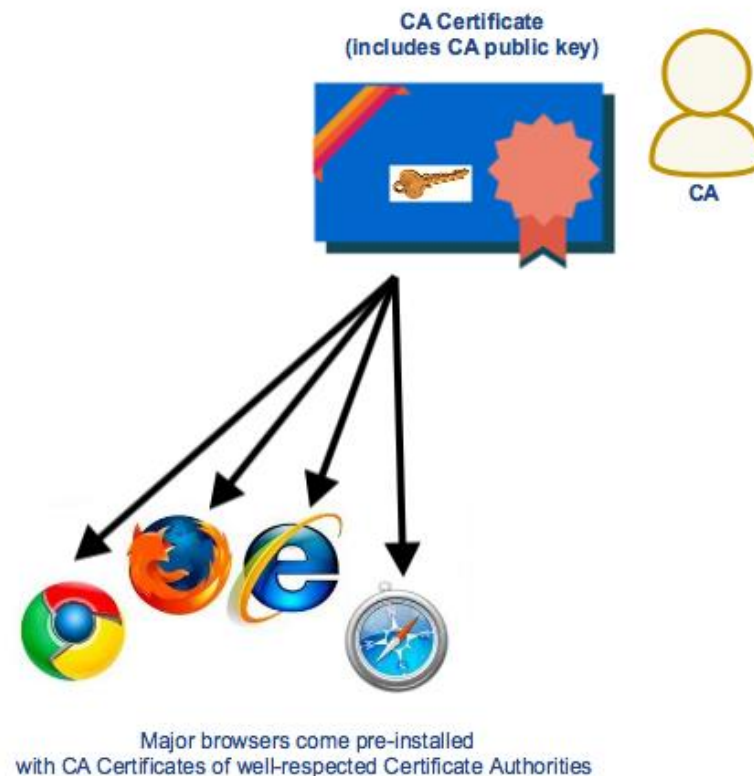
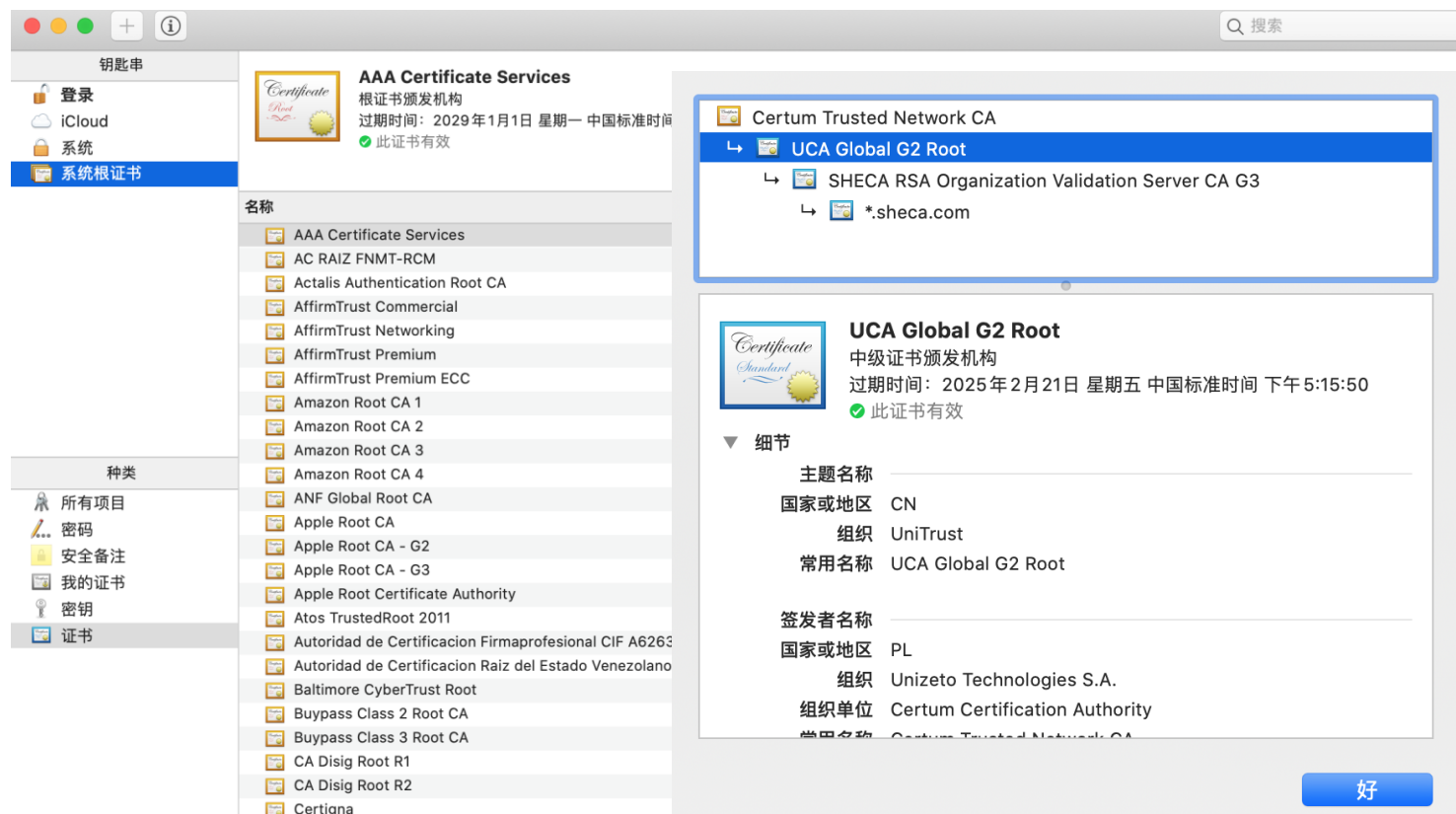
ITU-T X.509 format

```
SectigoRSADomainValidationSecureServerCA.crt x
-----BEGIN CERTIFICATE-----
1  MIIEGzCCA/ugAwIBAgIQfVtRJrR2uhHbdBYLVMnpzANBgkqhkiG9w0BAQwFADCB
2  iDELMAKGA1UEBhMCVVMxEzARBgNVBAGTCk5ldyBKZCZKZjZlZDZlZDZlZDZlZDZl
3  cnNleSBDaXR5MzR4WHAyDQVQKExVUAGUgVNFU1RSVWNUUE5ldHdvcm5xLjAsBgNV
4  BAMTJVVTRVJUCnVzdCBSU0EgQ2VydG1maWNoZGlvdjBBdXRob3JpdHkwHhcNMjg0
5  MTAyMDAwMDAwMjMxMjMxMTU0U5WjCBjzELMAKGA1UEBhMCR0IxEzARBgNVBAGT
6  BAGTEkdyZW0ZCZKZjZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZl
7  ChMPU2VjdGlnbyBmaW1pdGVKMTcwNQYDVQDEY5TZWNoaWdvIFJTSBEB21haW4g
8  VmFsaWRhdGlvbiBTZWNoZGlvdjBBdXRob3JpdHkwHhcNMjg0MTAyMDAwMDAwMjMx
9  MTAyMDAwMDAwMjMxMjMxMTU0U5WjCBjzELMAKGA1UEBhMCR0IxEzARBgNVBAGT
10 AQ8AMIIBCGKCAQEA1nMz1tc8INAA0hdFuNY+B6I/x0HuMjDJsGz99J/LepgPLT+N
11 TQEMgg8Xf2Iu6bhIefswG06t1z1lk7chv7LQP61Mw0Aq6Tn/2YHKHxYyQdqAJrkj
12 eocgHuP/IJo8LURvh3UGkEC0MpMwCRAIIZ7S3YcPb11RFGokAcVPAXJpz90TTG0E
13 oKMbgn6xmrtxz7FN31fmgg0+1YuWMQJDgZKw7w33PGfKGioVrCSolYfu4iYCBsk
14 Haswha6vsC6eep3BwE1c4gLw6uBK0u+QDrTBQ0Bbw4VCSmT3pDcG/r8uoydajotY
15 uK3DGRReY+1vVv2dy2A0xHS+5p3b4eTlygxfFQIDAQABo4IBbjCCAowHwYDVR0j
16 BBgwFoAUU3m/WqorSs9Ug0HYm8Cd8rIDZsSwHQYDVVR00BBYEFI2MXsRUrYrhd+mb
17 +ZsF4bgBjWHhMA4GA1UdDwEB/wQEAwIBhjASBgNVHRMBAf8ECDAGAQH/AgEAMB0G
18 A1UdJQQWMBQGCCsGAQUFBwMBBggrBgEFBQcDAjAbBgNVHSAEFDASMAyGBFUdIAAw
19 CAYGZ4EMAQIBMFAGA1UdHwRjMEcwwRABDoEGGP2h0dHA6Ly9jcmwudXNlcnRydXN0
20 LmNvbS9VU0VSU0FDZCZKZjZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZl
21 BgEFBQcBAQRqMGgwPwYIKwYBBQUHMAKGM2h0dHA6Ly9jcmwudXNlcnRydXN0LmNv
22 bS9VU0VSU0FDZCZKZjZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZlZDZl
23 L29jc3AudXNlcnRydXN0LmNvbTANBgkqhkiG9w0BAQwFAA0CAgEAMr9hvQ5Iw0/H
24 ukdN+Jx4GQHcEx2Ab/zDcLRSmjEzmldS+zGea6TvvKqJjUAXaPgREHzSyrHxVYbH
25 7rM2kYb20VG/Rr8PoLq0935JxCo2F57kaDl6r5R0Vm+yezu/Coa9zcV3HA040LGi
26 H19+24rcRk12aArPsRw04jTkZ6k4Zgle0rj8nSg6F0AnwnJOKf0hPHZPE/uWLMUx
27 RP0T7dwbqlod3zu4f+k+TY4CFM5ooQ0nBnzvg6s1S36y0oeNDT5++SR2Ri0SLv
28 xvcRvKfXmZEJCa0EDKNyJ0uB56DPi/Z+fVGjmo+wea03KbNiAiGCPxZLoUmGv38
29 sbZXQm2V0TP20RQgGke49Y9Y3IBbpNV9Lxj9p5v//cwoasm56ekBYdbqbe4oyAL
30 l6LFhd2zi+WJN44pDfwGF/Y4QA5C5B1G+3vzxhFoYt/jmPQT2BVP17Fp2RBgvGQq
31 6jG35LWj0hSbJuMLe/0CjraZwTiXWtb2qHSihrz68Zk6s+go/lunrotEbaGmAhY
32 LcmsJWTyXnW00MGuf1pGg+pRyrbxmRE1a6Vqe8YAs0f4vmSyrCj8azjUeqkk+B5
33 y0GBQMkKw+ESPMFgK0uXwILCypTPRpgSabuY0MLTDXJLR27lk8QyKG0HQ+Swmj4K
34 00u/I5sUKUErmgQfky3xxzLIPK1aEn8=
35 -----END CERTIFICATE-----
36
```



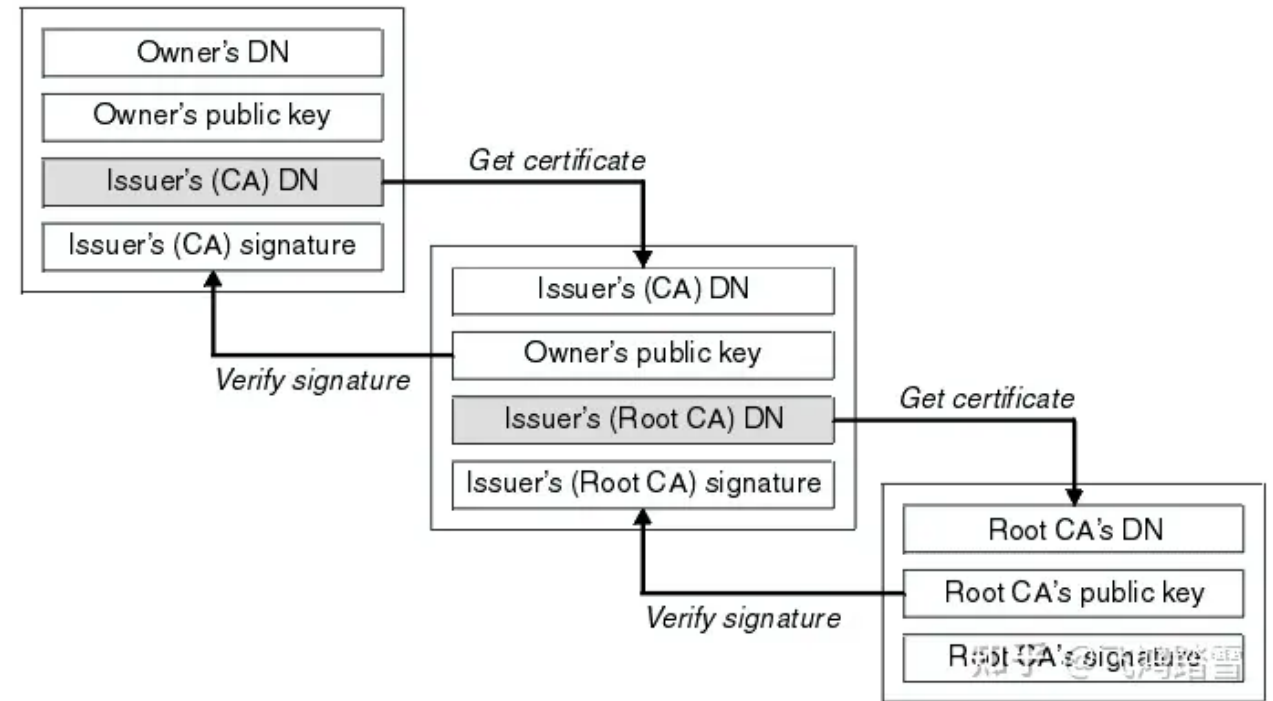
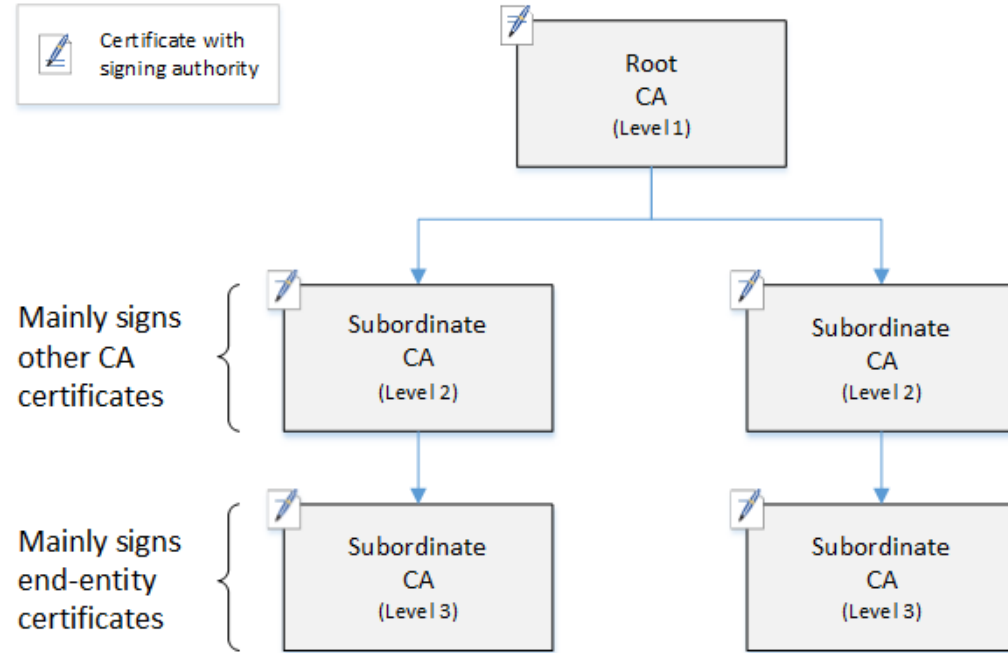
<https://www.itu.int/rec/T-REC-X.509/en>

Major CA in our browsers



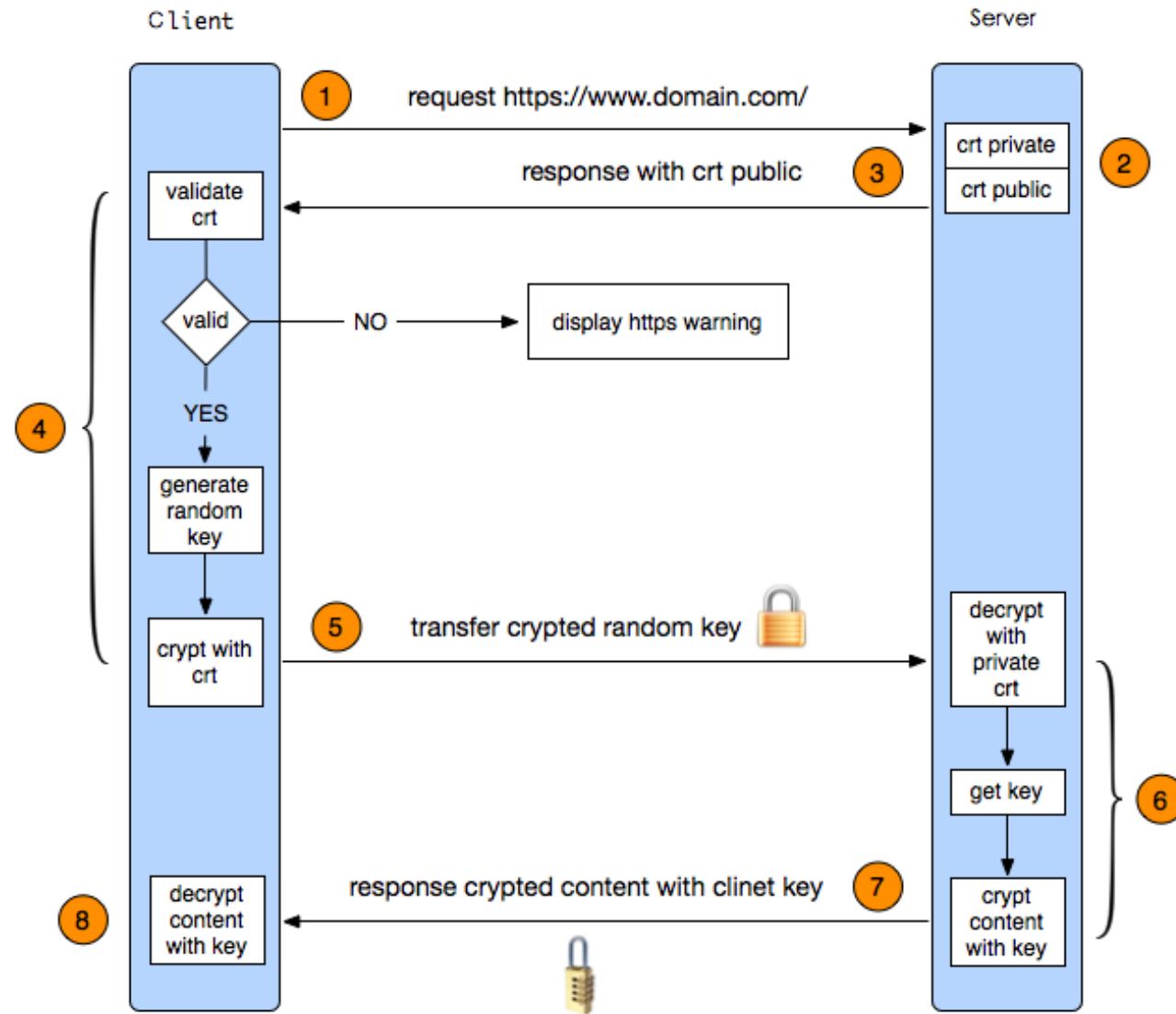
- Dominated by US and European companies.
- 上海CA has been accepted by most browsers.

Certificate chain



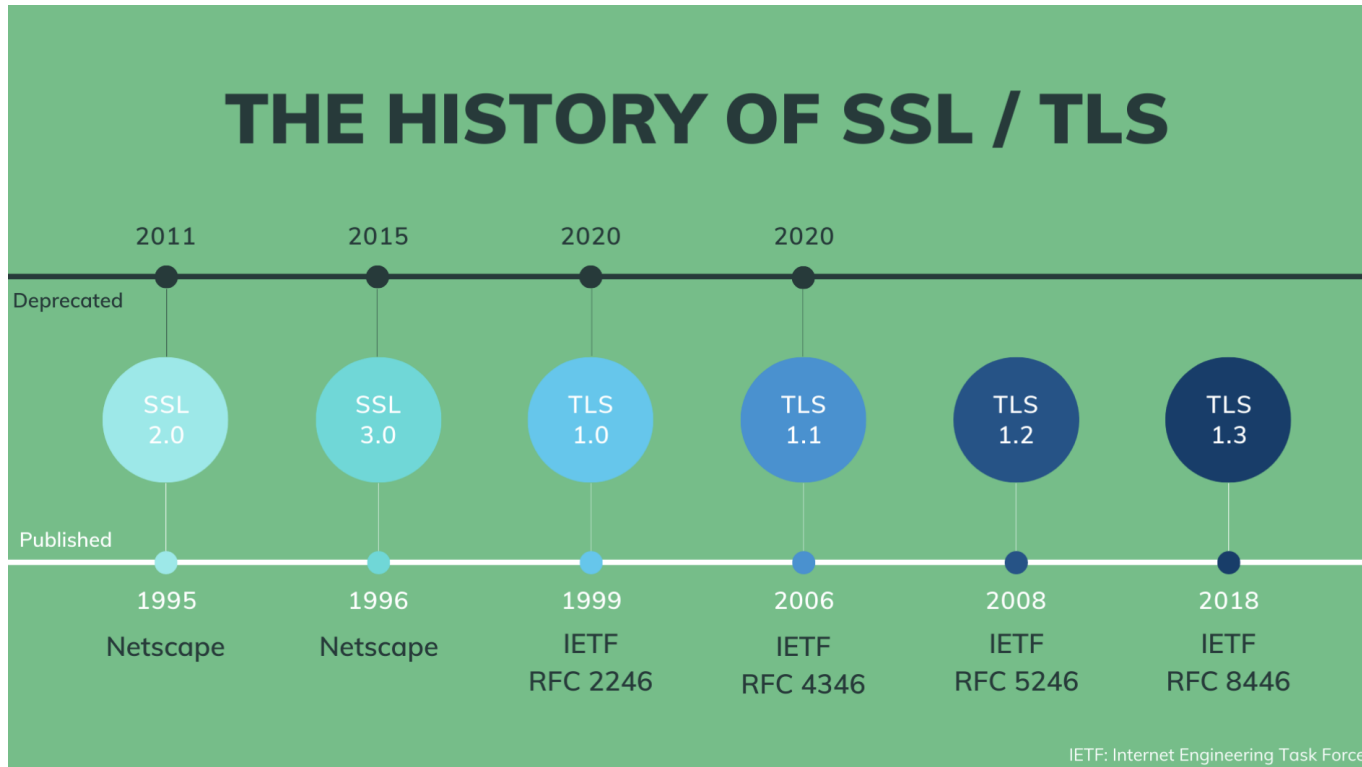
- CA has many levels

A principle process



- **Verify the certificate of sever with the build-in root CAs**

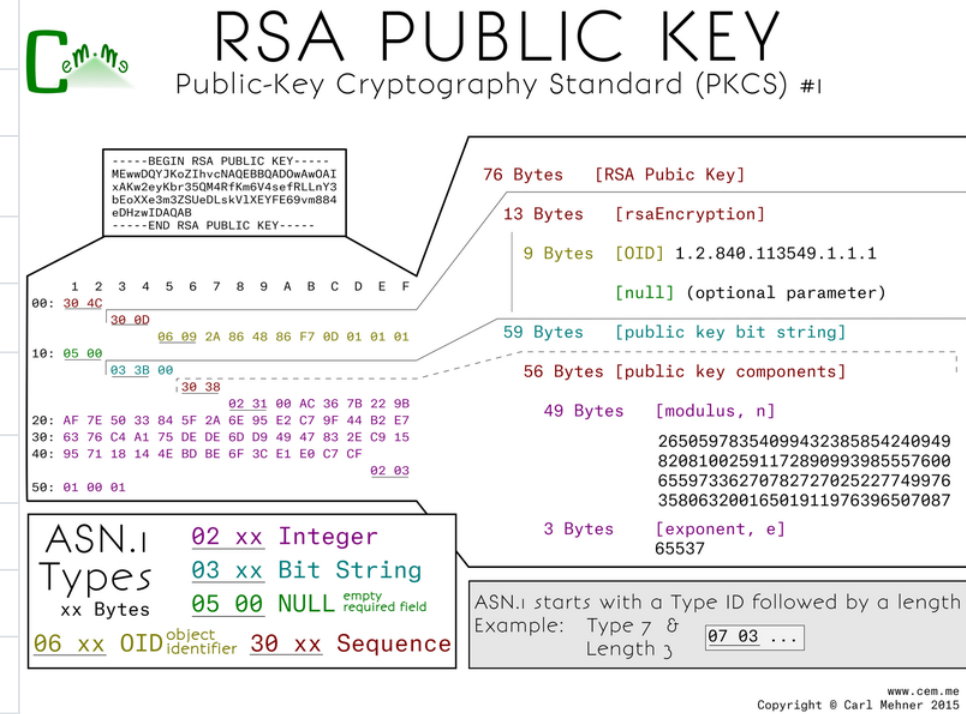
SSL/TLS



- How to integrate the key exchange, digital signature and symmetric algorithm together? It need certain industry stander.
- SSL refers to Secure Sockets Layer whereas TLS refers to Transport Layer Security. Basically, they are one and the same, but, entirely different.
- SSL/TLS also have **Vulnerability**. For example, SSL3.0 cannot against **POODLE attack**.

PKCS (Public-Key Cryptography Standards)

No.	PKCS Title	Comments
1	RSA Cryptography Standard	
2,4		incorporated into PKCS #1
3	Diffie-Hellman Key Agreement Standard	superseded by IEEE 1363a.
5	Password-Based Cryptography Standard	
6	Extended-Certificate Syntax Standard	never adopted
7	Cryptographic Message Syntax Standard	superseded by RFC 3369
8	Private-Key Information Syntax Standard	
9	Selected Object Classes and Attribute Types	
10	Certification Request Syntax Standard	
11	Cryptographic Token Interface Standard	referred to as CRYPTOKI
12	Personal Information Exchange Syntax Standard	
13	(reserved for ECC)	never been published
14	(reserved for pseudo-random number generation)	never been published
15	Cryptographic Token Information Syntax Standard	



<https://www.educba.com/pkcs/>
<https://www.encryptionconsulting.com/public-key-cryptography-standards/>

Cipher suites - different combinations:

▲ Cipher Suites (26 suites)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)

Cipher Suite: TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)

Cipher Suite: TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x009f)

Cipher Suite: TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x009e)

Cipher Suite: TLS_RSA_WITH_AES_256_GCM_SHA384 (0x009d)

Cipher Suite: TLS_RSA_WITH_AES_128_GCM_SHA256 (0x009c)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc02c)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384 (0xc024)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256 (0xc023)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (0xc00a)

Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (0xc009)

Cipher Suite: TLS_RSA_WITH_AES_256_CBC_SHA256 (0x003d)

Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA256 (0x003c)

Cipher Suite: TLS_RSA_WITH_AES_256_CBC_SHA (0x0035)

Cipher Suite: TLS_RSA_WITH_AES_128_CBC_SHA (0x002f)

Cipher Suite: TLS_DHE_DSS_WITH_AES_256_CBC_SHA256 (0x006a)

Cipher Suite: TLS_DHE_DSS_WITH_AES_128_CBC_SHA256 (0x0040)

Cipher Suite: TLS_DHE_DSS_WITH_AES_256_CBC_SHA (0x0038)

Cipher Suite: TLS_DHE_DSS_WITH_AES_128_CBC_SHA (0x0032)

Cipher Suite: TLS_RSA_WITH_3DES_EDE_CBC_SHA (0x000a)

Cipher Suite: TLS_DHE_DSS_WITH_3DES_EDE_CBC_SHA (0x0013)

Cipher Suite: TLS_RSA_WITH_RC4_128_SHA (0x0005)

Cipher Suite: TLS_RSA_WITH_RC4_128_MD5 (0x0004)

ECDHE - RSA - AES256 - GCM - SHA384



- There are four parts in the cipher suites
- Each part has many algorithm choices
- D-H can also use EC algorithm, then its name would be ECDH

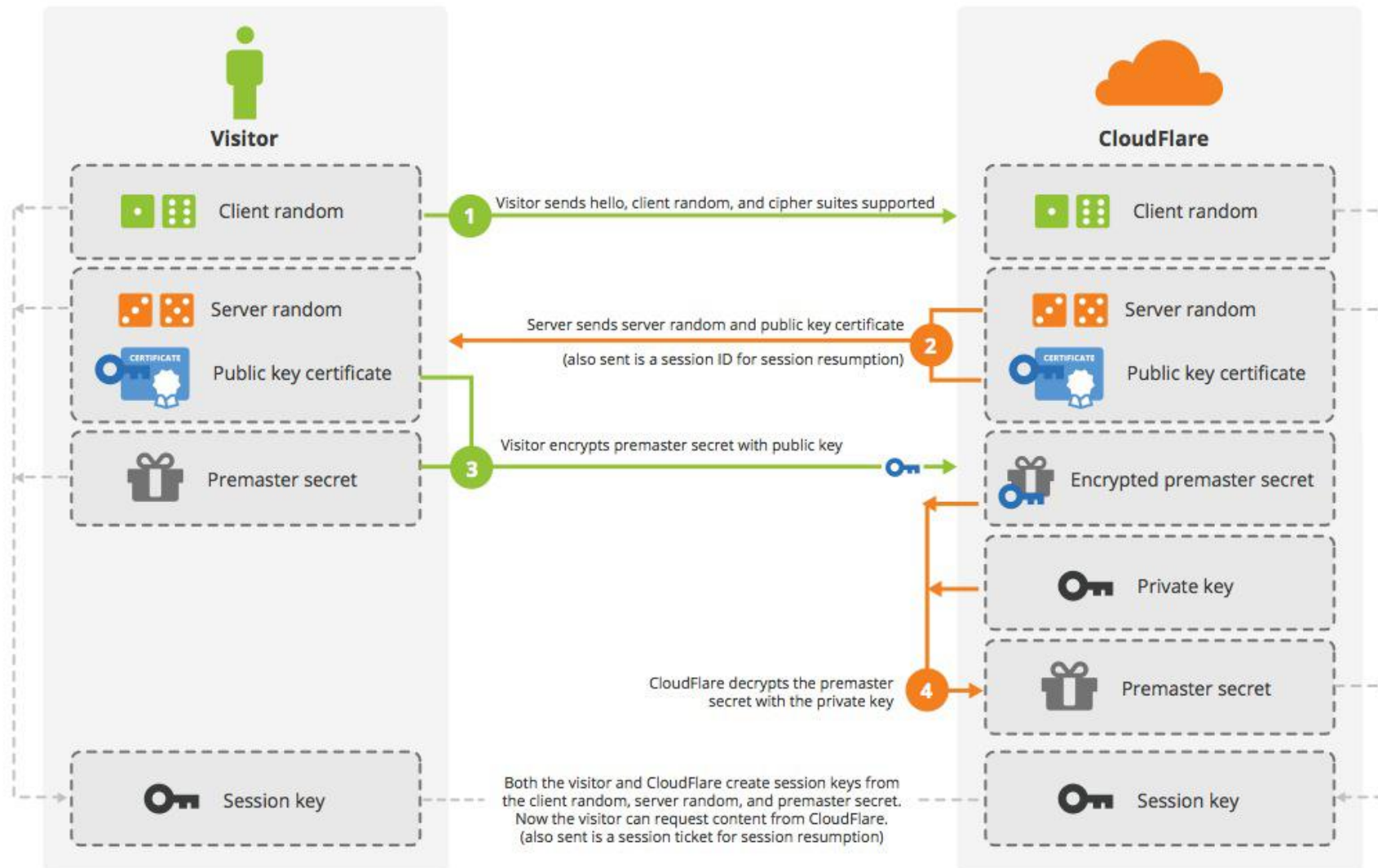
<https://www.jianshu.com/p/580e92dc4fdd>

<https://www.iana.org/assignments/tls-parameters/tls-parameters.xhtml>

<https://blog.csdn.net/herongoal/article/details/83414888>

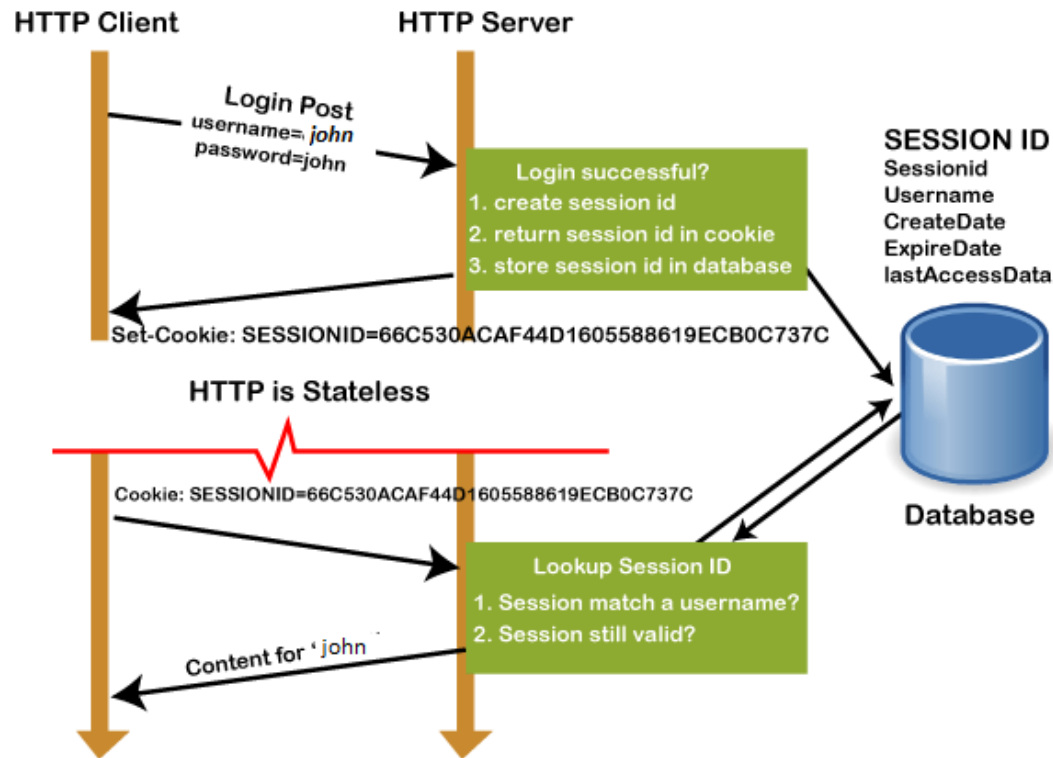
SSL Handshake (RSA)

Handshake



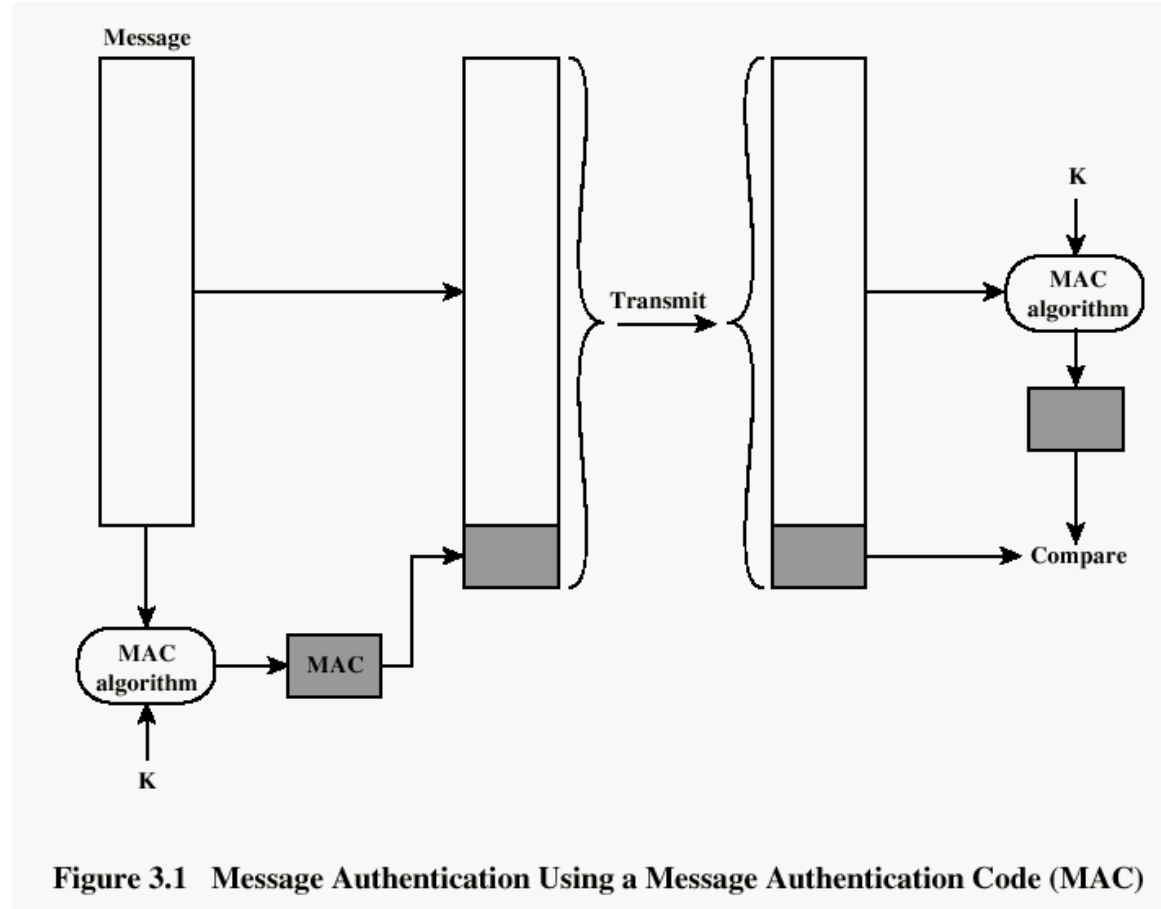
- Session key is generated by server random, client random and pre-master

HTTP – Cookie Session



- HTTP is designed to be stateless to be simple, scalable and reliable.
- Stateless meaning that the server does not keep any data (state) between two requests.
- We need to use Cookie and Session to track the status.
- A cookie is a small text file that is stored on the user's computer (Due to the security reason, the browsers only allow interaction with cookie but not other files).
- Cookies are created and shared between the server and browser with the help of an HTTP header.
- Session is a global variable stored on the server. Each session is assigned a unique id which is used to retrieve stored values and the session id is stored as a **cookie** on the user's computer.
- But the information stored within cookies is **NOT** secure because this information is stored in text-format on the client-side, which can be read even tampered by malicious code.

MAC - Message Authentication Code



- In TLS, MAC algorithm of symmetric encryption is also a part of cipher suite.
- MAC means how to check the integrity of a message, normally a HASH function or HMAC.

Challenge for leakage of the private key

```

1 -----BEGIN CERTIFICATE-----
2 MIIEGzCCA/uGAwIBAgIQIofvTRJR2uHhbkBYLVFMNpZANBqkqhkiG9w0BAQFDB
3 iDcLMkAQA1UEBhMCVCMwEzAR8NBwHbCd51dy8KZ3JzYkxvFDASBhNBVAC TC0pL
4 cN1eSBDaXR5MR4wHAYDVQKQExVUAGUgVNVFURSVVNUIES1dHdvcmxsLjAsBgNV
5 BAMTJVVVTRVUJcnVzdCBSU0EgQ2VydGQlmaWhhdGlvb1BBDXRob3J3PCdHwHhcnMTgx
6 MTAYMDAwMDAwHwChNMx4YmJ1MxMjU1OTU0U5VjCBjzELMAKGA1UEBhMC1UcXZzAGBn
7 BAgTEkdyZWZ0ZXIgdWUuY2hlc3RlcjEQAQA4GA1UEBhMMHU2FszM9yZDEYMBYGA1UE
8 ChMUP2VydGlvb1BMAW1pdG9kMTUuY2VydGQlmaWhhdGlvb1BBDXRob3J3PCdHwHhcnMTgx
9 VmFsASRhdGlvb1BtZW50Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQl
10 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
11 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
12 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
13 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
14 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
15 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
16 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
17 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
18 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
19 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
20 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
21 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
22 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
23 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
24 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
25 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
26 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
27 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
28 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
29 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
30 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
31 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
32 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
33 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
34 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
35 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
36 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
37 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
38 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
39 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
40 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
41 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
42 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
43 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
44 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
45 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
46 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
47 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
48 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
49 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
50 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
51 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
52 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
53 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
54 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
55 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
56 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
57 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
58 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
59 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
60 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
61 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
62 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
63 Y2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0Y2VydGQlY2E5MTY1ZjE0
64 Y2E5MTY1ZjE0
```



- **Normally private key is a file in the server**
- **If hackers got the private key ...**

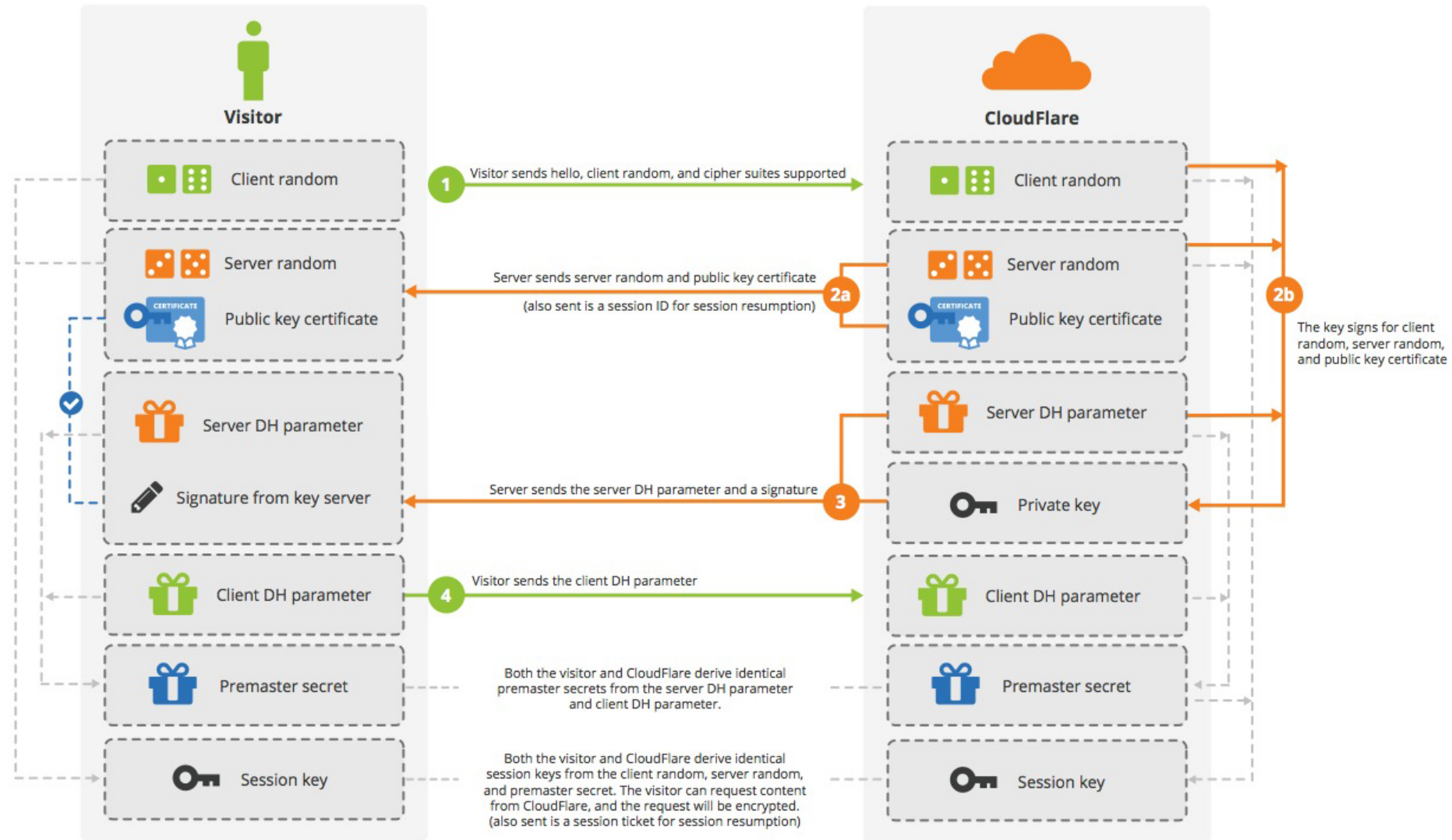
And record all cipher communication!



- It is time to **decrypt** all **previous** securities!

SSL Handshake (Diffie-Hellman)

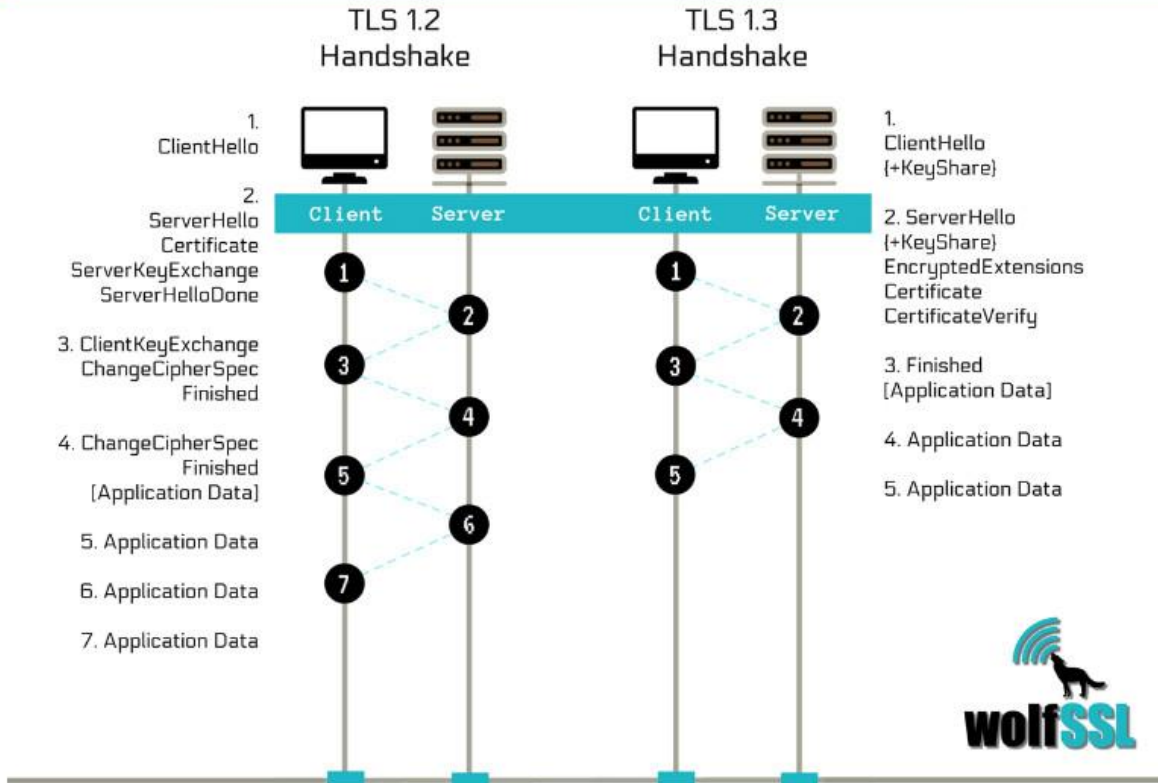
Handshake



- DH algorithm is used to further enhance the security of pre-master.

From TLS 1.2 to 1.3

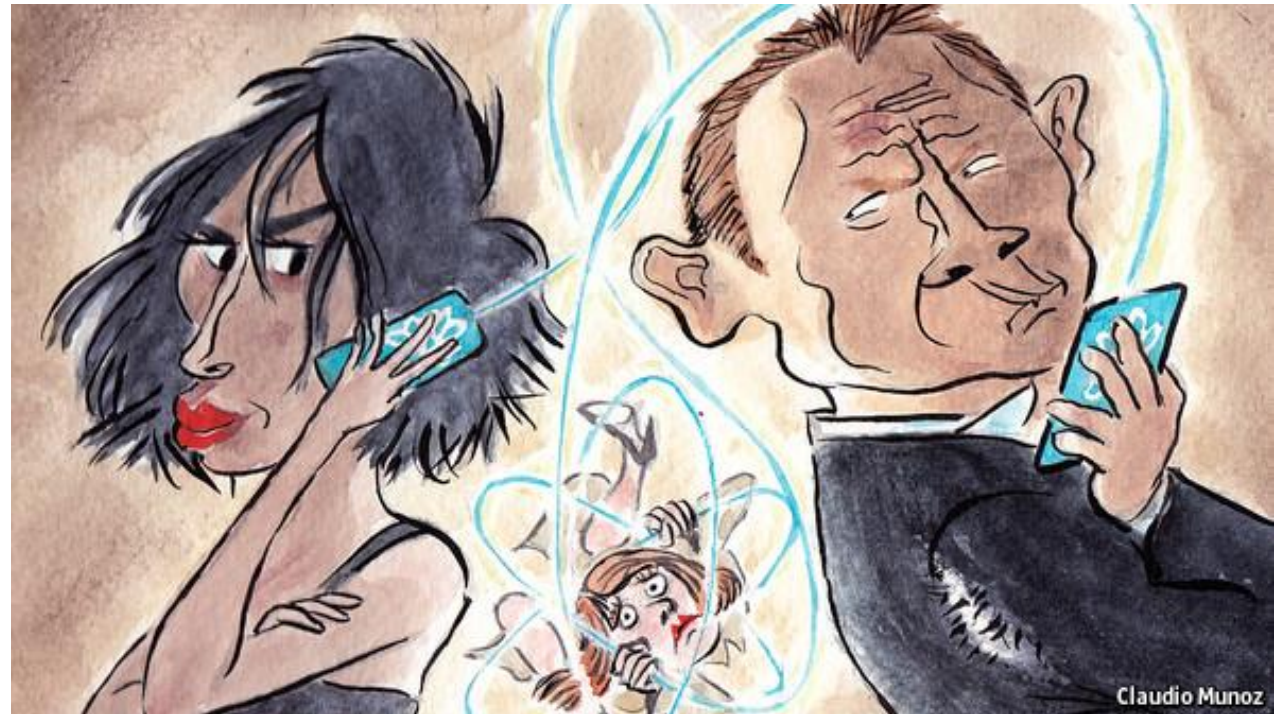
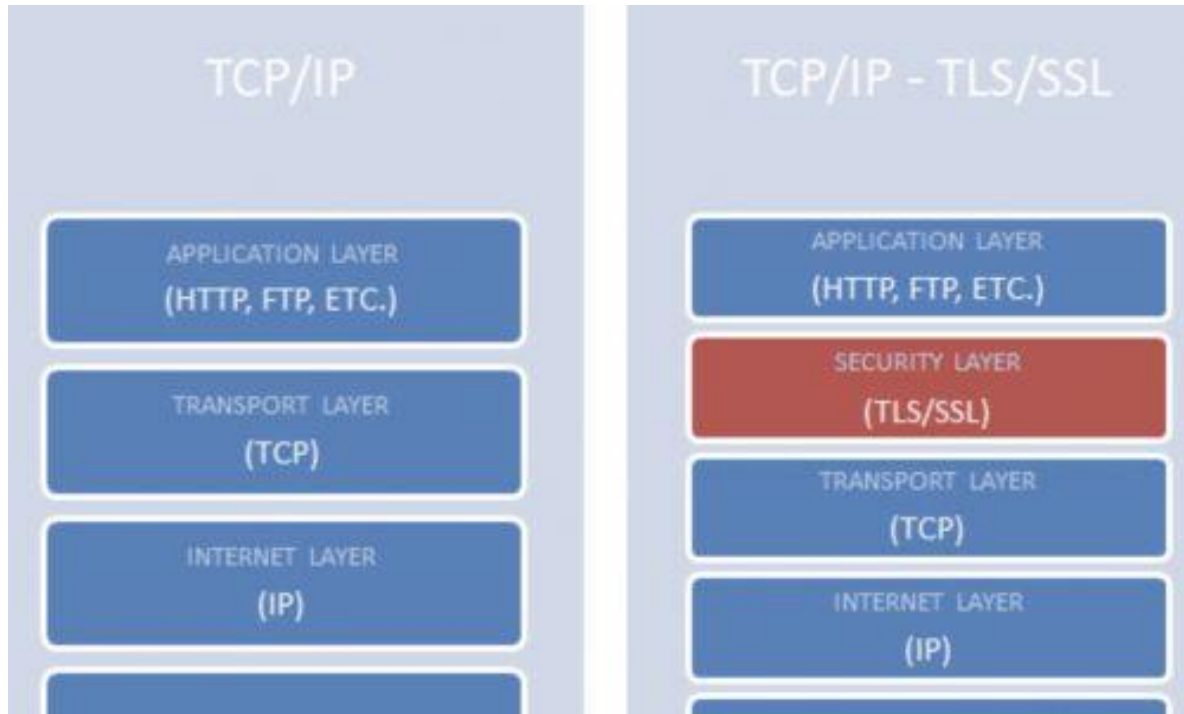
FASTER!



- **Cipher suites of TLS 1.3**
 - TLS_AES_256_GCM_SHA384
 - TLS_CHACHA20_POLY1305_SHA256
 - TLS_AES_128_GCM_SHA256
 - TLS_AES_128_CCM_8_SHA256
 - TLS_AES_128_CCM_SHA256

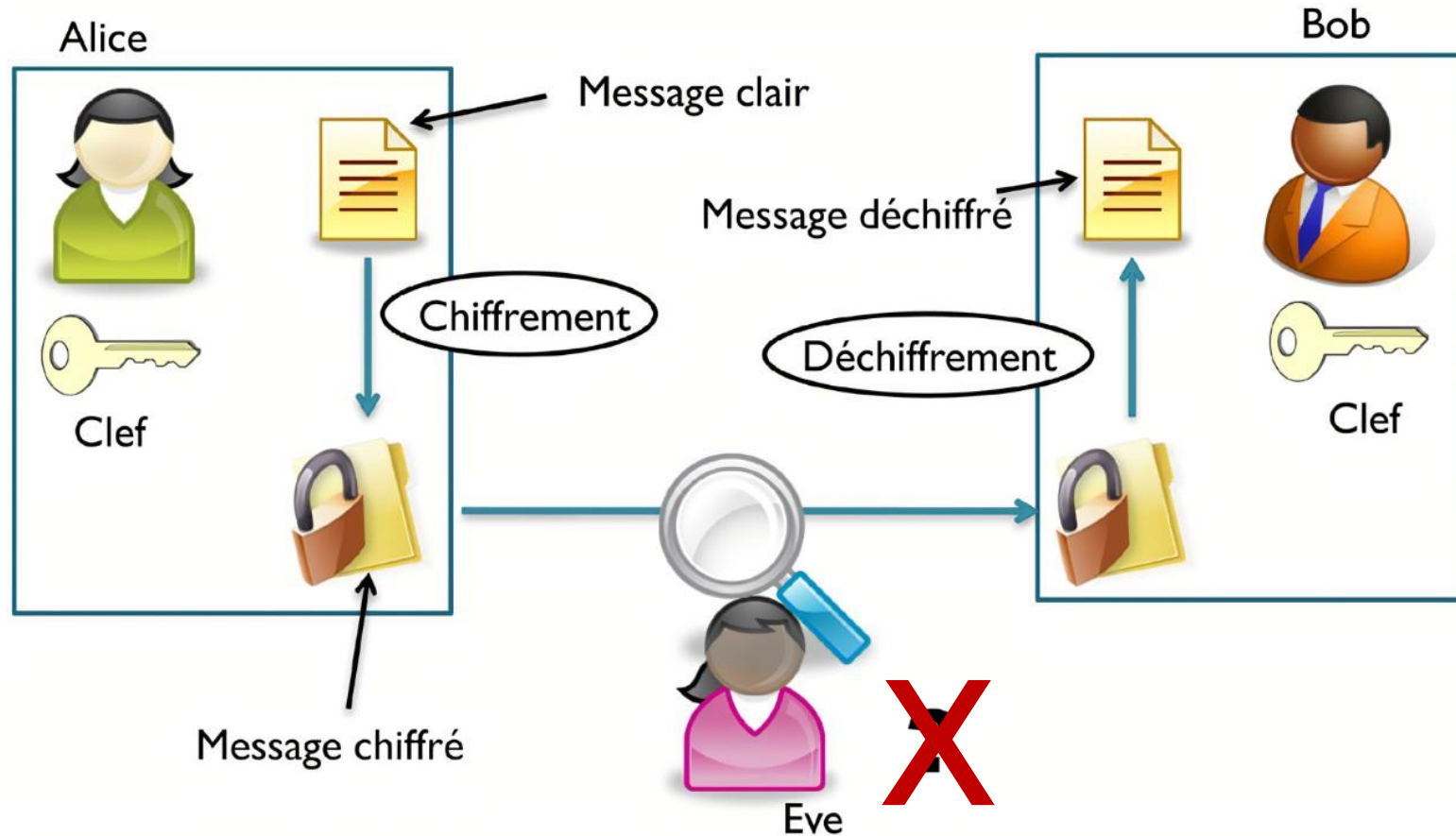
- TLS 1.3 **removes** the RSA algorithm
- Reduce the handshake to increase the speed.

Summary of SSL/TLS



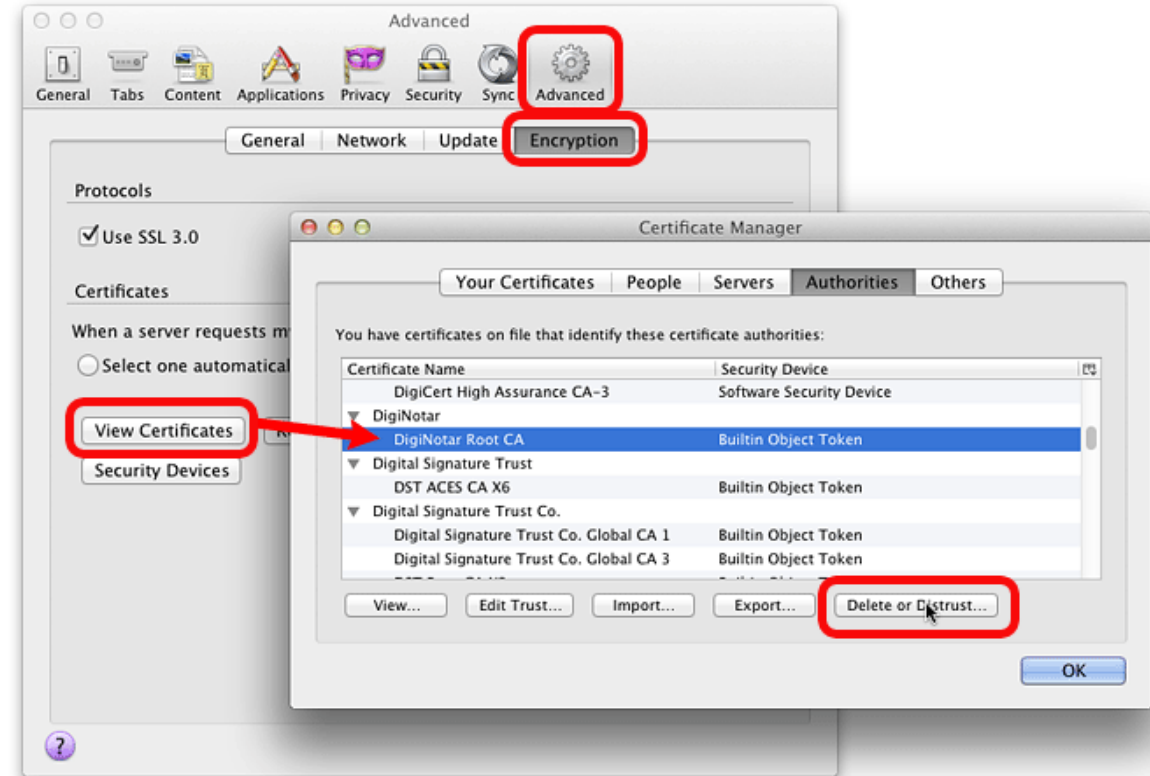
- TLS is not limited to Http.
- TLS can also apply for FTP, SMTP ...
- TLS cannot work if only use symmetric algorithms or otherwise, it combines both.

It seems Eve is out!



- Remember, the biggest danger is "We think we are safe!"

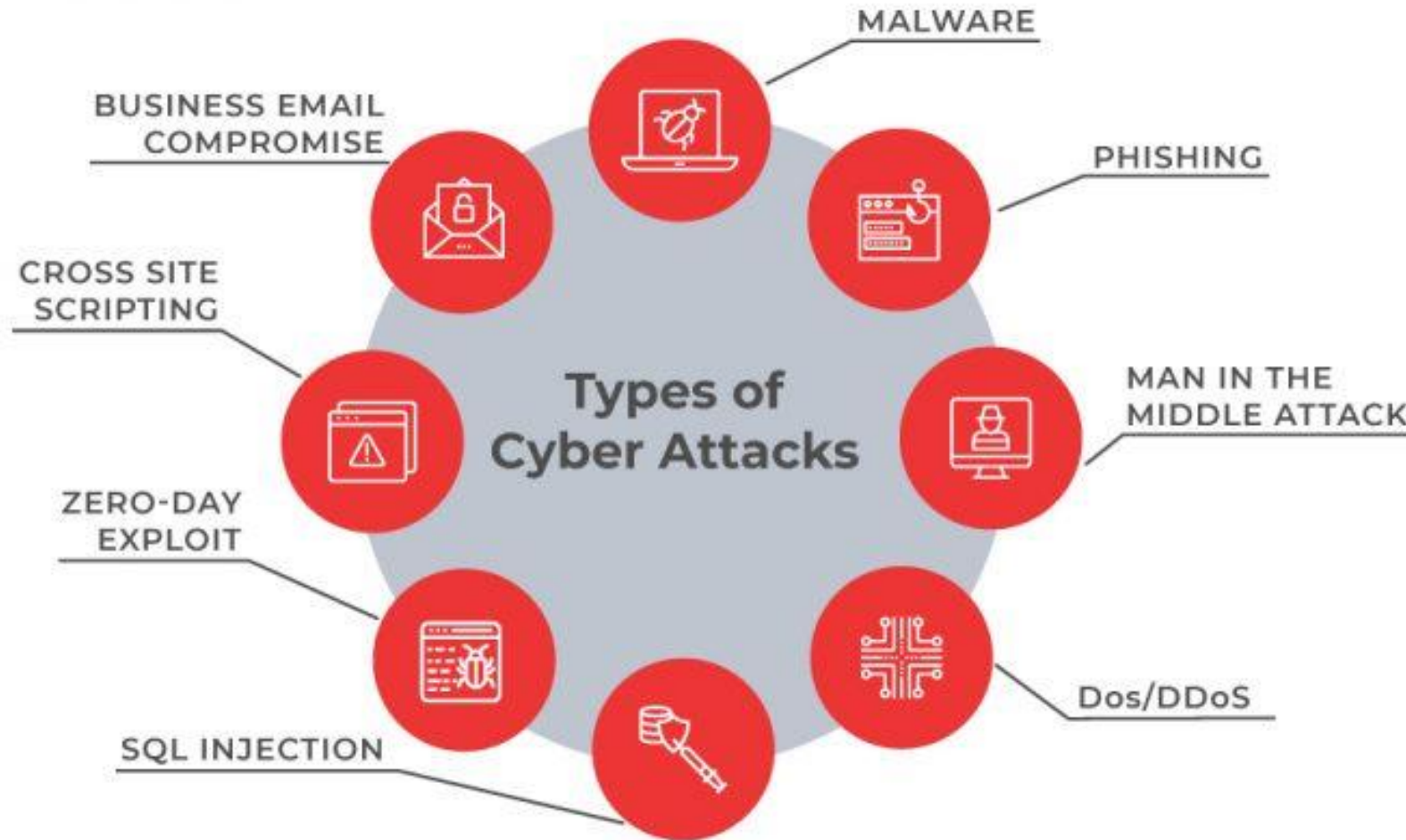
Be attention to this



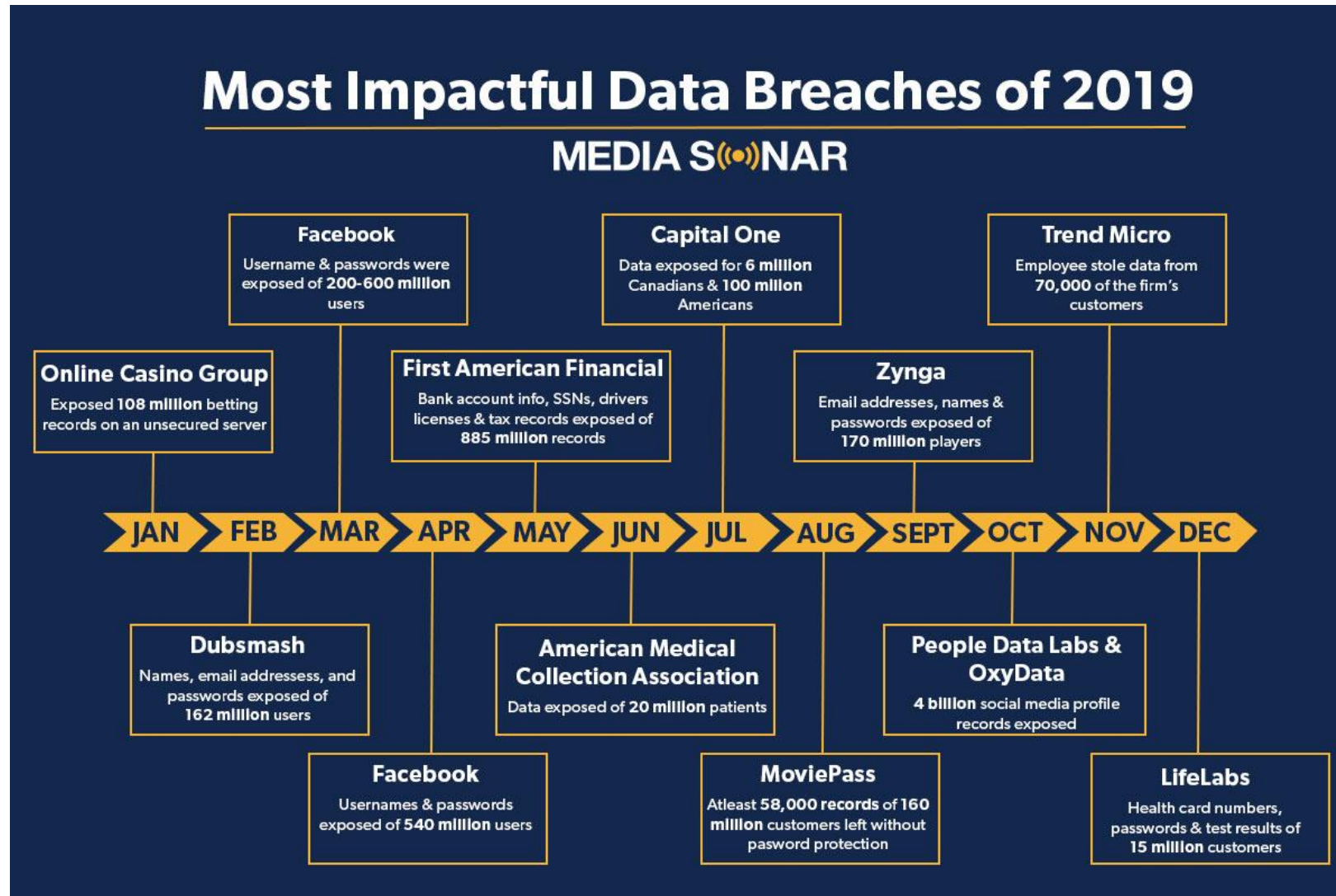
- CA DigiNotar has been hacked and faked "google" was online in 2011

<https://www.zdnet.com/article/diginotar-files-for-bankruptcy-following-hack-attack/>

More cyber attacks



So many cyber leakage...



<https://www.upguard.com/blog/biggest-data-breaches>

Password is widely used for authorization



Credential stuffing with leakage data

Brute Force Attack

Off-line Attacks with Passwords

Assumes most passwords are found in cracking dictionaries – attacker relies on high volume guessing

Password API

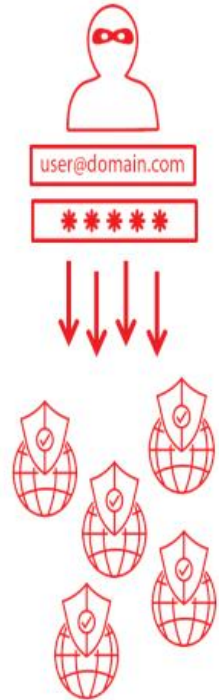


Credential Stuffing

On-line Attacks with Credentials

Assumes most people reuse the same credentials on multiple sites – attacker relies on breached credentials

Credential API



<https://zhuanlan.zhihu.com/p/126243422>

<https://www.scoopwhoop.com/most-dangerous-passwords-that-can-be-hacked/>

Never store passwords in plain text

The screenshot displays the Microsoft SQL Server Enterprise Manager interface. On the left, the '对象资源管理器' (Object Explorer) pane shows the 'newfft' database structure, including '系统表' (System Tables) and '用户表' (User Tables). The 'dbo.login' table is selected. The main pane shows the 'dbo.login' table data, which includes columns: ID, LoginName, LoginPwd, Status, IsDel, UpdateTime, and EName. Red arrows point to specific rows, likely indicating the target for a password change operation.

ID	LoginName	LoginPwd	Status	IsDel	UpdateTime	EName	
44	181	563	25 33	3	False	NULL	xiaoma
45	hellc	5	12 36	3	False	NULL	NULL
46	137	491	pr se	2	False	NULL	NULL
49	130	202	12 367	3	False	NULL	zhumeng
51	186	338	01 121	3	False	NULL	NULL
52	137	417	11 072	3	False	NULL	billyboy333
53	158	605	o6 dv	3	False	NULL	NULL
54	151	073	12 36	3	False	NULL	NULL
55	151	072	12 36	3	False	NULL	NULL
56	adm	pr se	131	False	NULL	NULL	NULL
58	130	738	12 36	3	False	2014-7-15 11:1...	wft88
59	135	117	12 36	2	False	NULL	NULL
61	157	567	12 36	3	False	2014-7-25 11:3...	999999999
62	wft	wf	18382	1	False	NULL	NULL
64	w18	35709	12 36	2	True	NULL	NULL
65	186	709	12 36	3	True	NULL	NULL
66	180	586	ss 7198	3	False	NULL	NULL
67	189	919	ty y2013	3	False	NULL	NULL
69	158	858	65 21	2	True	NULL	NULL
70	158	859	65 21	2	True	NULL	NULL
71	138	351	65 21	2	False	NULL	NULL
72	185	213	00 33	2	False	NULL	NULL
73	138	817	65 21	2	True	NULL	NULL
74	133	817	65 21	2	True	NULL	NULL
75	185	228	12 36	3	False	NULL	leiren
76	185	517	12 36	3	False	NULL	NULL
77	187	599	66 0810	3	False	NULL	NULL
78	188	132	00 34	3	False	NULL	NULL
79	186	971	40 10	3	False	NULL	NULL
80	186	891	76 30	3	False	NULL	NULL
81	132	868	wf 752256	3	False	NULL	NULL
82	188	946	52 23xyu	3	False	NULL	NULL
83	189	888	65 21	2	False	NULL	NULL

- **Password** is only for comparison purpose.
- On design, even the Admin should **NOT** has any chance to access customers passwords in plain text.
- **HASH** is a good choice while it is NOT an encryption algorithm.
- For example, you can read 123456 very easy. But you may hardly know what does "8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92" means.
- It is SHA256("123456")

http://wy.zone.ci/bug_detail.php?wybug_id=wooyun-2015-095231

Some suggestions on Password/Credential

Password Strength Chart		
This is based on the average brute forcing (botnet) power in 2019.		
123456 Top 10,000 password	0.20 milliseconds	Unsafe
qwerty123456 Longer "common" password	13 hours	Unsafe
ITFunSom3times Longer password with numbers	48 thousand years	Risky
ITi\$fun\$0m3times! Longer password with numbers and special characters	13 trillion years	Good
imusingalongpasswordtoday Even Longer password	913 trillion years	Better
imu\$ingalongpa\$\$word+oday! Even Longer password with numbers and special characters	2 octillion years	Best
Please Note: These passwords are for demonstration purposes ONLY and are not to be used.		

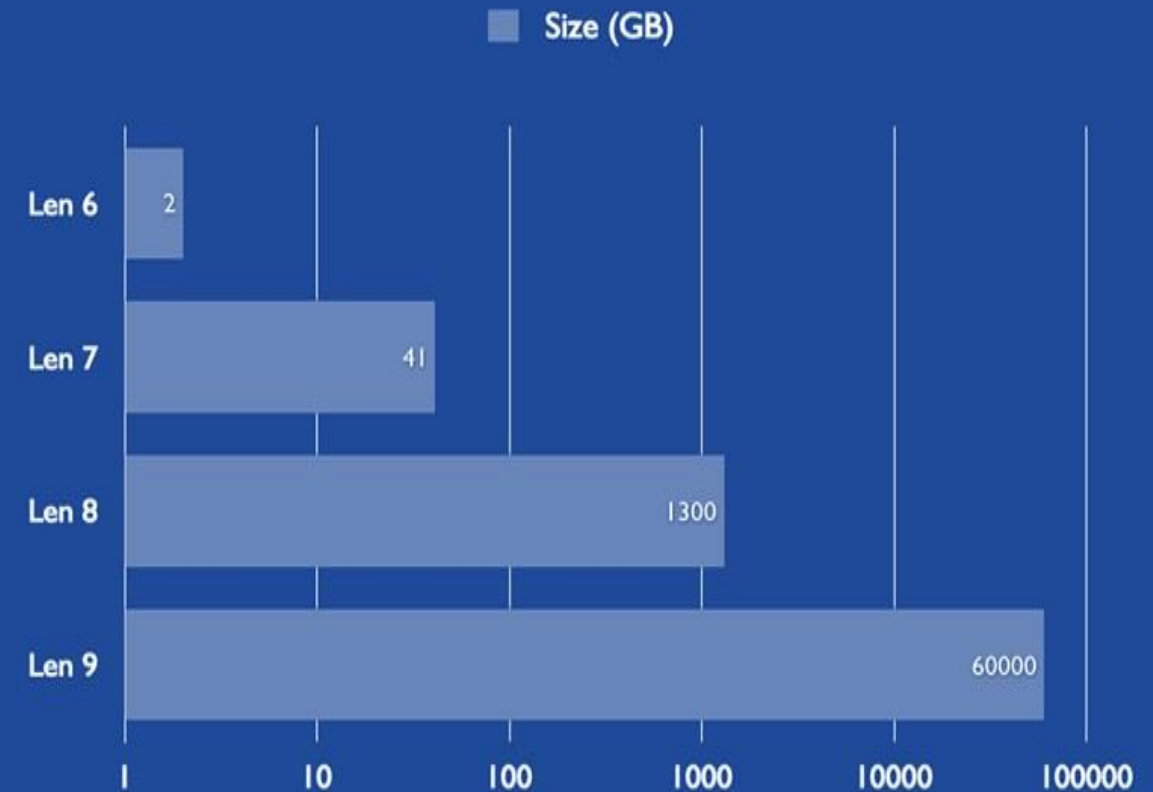
- Weak password is the NO.1 factor.
- Do not install "dangers" APP/software.
- If you have to, use the "dangers" software in VM.
- Do not use the same password for different website/APPs, at least add some "salt".
- Do not register account in "*unsafe*" websites.
- Do not share any password.

Rainbow table

Rainbow Table

Plaintext	MD5 Checksum
1234567	ab23gdv53500w0dnf950wb5bd4eawa
abcedf	2fe34gv30i7ijgk8ow034mdn12mkd86b
abcd1234	87uy9jhsno3856502hdxni93h2c6yd7bx
xyzasd43	aq87nh2np39nfh4655b5i2gg4g0zq2w
computer	dw7b4b4jj3vk2202dbhdnsqg265wjijnc
armyone	g5g556b2n3n45n63v2c18n3bxvztq63v
admin1234	h6v3h39xb21lma282h40o1bmzjw54r4

Rainbow Table Size



<https://ipwithease.com/introduction-to-rainbow-table-cyber-attack/>

Add salt against Rainbow table

User	Password	User	Password Hash
Stephen	auhsoJ	Stephen	39e717cd3f5c4be78d97090c69f4e655
Lisa	hsifdrowS	Lisa	f567c40623df407ba980bfad6dff5982
James	1010NO1Z	James	711f1f88006a48859616c3a5cbcc0377
Harry	sinocarD tupaC	Harry	fb74376102a049b9a7c5529784763c53
Sarah	auhsoJ	Sarah	39e717cd3f5c4be78d97090c69f4e655

User	Random Salt	Password Hash
Stephen	06917d7ed65c466fa180a6fb62313ab9	b65578786e544b6da70c3a9856cdb750
Lisa	51f2e43105164729bb46e7f20091adf8	2964e639aa7d457c8ec0358756cbffd9
James	fea659115b7541479c1f956a59f7ad2f	dd9e4cd20f134dda87f6ac771c48616f
Harry	30ebf72072134f1bb40faa8949db6e85	204767673a8d4fa9a7542ebc3eceb3a2
Sarah	711f51082ea84d949f6e3efecf29f270	e3afb27d59a34782b6b4baa0c37e2958

Hash collision attack



These following two different 128 byte sequences hash to the same:

55

MD5 Hash: 79054025255fb1a26e4bc422aef54eb4



The differences below are highlighted (bold). Sorry it's kind of hard to see.



```
d131dd02c5e6eec4693d9a0698aff95c 2fcab58712467eab4004583eb8fb7f89
55ad340609f4b30283e488832571415a 085125e8f7cdc99fd91dbdf280373c5b
d8823e3156348f5bae6dacd436c919c6 dd53e2b487da03fd02396306d248cda0
e99f33420f577ee8ce54b67080a80d1e c69821bcb6a8839396f9652b6ff72a70
```

and

```
d131dd02c5e6eec4693d9a0698aff95c 2fcab50712467eab4004583eb8fb7f89
55ad340609f4b30283e4888325f1415a 085125e8f7cdc99fd91dbd7280373c5b
d8823e3156348f5bae6dacd436c919c6 dd53e23487da03fd02396306d248cda0
e99f33420f577ee8ce54b67080280d1e c69821bcb6a8839396f965ab6ff72a70
```

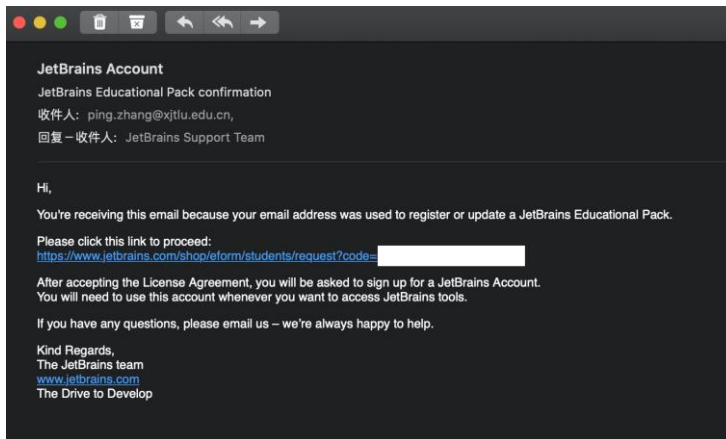
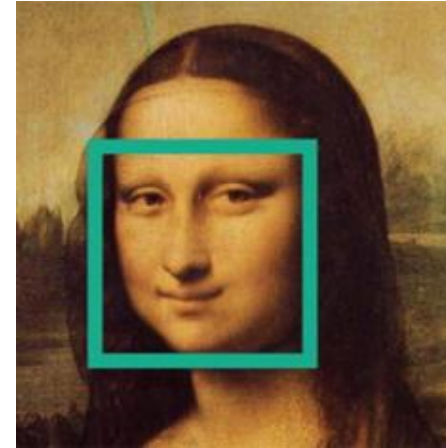
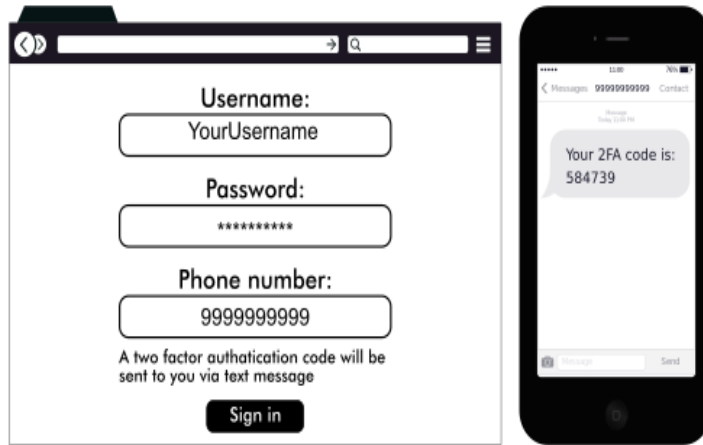


- Dr. 王小云 proved collisions can be found in MD5, SHA-1 algorithms
- She lead the design of SM-3

<https://baike.baidu.com/item/%E7%8E%8B%E5%B0%8F%E4%BA%91/29050>

<https://zhuanlan.zhihu.com/p/377468857>

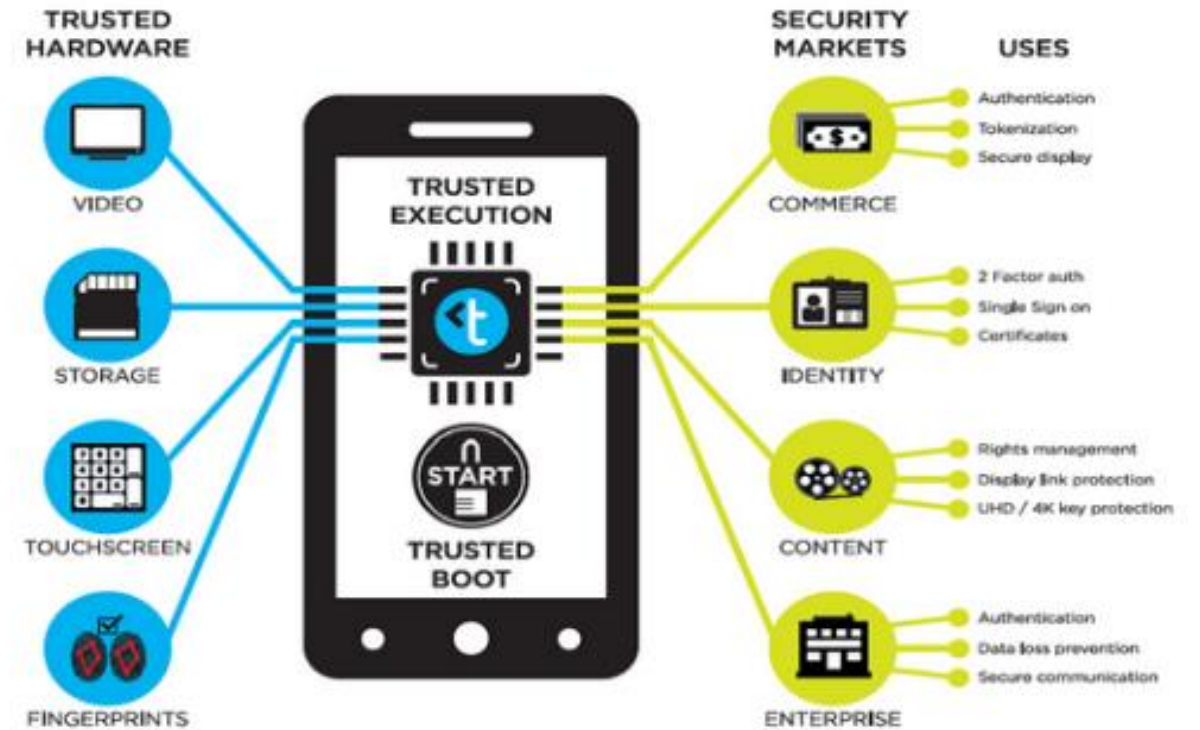
MFA: Multi-Factor Authentication



MFA is a security system that requires more than one method of authentication to verify user's identity for a login or other transaction. Normally, 2 factors are used. **2FA** (Two-factor authentication) is a subset of MFA.

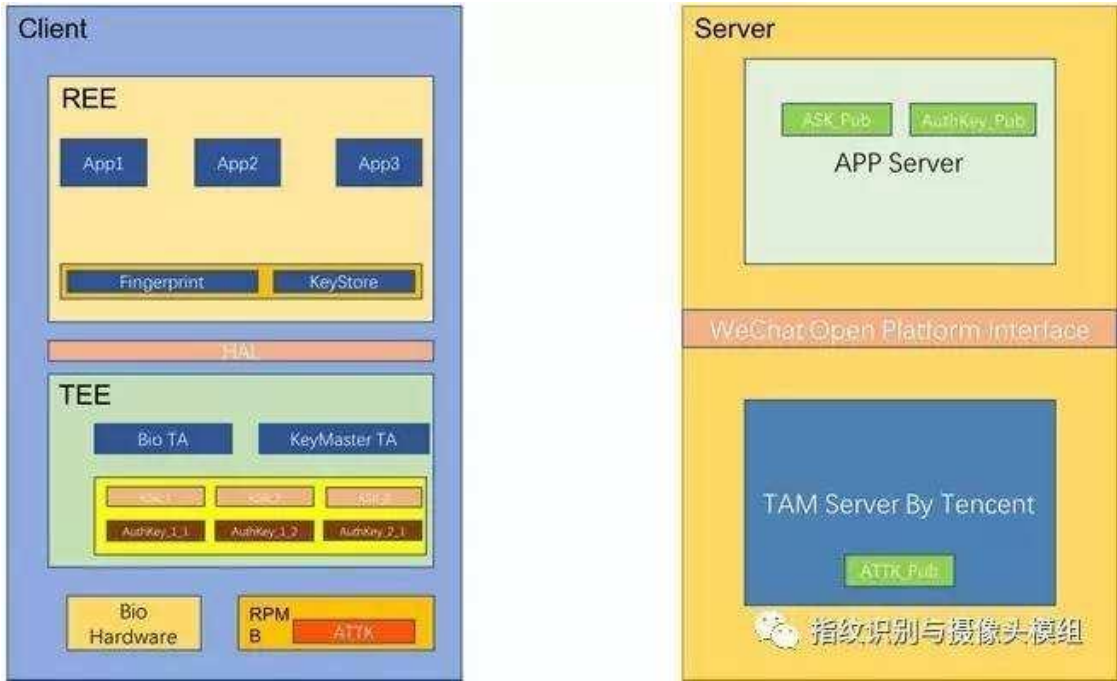
<https://authonet.com/authentication.php>

PKI used for critical applications



- Public Key Infrastructure (PKI) can also be used at the client side.
- Normally the private keys are protected by chips.
- CAs play an important role in USB sticks for PC applications.

Tencent 'soter'

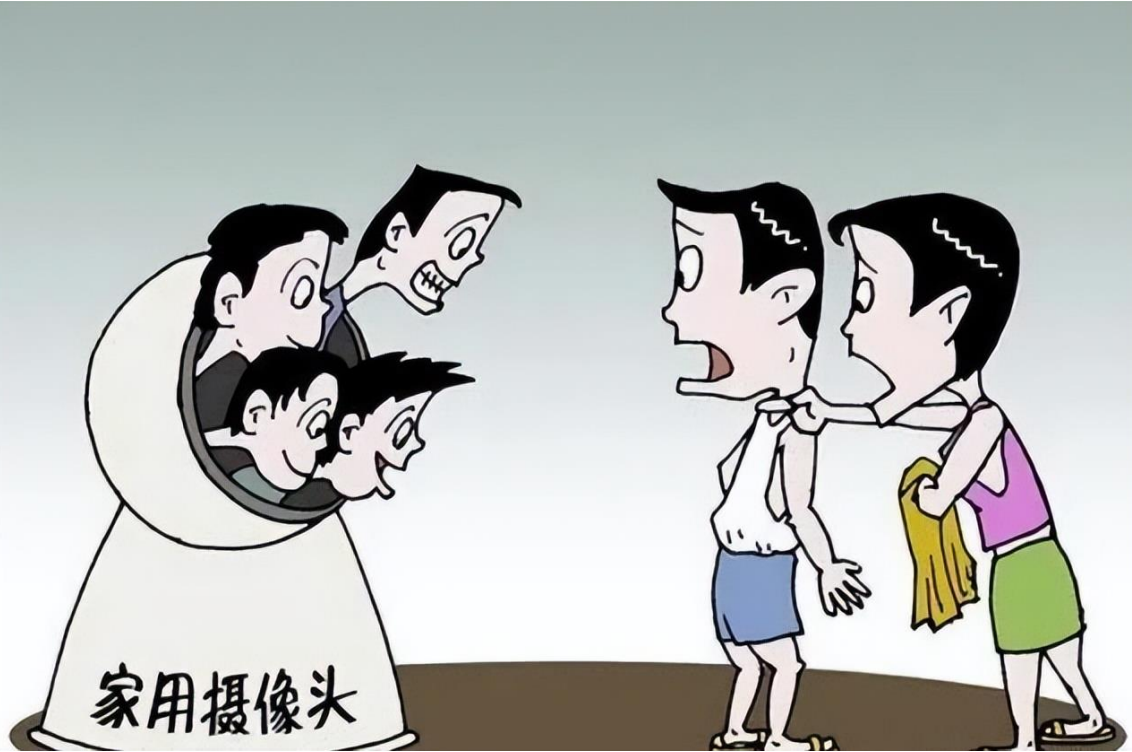


密钥名称	唯一性	作用描述	生成算法	公钥位置	私钥位置
ATK	设备唯一	验证设备合法性	RSA-2048	TAM Server	RPMB
ASK	应用唯一	验证应用合法性	RSA-2048	第三方应用程序 Server	File system as other keys (加密存储、权限控制)
Auth Key	不限数量, 根据业务需要生成	验证业务逻辑唯一性	RSA-2048	第三方应用程序 Server	File system as other keys (加密存储、权限控制)

- It is a correct **BUT** difficult.
- Get all mobile vendors' support to send their root certificates to Tencent.
- Tencent TAM server play like the root CA server.

<https://github.com/Tencent/soter/wiki>

Unauthorized visitors for live camera



https://www.sohu.com/a/361723024_99962827

Wanna to Cry!

ETERNALBLUE | THE NSA-
DEVELOPED EXPLOIT THAT
JUST WON'T DIE



<https://www.ssl2buy.com/cybersecurity/wannacry-ransomware-attack>

<https://www.4hou.com/posts/RMrw>

Wanna to Cry!

Ransomware impacted millions of victims

Destructive ransomworms had a global impact and caused massive financial losses in 2017.

Destructive ransomworms took center stage among notable ransomware in 2017

NotPetya

USD892 million in damages
Spread to **65 countries**

Bad Rabbit

Targeted critical infrastructure

WannaCry

Spread to **150 countries**
USD8 billion+ in damages

Phone + Fishing → Phishing



https://en.wikipedia.org/wiki/2014_Sony_Pictures_hack

Phishing to me



Dr. Yimin Ding
directormail872@gmail.com
2021年5月26日 下午1:44

回复: Available?
收件人: Ping Zhang

Hello Zhang,

I need you to please need to send these me know if you can

In a nearby store, there are some prospects I and I haven't been able to get them myself. Let you further details. I'll reimburse you.

YD

拷贝地址
添加到VIP
屏蔽联系人
新建电子邮件
从以前的收件人列表中移除
添加到通讯录
搜索“Dr. Yimin Ding”

ues urc
2023年
收件人:

LU-AAU-AVPE, XJTLU-AAU-AoPHA-PPS,

2023年第一季度
财政补....docx

W

拷贝地址
添加到VIP
屏蔽联系人
新建电子邮件
添加到通讯录
搜索“ues urc”

Tools cannot guarantee safe, but with people



```
erk: C0 CE FE 84 C2 27 F7 5B D0 7A 7E B8 46 50 9F 93 B2 38 E7 70 DA CB 9F F4 A3 88 F8 12 48 2B E2 1B
riv: 47 EE 74 54 E4 77 4C C9 B8 96 0C 7B 59 F4 C1 4D
pub: C2 D4 AA F3 19 35 50 19 AF 99 D4 4E 2B 58 CA 29 25 2C 89 12 3D 11 D6 21 8F 40 B1 38 CA B2 9B 71 01 F3 AE B7 2A 97 50 19
R: 80 6E 07 8F A1 52 97 90 CE 1A AE 02 BA DD 6F AA A6 AF 74 17
n: E1 3A 7E BC 3A CC EB 1C B5 6C C8 60 FC AB DB 6A 04 8C 55 E1
K: BA 90 55 91 68 61 B9 77 ED CB ED 92 00 50 92 F6 6C 7A 3D 8D
Da: C5 B2 BF A1 A4 13 DD 16 F2 6D 31 C0 F2 ED 47 20 DC FB 06 70
```

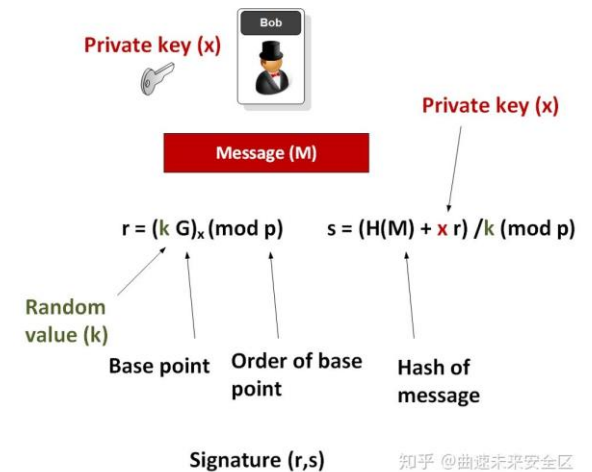
-geohot

props to fail0verflow for the asymmetric half
no donate link, just use this info wisely
i do not condone piracy

if you want your next console to be secure, get in touch with me. any of you 3.
it'd be fun to be on the other side.

...and this is a real self, hello world
although it's not NPDRM, so it won't run off the hard drive
shouts to the guys who did PSL1GHT
without you, I couldn't release this

first piece of homebrew you can run
put in service mode, put on usb stick, boot



- **Again**, But more important thing is about people and related regulations.
- Sony PS3 use a **fixed** "random" number, the door opens for everyone.

Or accidents

< 返回

微博热搜

...

我的

热搜

文娱

要闻

同城

更多

1

微信QQ出现功能异常

4128696

新

2

微信朋友圈

2861654

南方都市报



腾讯微信团队

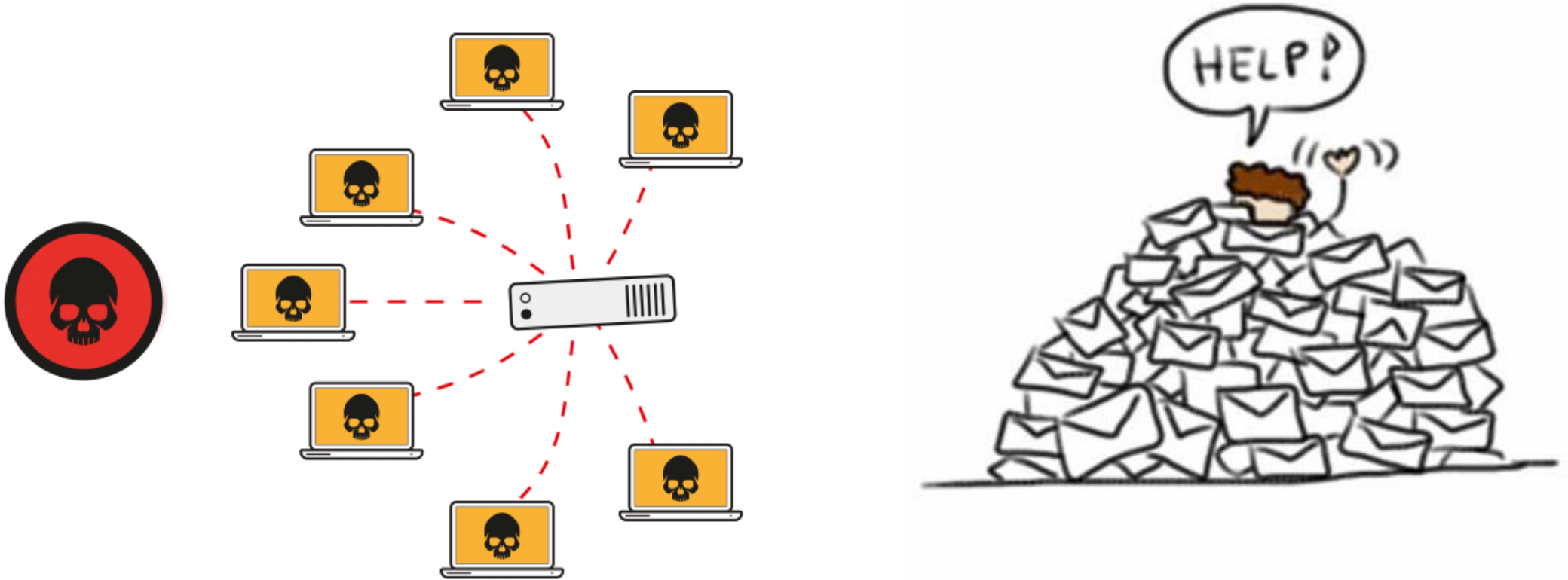
38 分钟前

今天凌晨部分用户使用微信、微信支付相关功能出现异常，经工程师抢修，系统正在逐步恢复，很抱歉给大家带来不便。

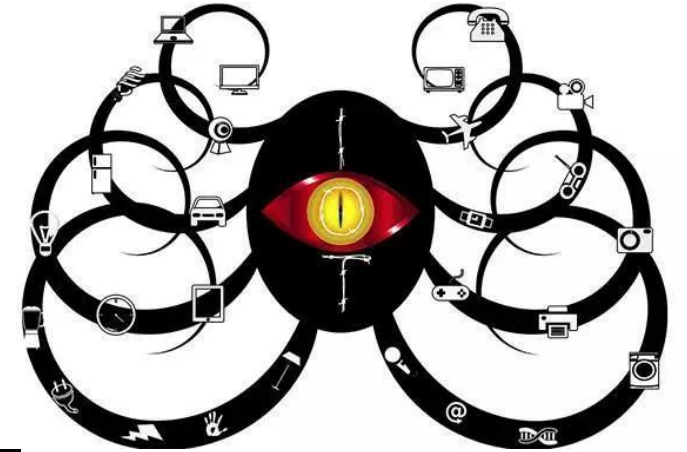
And accidents



DDOS(Distributed Denial of Service)



Attacks never sleep



briankrebs 
@briankrebs

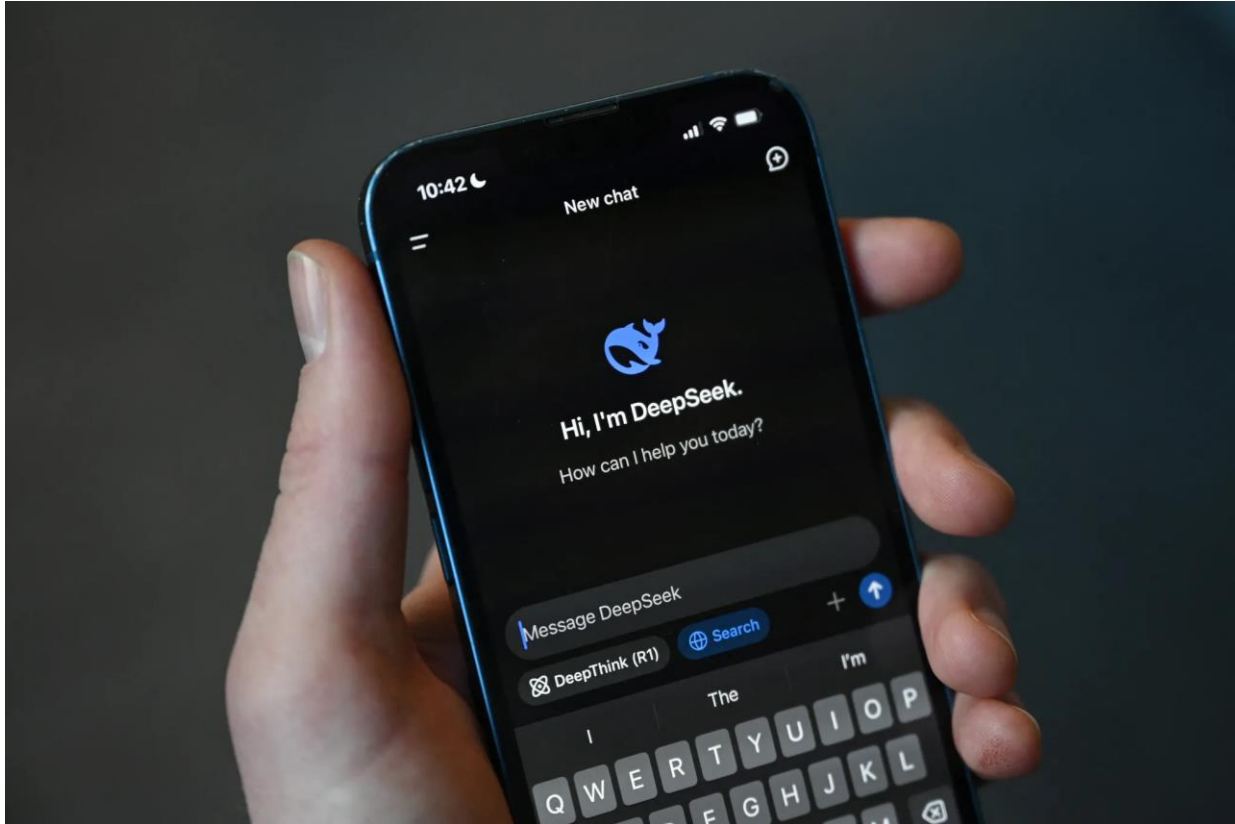
Holy moly. Prolexic reports my site was just hit with the largest DDOS the internet has ever seen. 665 Gbps. Site's still up. #FAIL

3:02 AM - 21 Sep 2016

Largest DDoS attack the Internet has ever seen!
665 Gbps!

<https://zhuanlan.zhihu.com/p/89428085>

DDOS bomb DeepSeek



- **The peak traffic is over 3Tbps!**

https://blog.csdn.net/qq_22866291/article/details/145405785

Matrix is another real world



News
Release

华人生活情报局
ID:73830932

- Police warning: Be care your bank cards!!!



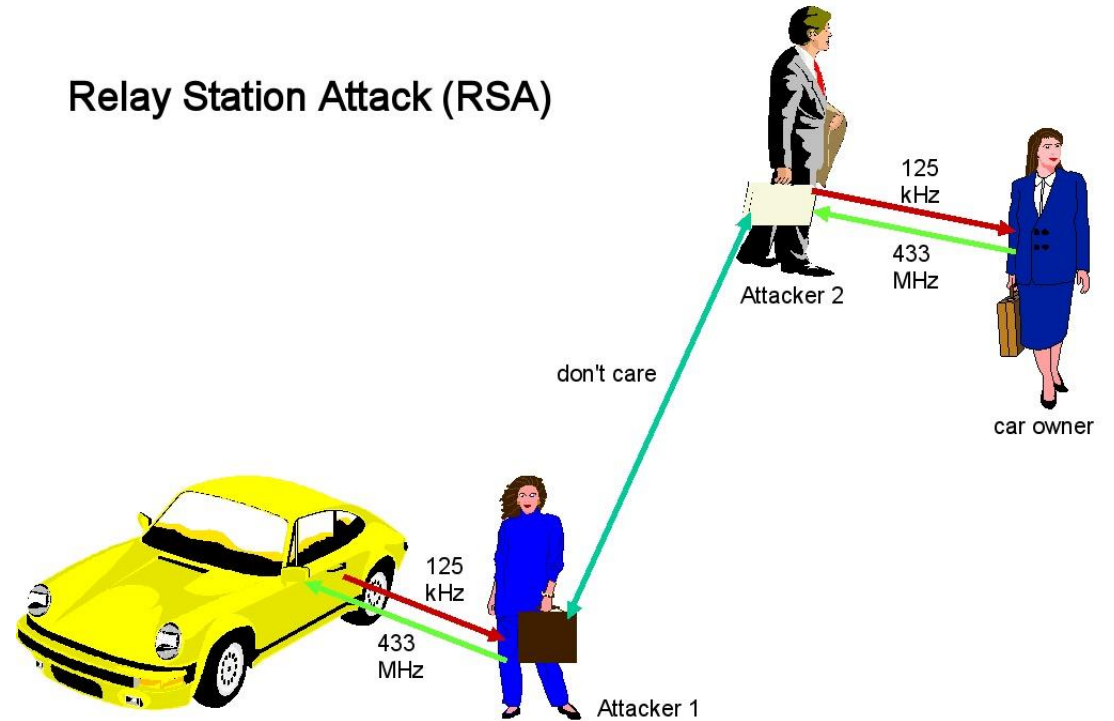
华人生活情报局
ID:73830932

Matrix is another real world



- NFC cards can be easily faked.

Even Tesla cars have been attacked



<https://www.threatshub.org/blog/new-bluetooth-hack-can-unlock-your-tesla-and-more/>

Risk = Threat Probability * Vulnerability Impact



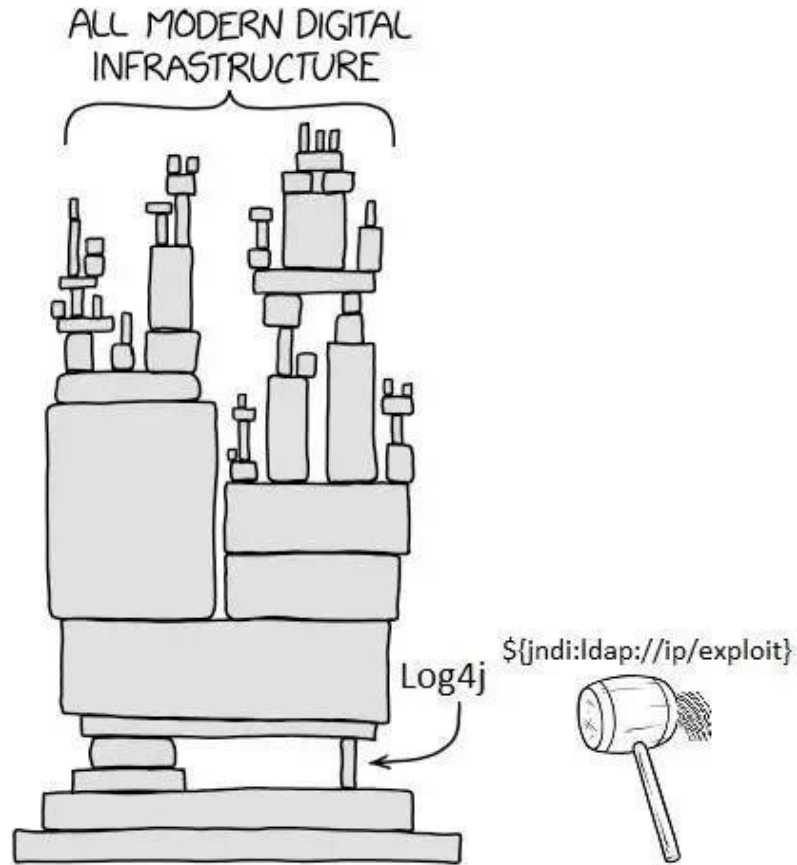
- **Risk** is a combination of the threat probability and the impact of a vulnerability.
- In other words, risk is the probability of a threat agent successfully exploiting a vulnerability.

Threat



- A **threat** is any type of danger, which can damage or steal data, create a disruption or cause a harm in general.
- Common examples of threats include malware, phishing, data breaches and even rogue employees.
- Or a set of potential incidents in which a **threat agent** causes a threat event to an asset using a **specific entry point** into the system

Vulnerability

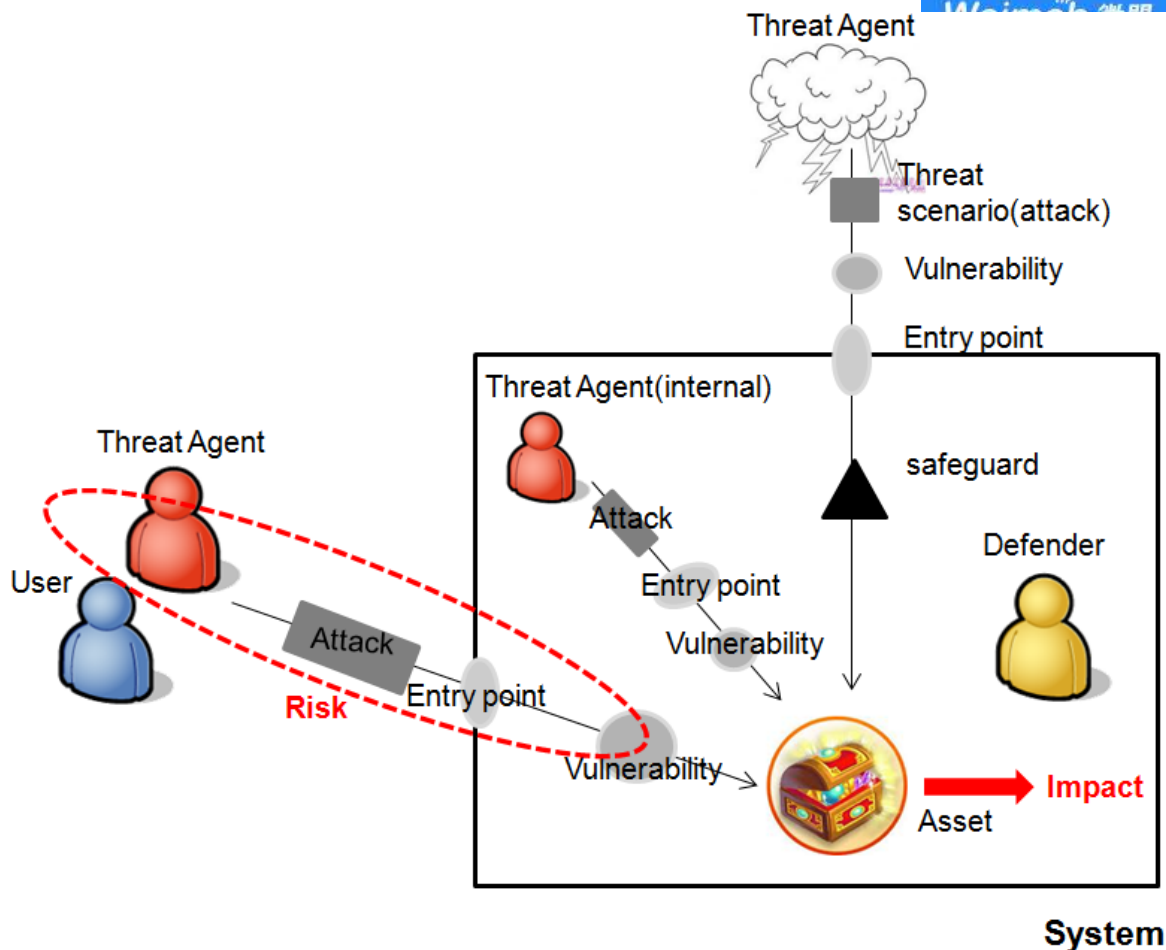


- A **vulnerability** is a weakness in hardware, software, **personnel** or **procedures**, which may be exploited by threat actors in order to achieve their goals.
- Many famous vulnerabilities, such as Log4j in 2020.
- Vulnerabilities can be marked by Common Vulnerability Scoring System or CVSS.
- It is **not** only hardware and software, **but** human being.
- A vulnerability, to which fix is not yet available, is called a **zero-day** vulnerability.

<https://lifars.com/2020/07/threat-vulnerability-risk-what-is-the-difference>

<https://www.securingpeople.com/security-risk-assessment/threat-vulnerability-risk/>

Risk is **ALSO** about people



关于微盟系统故障的通告

微盟 股票代码 3.HK 解决方案 渠道合作 关于微盟 投资者关系

关于微盟系统故障的通告

尊敬的微盟商户：

和您一样，我们一起度过了煎熬的36小时，我们预计此次故障还会持续一段时间，现就此次系统故障作如下通告：

2月23日19点，我们收到系统监控报警，服务出现故障，随后我们立刻召集相关技术人员进行定位，发现大面积服务集群无法响应，生产环境及数据遭受严重破坏。我们立刻启动应急响应机制，并与腾讯云技术团队一起研究制定生产环境和数据修复方案。

截止到2月25日7点，我们的生产环境和数据修复都在有序的进行，我们预计2月25日晚上24点前我们的生产环境将修复完成，微盟所有新用户将可恢复服务，老用户由于数据修复时间问题，我们将提供临时过渡方案，我们预计老用户数据修复将可在2月28日晚上24点前完成。

我们事后对恶意破坏生产环境的犯罪嫌疑人进行追踪分析，成功定位到犯罪嫌疑人登录账号及IP地址，并于2月24日向宝山区公安局报案，目前犯罪嫌疑人已经被宝山区公安局进行刑事拘留，犯罪嫌疑人承认了犯罪的事实。犯罪嫌疑人乃微盟研发中心运维部核心运维人员贺某，贺某于2月23日晚18点56分通过个人VPN登入公司内网跳板机，因个人精神、生活等原因对微盟线上生产环境进行了恶意的破坏。

针对此次事故微盟深表歉意，我们正在拟定相关赔付方案来补偿因此次事故而遭受损失的商家，我们对此次因人为造成的事故灾难无比愧疚，我们今后将一定吸取这个惨痛的教训，加强对线上运维的治理，同时我们也对因远程办公而疏忽对员工的精神状态的关注而深表痛惜！

微盟集团

- Risk is **NOT** only about technology.

CIA triad



The CIA Triad

What Is the CIA?

Confidentiality	Integrity	Availability
I send you a message, and no one else knows what that message is.	I send you a message, and you receive exactly what I sent you	I send you a message, and you receive it

What's The Purpose of the CIA?

Data is not disclosed	Data is not tampered	Data is available
-----------------------	----------------------	-------------------

How Do You Achieve the CIA?

e.g., Encryption	e.g., Hashing, Digital signatures	e.g., Backups, redundant systems
------------------	-----------------------------------	----------------------------------

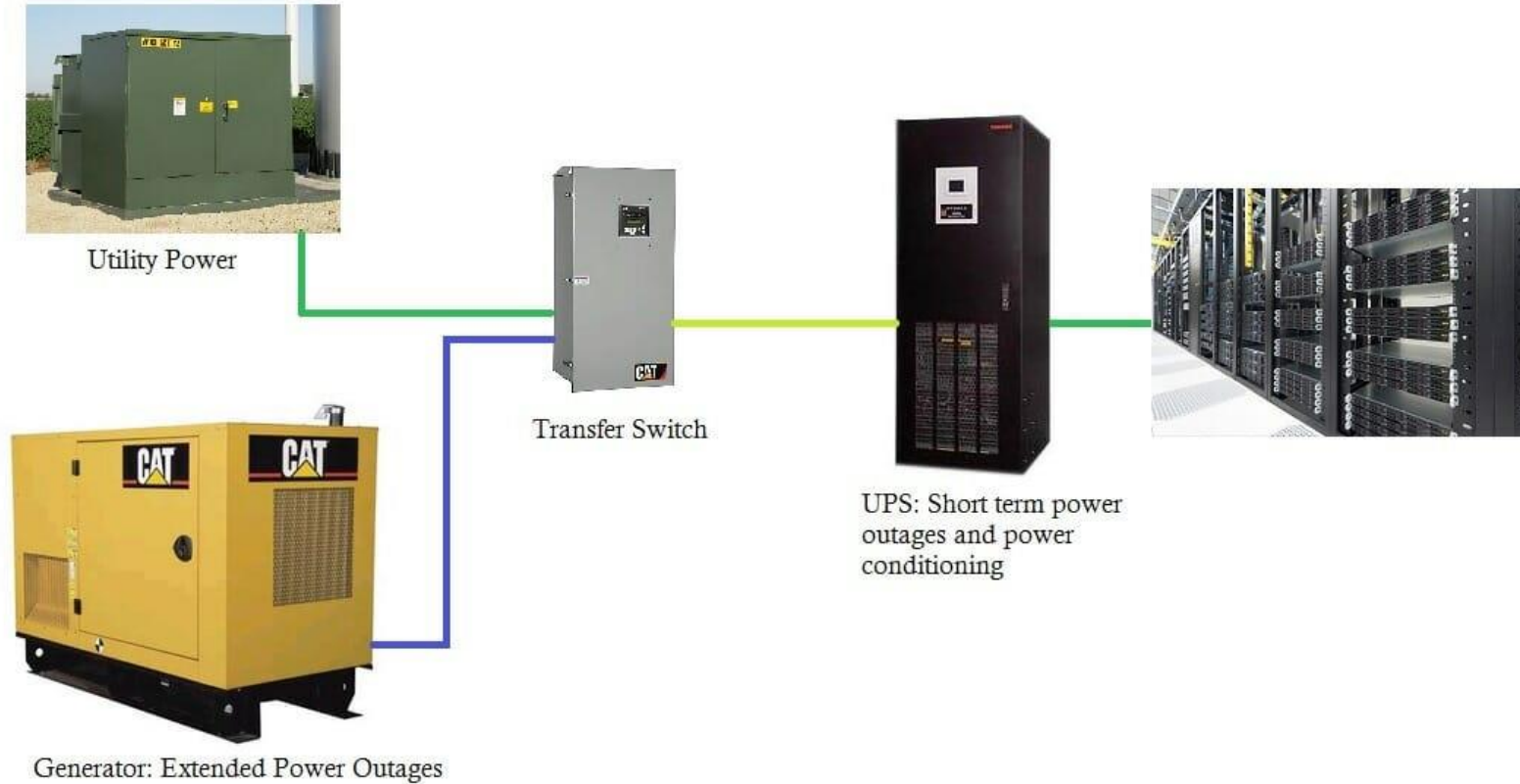
Opposite of CIA

Disclosure	Alteration	Destruction
------------	------------	-------------

<https://www.cybernewsbox.com/cia-triad/>

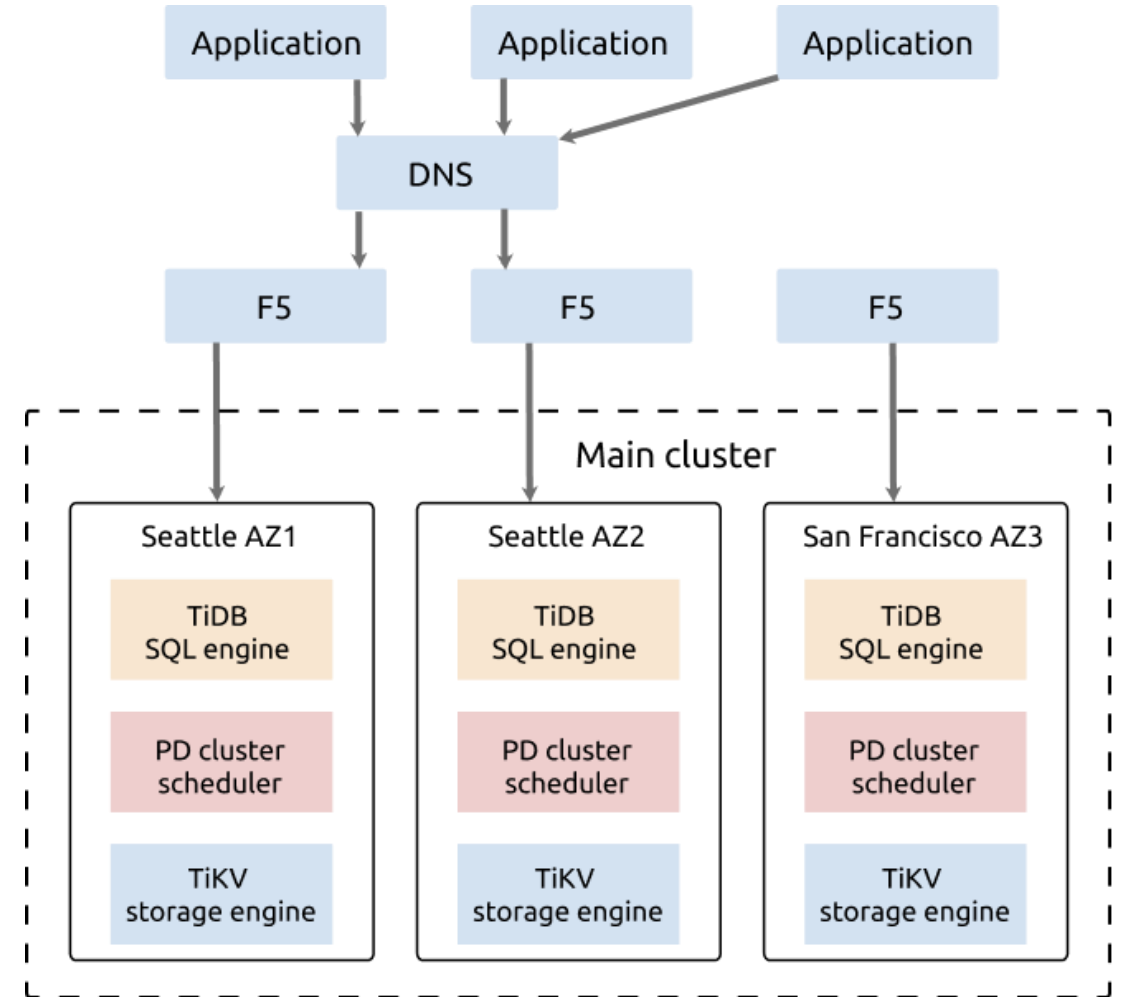
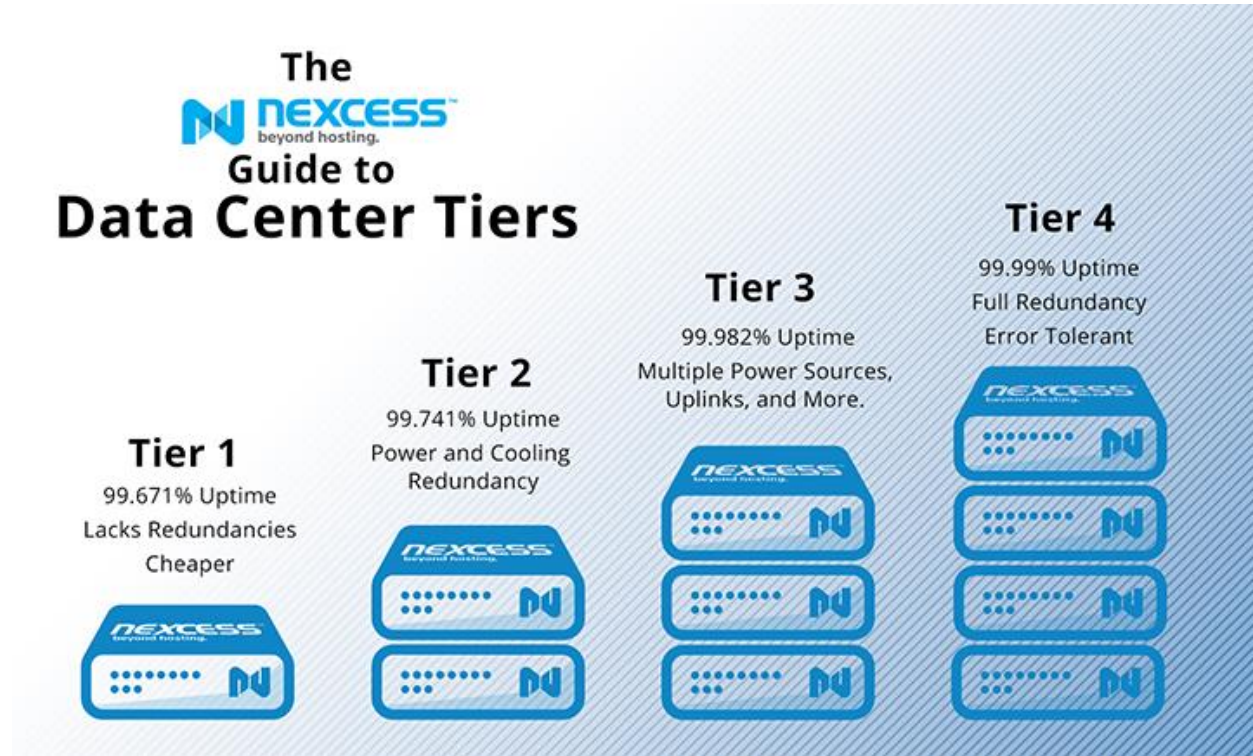
<https://digitalforensicforest.com/2017/12/14/confidentiality-integrity-availability-cia/>

Reliable infrastructure



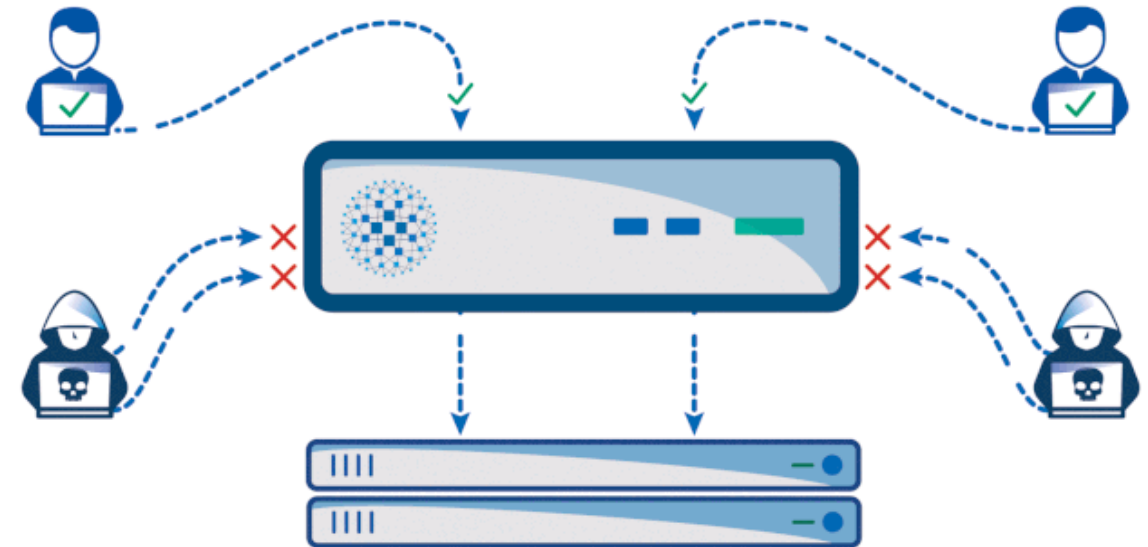
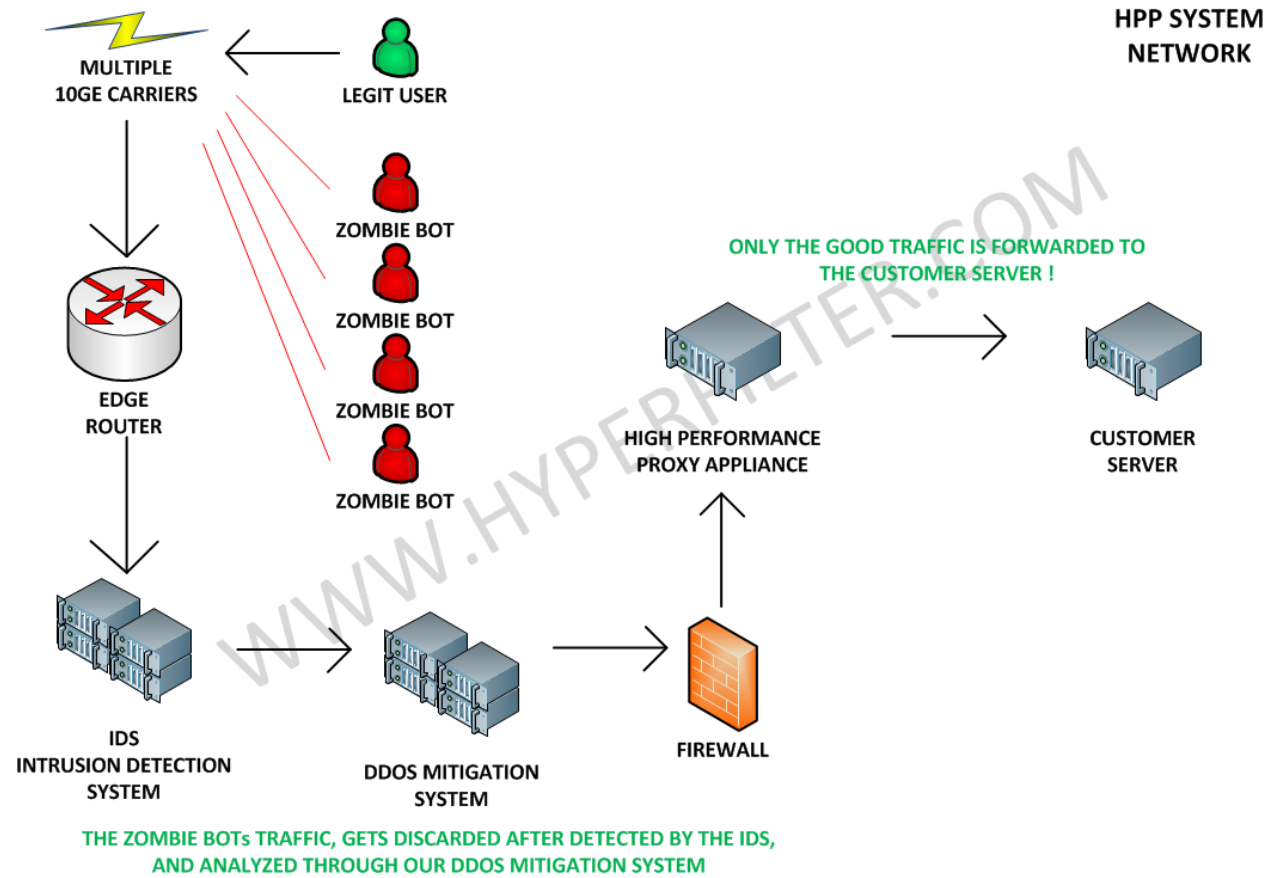
<https://www.qpsolutions.net/ups/how-ups-systems-protect-your-bottom-line/>

Infrastructure level



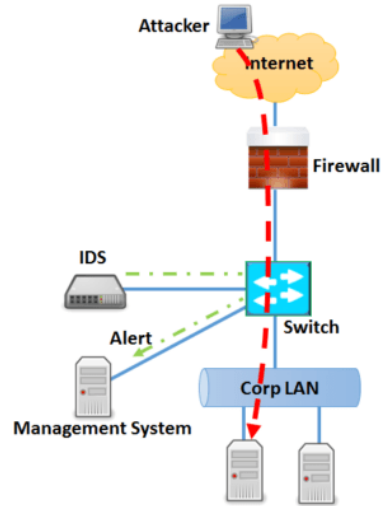
<https://www.nexcess.net/blog/what-are-data-center-tiers-explained/>

DDOS filtering

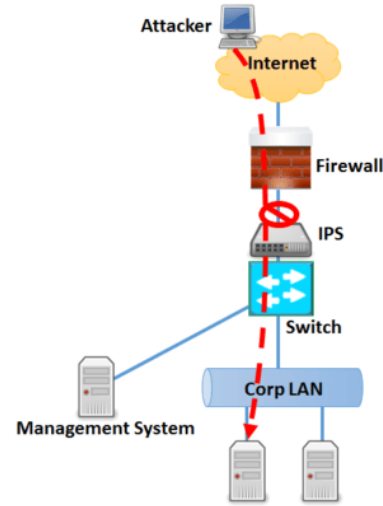


Application level

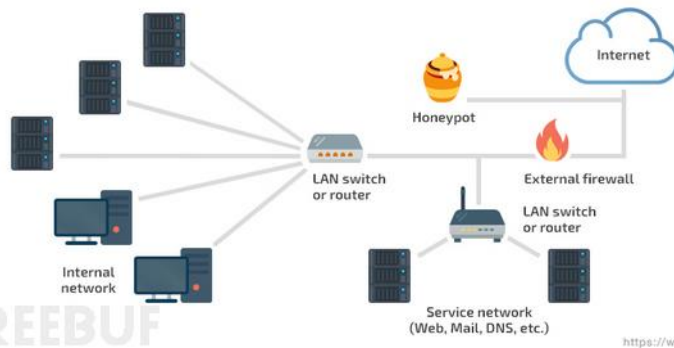
Intrusion Detection System



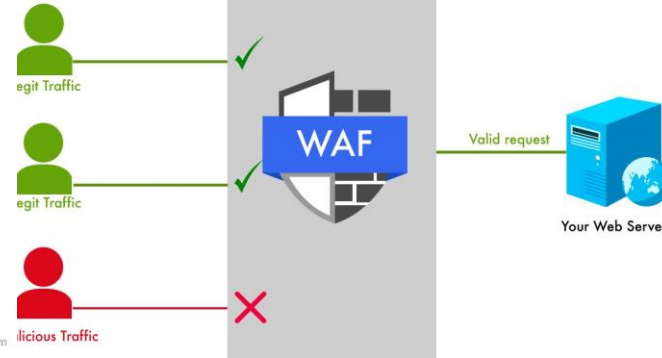
Intrusion Prevention System



HONEYPOT DEPLOYMENT



<https://www.apriorit.com>



SQL Injection

Vulnerability used by attackers to corrupt or modify data stored in the database

Cross Site Scripting (XSS)

Injects client-side scripts to deface application, redirect users, steal valuable information

Denial of Service Attacks

Prevents legitimate users to access the application by flooding the network resulting in application slowdown or complete shutdown

Cross Site Request Forgery(CSRF)

Forcing or tricking users to perform unusual actions

Session Hijacking

Modifying cookie to gain unauthorized access to information

Parameter Tampering

Changing URL parameters or form field data without user's authorization

Code Injection

Injecting scripts on the server side by unauthorized means to install malwares, backdoors, exploit server resources, steal valuable information

Buffer Overflows

Attacker sends crafted data to cause buffer overflows on server resulting in corrupted data, segmentation faults, exceptions etc

How to know the security is good enough?



Network security level protection

网络安全等级保护
(等保2.0)



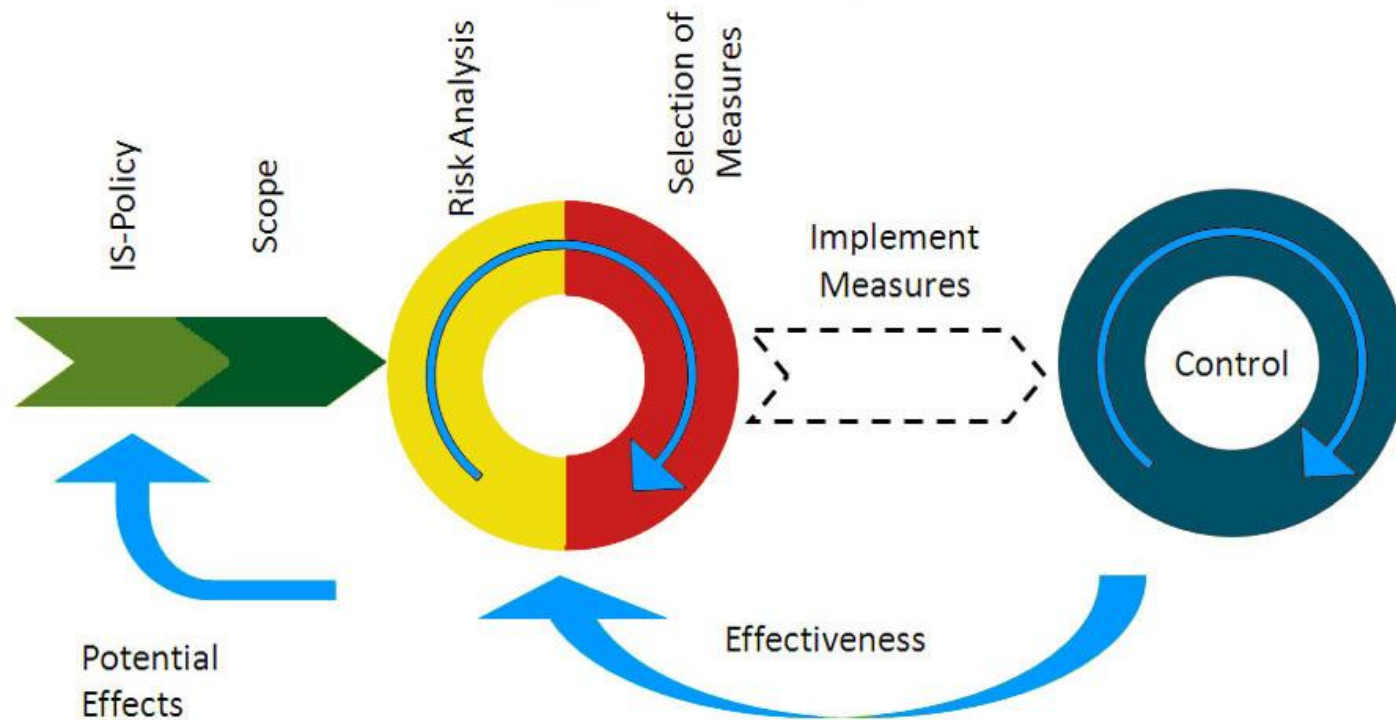
- There is **NO** absolute security.
- Do the enough and appropriate evaluation and **investment**.
- Good **enough** lock for the asset.
- The highest risk is:
"You believe you are safe!!!"

Network security level protection

L1:	Once damaged, it will cause damage to the legitimate rights and interests of relevant citizens, legal persons, and other organizations, but it does not endanger national security, social order, and public interests of the general network;
L2:	Once damaged, it will cause serious damage to the legitimate rights and interests of relevant citizens, legal persons, and other organizations, or pose a threat to social order and public interests, but does not endanger the general network of national security;
L3:	Once damaged, it will cause particularly serious damage to the legitimate rights and interests of relevant citizens, legal persons, and other organizations, or cause serious harm to social order and public interests, or pose a threat to national security through important networks;
L4:	Once disrupted, it will cause particularly serious harm to social order and public interests, or pose a serious threat to national security through particularly important networks;
L5:	An extremely important network that can cause particularly serious harm to national security once damaged.

Manage the risks

ISO / IEC 27000 Information Security Management System (ISMS)

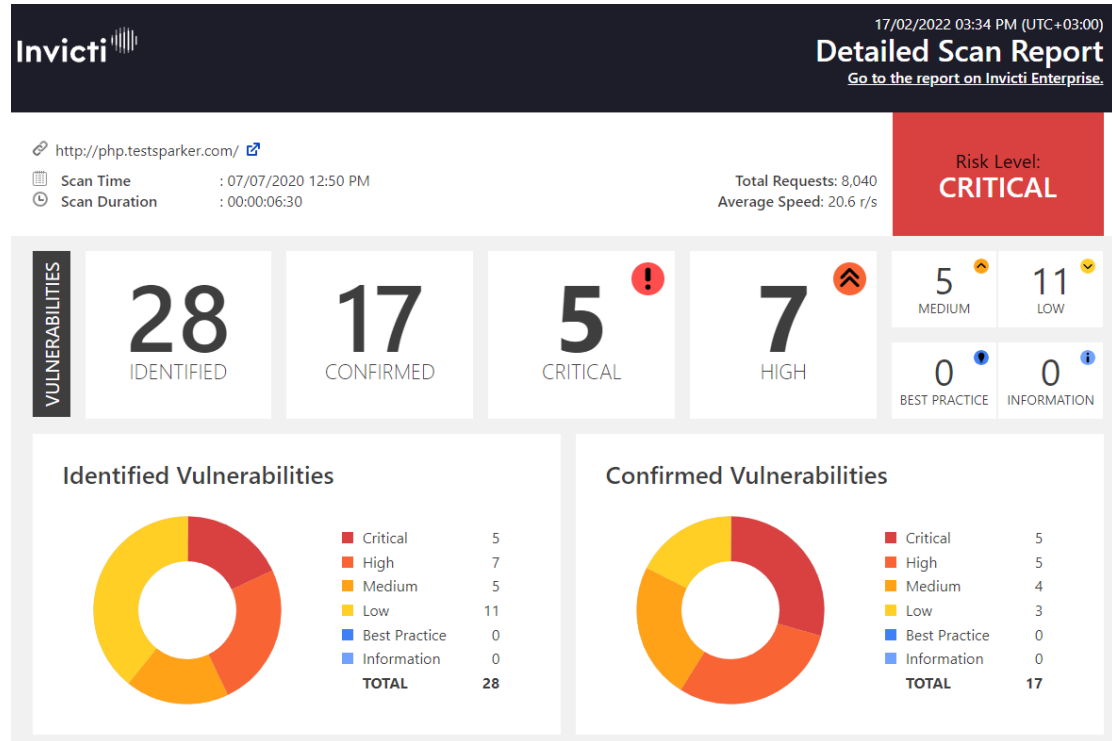


- Normally we may think security products like firewall, anti-virus software will make us safe.
- But don't forget **people** and related **regulations**.
- **ISO27000** ensuring **Integrity** & **Confidentiality**. It was divided to many topics category in:
 - Physical and Environmental Security
 - Human Resource security
 - Access control

<https://www.trueability.com/security/>

<https://www.mitre.org/capabilities/cybersecurity/overview/cybersecurity-blog/more-ancient-wisdom-for-the>

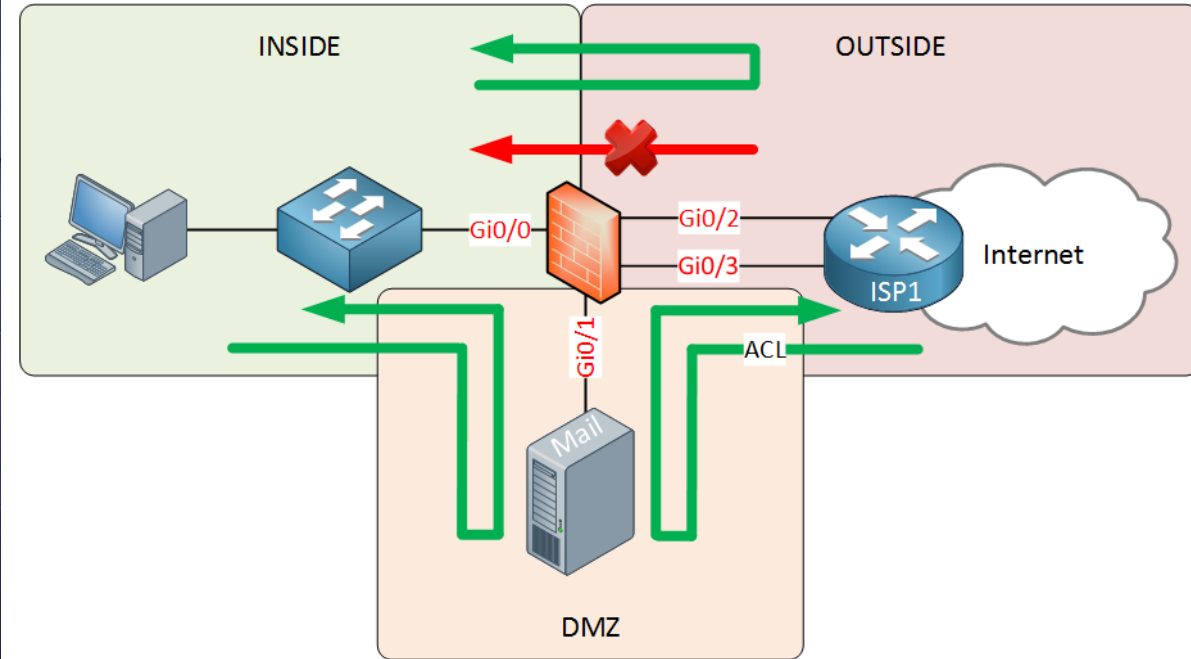
Vulnerability Assessment Scanning



Vulnerability Identifier	Affected Application	Reported
CVE-2019-0604	Microsoft® SharePoint® ¹⁵	15 May 2019 [8]
CVE-2019-19781	Citrix® ¹⁶ Gateway, Citrix® Application Delivery Controller, and Citrix® SD-WAN WANOP appliance	22 Jan 2020 [9]
CVE-2019-3396	Atlassian® Confluence® ¹⁷ Server	20 May 2019 [10]
CVE-2019-3398	Atlassian® Confluence Server and Atlassian® Confluence Data Center	26 Nov 2019 [11]
CVE-2019-9978	WordPress® ¹⁸ "Social Warfare" Plugin	22 Apr 2019 [12]
CVE-2019-18935 CVE-2017-11317 CVE-2017-11357	Progress® Telerik® ¹⁹ UI	7 Feb 2019 [13]
CVE-2019-11580	Atlassian® Crowd and Crowd Data Center	15 July 2019 [14]
CVE-2020-10189	Zoho® ManageEngine® ²⁰ Desktop Central	6 Mar 2020 [15]
CVE-2019-8394	Zoho® ManageEngine® ServiceDesk Plus	18 Feb 2019 [16]
CVE-2020-0688	Microsoft® Exchange® ²¹ Server	10 Mar 2020 [17]
CVE-2018-15961	Adobe® ColdFusion® ²²	8 Nov 2018 [18]

<https://www.softwaretestinghelp.com/vulnerability-assessment-tools/>

Apply proper products and regulations



Test them regularly

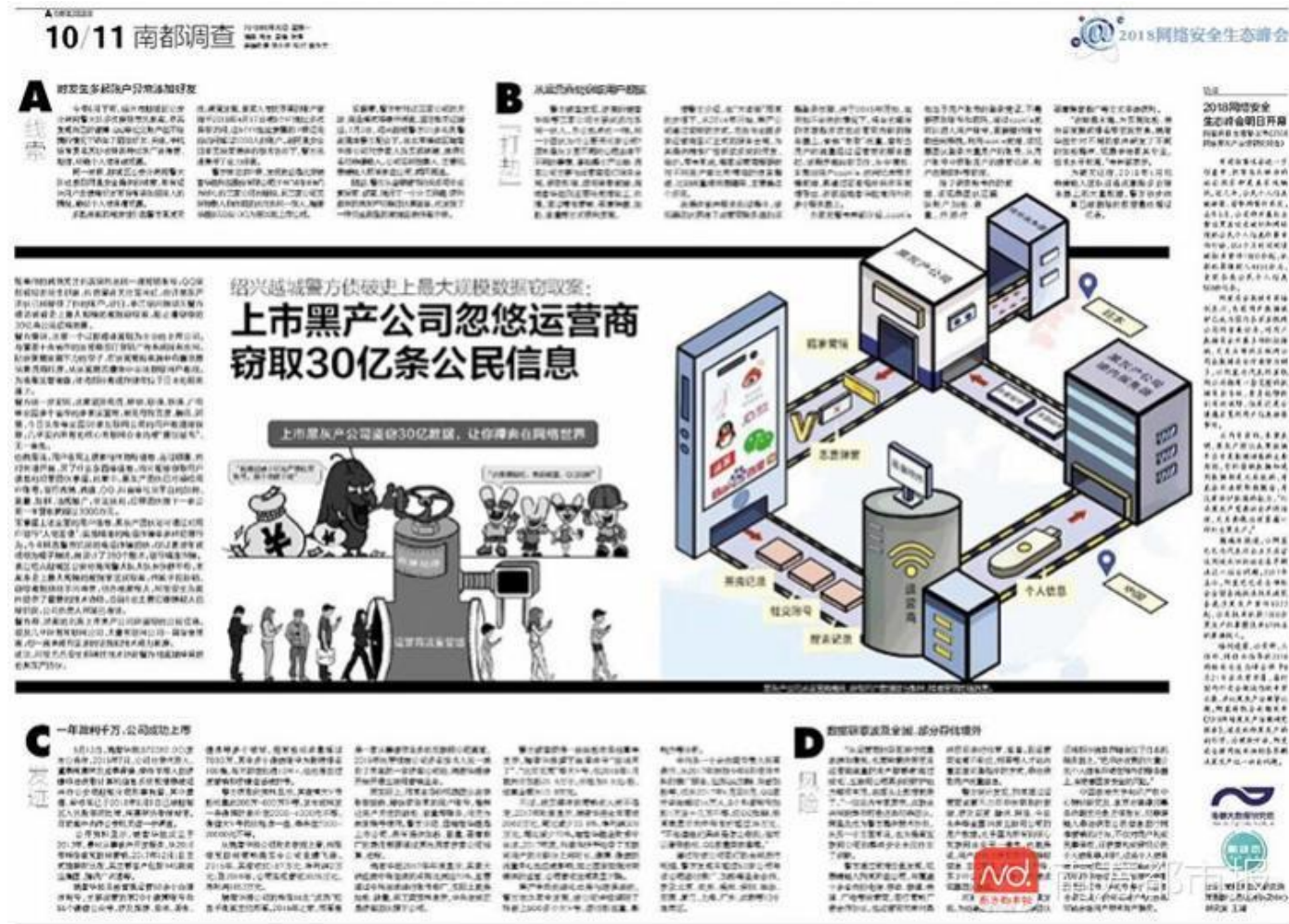


<https://www.simplilearn.com/tutorials/cyber-security-tutorial/what-is-penetration-testing>

Do we safe now?



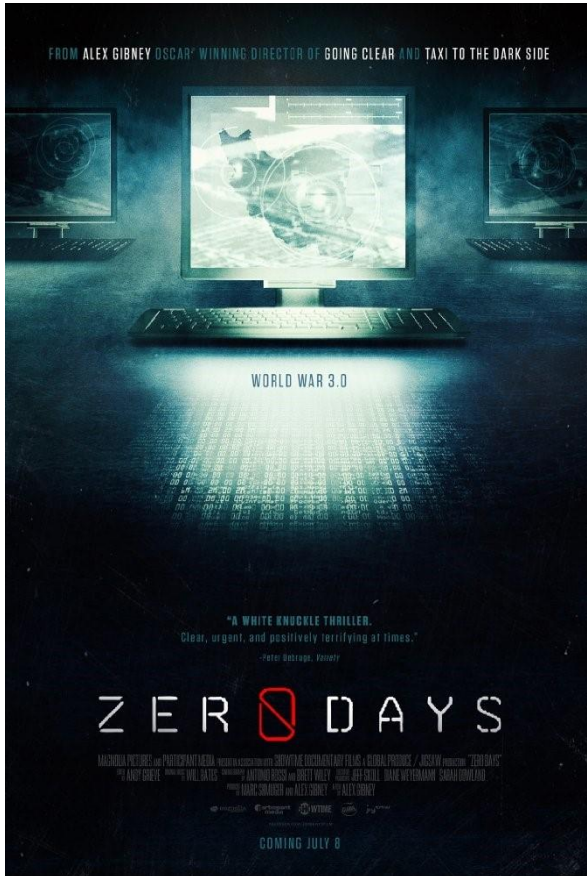
Thinks about this one



- Get the session key within telecom operators.

<https://baijiahao.baidu.com/s?id=1609311065725352764>

Or by nations



<https://zhuanlan.zhihu.com/p/24037701>

ECHELON program



EUROPEAN PARLIAMENT

1999



2004

Session document

11 July 2001

FINAL
A5-0264/2001
PAR1

REPORT

on the existence of a global system for the interception of private and commercial communications (ECHELON interception system) (2001/2098(INI))

Part 1: Motion for a resolution
Explanatory statement

Temporary Committee on the ECHELON Interception System

Rapporteur: Gerhard Schmid

PE 305.391

- In the early 1990s, the US National Security Agency intercepted the communications between the Airbus and the Saudi Arabian national airline. In 1994, Airbus lost a \$6 billion contract with Saudi Arabia and McDonnell Douglas (now part of Boeing) won the multibillion-dollar contract instead of Airbus.
- The United States defense contractor Raytheon won a US\$1.3 billion contract with the Government of Brazil to monitor the Amazon rainforest. Raytheon's French competitor is Thomson-Alcatel.



<https://en.wikipedia.org/wiki/ECHELON>

You may also know these cases



For decades, countries all over the world trusted a single company to keep the communications of their spies, soldiers and diplomats secret.

The Swiss company, Crypto AG, was secretly owned by the CIA.

由翻译自 英语 Google

几十年来，全世界的各个国家都信任一家公司来保护其间谍，士兵和外交官的通讯保密。

瑞士公司Crypto AG由CIA秘密拥有。

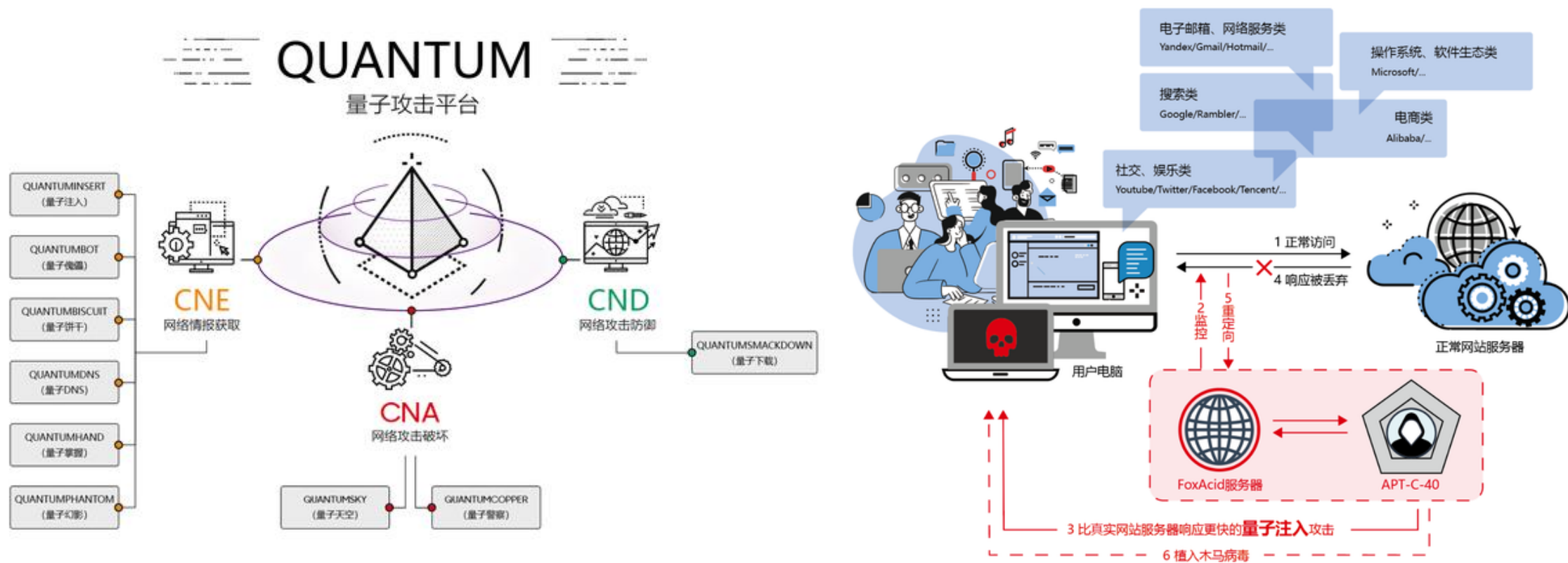


The CIA secretly bought a company that sold encryption devices across th...
U.S. and German intelligence agencies partnered on a scheme to dupe
dozens of nations into buying rigged encryption systems — taking their ...
[washingtonpost.com](https://www.washingtonpost.com)

上午3:14 · 2020年2月12日 · SocialFlow

<https://www.zhihu.com/question/371511579/answer/1013863094>

And ...



<https://baijiahao.baidu.com/s?id=1727991608277846854>